

Daily Vulnerability Report - 2026-09-09

Window (UTC): 2026-09-09T00:00 to 2026-09-10T00:00 | Sources: NVD, CISA KEV, FIRST EPSS | Generated 2026-09-17 05:54:22 UTC

Total	KEV (exploited)	Critical	High	Medium	Low	Unscored	Watchlist
2411	19	293	1143	847	95	30	845

P1 - Act now (KEV / high EPSS)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75650	10.0	CRIT	Yes	0.021	adobe:commerce, adobe:commerce_b2b, adobe:magento	Adobe Commerce is affected by an Improper Neutralization of Special Elements Used in a Template Engine vulnerability that could result in arbitrary code execution in the context of the current user. An attacker could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-86218	10.0	CRIT	Yes	0.007	n-able:n-central	N-central is vulnerable to a pre-auth remote code execution This issue affects N-central: before 2026.3.1.14.
CVE-2025-14733	9.3	CRIT	Yes	0.265	watchguard:firebox_m270, watchguard:firebox_m290, watchguard:firebox_m295, watchguard:firebox_m370, watchguard:firebox_m	An Out-of-bounds Write vulnerability in the WatchGuard Fireware OS iked process may allow a remote unauthenticated attacker to execute arbitrary code. This vulnerability affects both the mobile user VPN with IKEv2 and the branch office VPN using IKEv2 when configured with a dynamic gateway peer. If the Firebox was previously configured with the mobile user VPN with IKEv2 or a branch office VPN using IKEv2 to a dy...
CVE-2026-87491	8.8	HIGH	Yes	0.01	google:chrome	Out of bounds write in V8 in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code inside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-81963	7.8	HIGH	Yes	0.006	microsoft:windows_11_23h2, microsoft:windows_11_24h2, microsoft:windows_11_25h2, microsoft:windows_11_26h1, microsoft:wi	Improper link resolution before file access ('link following') in Windows Update Stack allows an authorized attacker to elevate privileges locally.
CVE-2026-85880	7.8	HIGH	Yes	0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows ALPC allows an authorized attacker to elevate privileges locally.
CVE-2025-25249			Yes	0.024	fortinet:multiple products	Fortinet FortiOS, FortiSwitchManager, and FortiSASE contain a heap-based buffer overflow vulnerability that allows an attacker to execute unauthorized code or commands via specially crafted packets.
CVE-2026-19490			Yes	0.056	citrix:netscaler	Citrix NetScaler ADC and NetScaler Gateway contain an authentication-bypass vulnerability involving an alternate path or channel. When the NetScaler appliance is configured as an AAA virtual server or as a Gateway (SSL VPN, ICA Proxy, CVPN, or RDP Proxy), an unauthenticated remote threat actor may be able to bypass authentication.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-20079			Yes	0.758	cisco:secure firewall management center (fmc) and security cloud control (scc) firewall management	Cisco Secure Firewall Management Center (FMC) Software and Cisco Security Cloud Control (SCC) Firewall Management contain an authentication Bypass using an alternate path or channel vulnerability that could allow an unauthenticated, remote attacker to bypass authentication and execute script files on an affected device to obtain root access to the underlying operating system.
CVE-2026-42016			Yes	0.009	jfrog:artifactory	JFrog Artifactory contains an incorrect authorization vulnerability that leads to a privilege escalation attack due to a validation check of the token signature/issuer and not the token's scope.
CVE-2026-42018			Yes	0.009	jfrog:artifactory	JFrog Artifactory contains an improper authentication vulnerability that could return an internal anonymous-user token to an unauthenticated caller when anonymous access is disabled, potentially exposing sensitive resources.
CVE-2026-58704			Yes	0.001	google:pixel	Google Pixel devices contain an improper authorization vulnerability in the cellular modem. A logic error may allow an attacker to bypass permission checks and escalate privileges.
CVE-2026-67277			Yes	0.009	mikrotik:routeros	MikroTik RouterOS contains a missing authentication for critical function vulnerability which allows kernel memory disclosure and denial of service in the btest service.
CVE-2026-76460			Yes		cisco:identity services engine	Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) contain an incorrect use of privileged APIs vulnerability that could allow an unauthenticated, remote attacker to gain unauthorized access to the affected device by bypassing the web-based management interface.
CVE-2026-76461			Yes	0.02	cisco:secure email gateway	Cisco AsyncOS software for Cisco Secure Email Gateway (SEG) contains a SQL injection vulnerability that could allow an unauthenticated, remote attacker to execute arbitrary commands with root privileges on the underlying operating system.
CVE-2026-84869			Yes	0.007	connectwise:screenconnect	ConnectWise ScreenConnect contains both an improper privilege management and missing authorization vulnerability that may allow an attacker to transfer and execute files through an active remote session without authorization or host confirmation.
CVE-2026-85706			Yes	0.12	gitlab:community edition and enterprise edition	GitLab Community Edition and Enterprise Edition contains a path traversal vulnerability that allows an unauthenticated user to read arbitrary files due to an improper path confinement and missing authentication enforcement in the repository commits API.
CVE-2026-86060			Yes	0.011	mikrotik:routeros	MikroTik RouterOS contains an improper neutralization of argument delimiters in a command vulnerability which allows an attacker to change the trusted RouterOS policy mask, leading to privilege escalation.
CVE-2026-87886			Yes		acronis:backup	Acronis Backup plugin for cPanel & WHM and extension for Plesk contains an incorrect default permissions vulnerability that could allow for privilege escalation.

P2 - High (CVSS >= 9.0 or 7.0+ with EPSS >= 0.10)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-45674	10.0	CRIT		0.002	netty:netty	Netty is a network application framework for development of protocol servers and clients. Prior to versions 4.1.135.Final and 4.2.15.Final, Netty's DnsResolveContext fails to validate the origin (bailiwick) of CNAME records in DNS responses. Versions 4.1.135.Final and 4.2.15.Final patch the issue.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-47691	10.0	CRIT		0.003	netty:netty	Netty is a network application framework for development of protocol servers and clients. Prior to versions 4.1.135.Final and 4.2.15.Final, Netty's `DnsResolveContext` insufficiently validates the bailiwick of NS records, enabling DNS Cache Poisoning. An attacker controlling an authoritative name server for a subdomain can poison the cache for parent domains (like `.co.uk`). In `io.netty.resolver.dns.DnsResolveCon...
CVE-2026-48056	10.0	CRIT		0.005		Streambert is a cross-platform Electron Desktop App to stream and download video content. Versions prior to 2.5.0 improperly validate executable paths supplied to the run-download IPC handler, allowing a compromised renderer process to execute arbitrary local binaries with the application's privileges. Version 2.5.0 contains a patch.
CVE-2026-54745	10.0	CRIT		0.004		Kubeflow Pipelines enables users to build and deploy portable, scalable machine learning workflows. Prior to 2.17.0, the Kubeflow Pipelines frontend exposes an unauthenticated server-side request forgery vulnerability through the `/_proxy/` route in frontend/server/proxy-middlewre.ts. The `_routePathWithReferer()` function accepts an arbitrary attacker-controlled HTTP or HTTPS target and passes its origin to createPr...
CVE-2026-65956	10.0	CRIT		0.004		KubePi is a Kubernetes multi-cluster management panel. In versions up to and including 1.6.15, the SSO configuration API endpoints are exposed on the same public routing boundary as the SSO login and callback endpoints, so SSO, OIDC, and SAML management operations can be reached without administrator authorization. Because reading, creating, and updating the global SSO configuration is not restricted to administra...
CVE-2026-73299	10.0	CRIT		0.012		Prompty is a markdown file format (.prompty) for LLM prompts. Prior to 0.1.5 and 2.0.0-beta.5, the TypeScript Nunjucks renderer evaluated untrusted .prompty template bodies with unrestricted JavaScript member access. An attacker-controlled template could traverse constructor and prototype properties to execute JavaScript in the host Node.js process. This issue is fixed in versions 0.1.5 and 2.0.0-beta.5.
CVE-2026-79696	10.0	CRIT		0.004		A Code Injection vulnerability in adk web in Google Cloud Agent Development Kit (ADK) for Python versions 2.0.0 through 2.6.0 on Python (OSS), Cloud Run, and GKE environments where pytest is installed allows an unauthenticated remote attacker to execute arbitrary code using a crafted test session replay.
CVE-2026-85061	10.0	CRIT		0.003		MapLibre GL JS is an interactive vector tile map library for web browsers. Prior to 6.4.1, DOM.sanitize() in src/util/dom.ts iterates elem.attributes as a live NamedNodeMap while removeAttributes() removes attributes from the same collection, shifting indexes and skipping an adjacent dangerous attribute. An attacker who controls untrusted third-party style attribution strings or user-supplied custom attributions c...
CVE-2026-85978	10.0	CRIT		0.009		An unauthenticated remote code execution vulnerability exists in the Policy Manager console of Akana API Platform. A path normalization discrepancy between the authentication filter and the servlet dispatcher allows a crafted request to bypass authentication and reach an endpoint that evaluates attacker-supplied script code without sandboxing, resulting in arbitrary code execution. Exploitation requires no authent...
CVE-2026-87827	10.0	CRIT		0.011		Certain KGUARD DVR devices running vulnerable firmware expose a system command execution service on all network interfaces without requiring authentication. A remote unauthenticated attacker with network access to the affected service can execute arbitrary system commands on the device, potentially resulting in complete compromise of the DVR. The vulnerability is known to have been exploited in the wild by the Mi...
CVE-2026-12645	9.9	CRIT		0.012		A Missing Authorization vulnerability in Ivanti Neurons for ITSM before 2026.2 allows a remote authenticated attacker to execute arbitrary code on the server.
CVE-2026-12646	9.9	CRIT		0.012		A Missing Authorization vulnerability in Ivanti Neurons for ITSM before 2026.2 allows a remote authenticated attacker to execute arbitrary code on the server.
CVE-2026-12647	9.9	CRIT		0.012		A Missing Authorization vulnerability in Ivanti Neurons for ITSM before 2026.2 allows a remote authenticated attacker to execute arbitrary code on the server.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-12650	9.9	CRIT		0.015		A Deserialization of Untrusted Data vulnerability in Ivanti Neurons for ITSM before 2026.2 allows a remote authenticated attacker to execute arbitrary code on the server.
CVE-2026-47686	9.9	CRIT		0.004		vm2 is an open source vm/sandbox for Node.js. Prior to 3.11.6, handleException() in lib/setup-sandbox.js sanitizes SuppressedError.error, SuppressedError.suppressed, and AggregateError.errors but does not sanitize Error.cause, allowing sandbox code to obtain a powerful host object such as process from an embedder-exposed host function that throws an error with that object as its cause and then execute arbitrary ho...
CVE-2026-48765	9.9	CRIT		0.003		TypeBot is a chatbot builder tool. Versions prior to 3.17.0 allow a low-privilege read collaborator to extract a workspace OAuth `credentialsId` from a readable bot configuration and then overwrite that credential through `handleUpdateOAuthCredentials()` by supplying an attacker-controlled writable `workspaceId`. The update path validates only the attacker-supplied workspace and then updates the credential record ...
CVE-2026-51366	9.9	CRIT		0.005		SQL Injection vulnerability in Bottinelli Informatica Vedo Suite v.1.2.5 allows a remote attacker to execute arbitrary code via the api_vedo/chat endpoint and the utente_chat parameter
CVE-2026-55089	9.9	CRIT		0.004		Etherpad is a real-time collaborative editor. From 2.1.0 until 3.1.0, Etherpad's src/node/handler/APIHandler.ts authorizes requests to /api/2/* in the authorization_code OAuth path by using requiredClaims with the admin claim. This check requires only that the claim exists, while src/node/security/OAuth2Provider.ts issues admin: false for configured non-admin users. A non-admin user with a valid signed token can t...
CVE-2026-55634	9.9	CRIT		0.004		Pimcore is an Open Source Data & Experience Management Platform. Prior to 11.5.19, 12.3.10, and 2026.1.6, the class-definition import endpoint /pimcore-studio/api/class/definition/configuration-view/detail/{id}/import accepts a DataObject field name that is emitted without an identifier allowlist by lib/DataObject/ClassBuilder/FieldDefinitionPropertiesBuilder.php into generated PHP properties and by models/DataObj...
CVE-2026-62283	9.9	CRIT		0.004		Nezha Monitoring is a self-hostable, lightweight, servers and websites monitoring and O&M tool. Nezha versions 1.14.13 through 1.14.14 and 2.0.0 through 2.0.9 do not bind stream identifiers created by CreateStream in service/rpc/io_stream.go to their creating user, and `GET /ws/terminal/:id` and `GET /ws/file/:id` only check whether the supplied UUID exists. An authenticated RoleMember who obtains a live stream UU...
CVE-2026-65974	9.9	CRIT		0.006		ERPNext is a free and open source Enterprise Resource Planning tool. Prior to 15.111.0 and 16.22.0, limited authenticated users can cross a permission boundary in Frappe safe execution because frappe.render_template is exposed without forcing restrict_globals, allowing server-side template injection and remote code execution. This issue is fixed in versions 15.111.0 and 16.22.0.
CVE-2026-67401	9.9	CRIT		0.01		A vulnerability in cPanel allows a mail-enabled account to achieve remote code execution as root through SQLi in EmailTrack component
CVE-2026-72911	9.9	CRIT		0.004		ERPNext is a free and open source Enterprise Resource Planning tool. Prior to 15.118.0 and 16.29.0, the validate_template and render_template calls in erpnext/accounts/doctype/process_statement_of_accounts/process_statement_of_accounts.py render subject, body, and pdf_name fields with unrestricted globals including frappe.utils, allowing an authenticated user with a common operational role to inject template expre...
CVE-2026-73263	9.9	CRIT		0.004		Prowler is a cloud security platform. Prior to 5.36.0, the Kubernetes provider connection test accepted kubeconfig_content containing a legacy gcp auth-provider with config.cmd-path and config.cmd-args because kubeconfig_contains_exec_auth in api/src/backend/api/v1/serializers.py checked only exec blocks, and POST /api/v1/providers/{id}/connection loaded it through config.load_kube_config_from_dict in prowler/prov...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-73294	9.9	CRIT		0.006		Semaphore UI is a web interface for managing DevOps tools. Prior to 2.18.17 and 2.19.5-beta2, repository git_url handling passes an attacker-controlled --upload-pack option to CmdGitClient.GetLastRemoteCommitHash through POST /api/project/{id}/repositories and scheduled commit-hash polling, allowing a project Manager or Owner to execute arbitrary OS commands in the Semaphore server process. This issue is fixed in ...
CVE-2026-86464	9.9	CRIT		0.004		In the current development version of Eclipse aeriOS, for which no official release has yet been published, the Identity Manager (IdM) deployment included insecure default configurations and credentials for security-sensitive services. The Helm chart exposed the Keycloak service and its PostgreSQL backing database through Kubernetes NodePort services by default, while the Docker Compose deployment similarly ex...
CVE-2021-43716	9.8	CRIT		0.003		Verification Bypass vulnerability exists in EPSON 150075647YWWV110 EasyMP Network Updater Ver.1.20. The Epson projector can be updated by encrypted firmware through USB.
CVE-2021-43717	9.8	CRIT		0.004		An issue exists in pson EH-TW5350 Epson iProjection.apk v3.2.6. If you identify a projector equipped with an iProjection function, you can access the projector using hard-coded authentication information and control the projector maliciously.
CVE-2025-29296	9.8	CRIT		0.022		H3C Magic BE18000 V200R007, H3C NX400 V100R015, H3C Magic NX30 Pro V100R0011, H3C Magic R3010 V100R009, H3C Magic NX15 V100R017, H3C Magic R1510 V100R016, H3C NE36 Pro V100R002 and H3C MC102G HM1A0V200R010 contain multiple command injection vulnerabilities in the /api/esps request handler. The affected object interfaces and methods are esps.dhcpd.vlan (getlist, delete), esps.filter.url (add, modify), esps.apcm.ver...
CVE-2025-63823	9.8	CRIT		0.004		My Safetipin Android Application 5.2.1 contains Hardcoded credentials in the authentication module, which allows remote attackers to bypass authentication and gain unauthorized access to user accounts via predictable OTP values.
CVE-2025-67066	9.8	CRIT		0.004		SQL Injection vulnerability in oasys sysoa version 1.0 allows a remote attacker to execute arbitrary code via the outtype parameter in the /outaddresspaging path
CVE-2025-70290	9.8	CRIT		0.005		An issue was discovered in Denx U-Boot before 2026.04. An integer overflow vulnerability in the ZFS filesystem support can be triggered by malformed on-disk metadata. The issue may result in incorrect memory allocation followed by out-of-bounds memory access, potentially leading to a crash or arbitrary code execution during the boot process.
CVE-2025-70293	9.8	CRIT		0.005		An issue was discovered in Denx U-Boot before 2026.04. An integer overflow vulnerability exists in function ext4fs_get_bgdtable, the size calculation can lead to under allocation and this underallocated buffer will be used in memcpy() which could lead to arbitrary code execution, a denial of service, or other unspecified impacts.
CVE-2026-12744	9.8	CRIT		0.022		A Deserialization of Untrusted Data vulnerability in Ivanti Neurons for ITSM before 2026.2 allows a remote unauthenticated attacker to execute arbitrary code on the server.
CVE-2026-12745	9.8	CRIT		0.021		A Deserialization of Untrusted Data vulnerability in Ivanti Neurons for ITSM before 2026.2 allows a remote unauthenticated attacker to execute arbitrary code on the server.
CVE-2026-36433	9.8	CRIT		0.005		An issue in Actions Semiconductor Co. Ltd Tool- Media Player Utilities v.4.46 allows a physically proximate attacker execute arbitrary code via the Production.dll and RdiskUpgrade.exe components
CVE-2026-37006	9.8	CRIT		0.006		A vulnerability in the WebSocket endpoint of gpt-researcher v0.14.7 and before allows an unauthenticated remote attacker to achieve code execution via malicious Model Context Protocol configurations.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-37751	9.8	CRIT		0.016		An OS command injection vulnerability in the killSessionSync function (lib/agent-runtime.ts) of 23blocks-OS ai-maestro v0.24.17 allows attackers to execute arbitrary commands via a crafted input.
CVE-2026-38165	9.8	CRIT		0.006		A Server-Side Template Injection (SSTI) vulnerability in the Velocity template engine configuration of xdcreport v0.9.2 to v2.2.0 allows attackers to execute arbitrary code via a crafted expression.
CVE-2026-39254	9.8	CRIT		0.006		Buffer Overflow vulnerability in SteelSeries GG (macOS) v.107.0.0 allows a remote attacker to execute arbitrary code via the libSSEdevice.dylib, CxAudioHidDevice::DeviceGetDescriptionString components
CVE-2026-39255	9.8	CRIT		0.006		Buffer Overflow vulnerability in SteelSeries GG (macOS) v.107.0.0 allows a remote attacker to execute arbitrary code via the libSSEdevice.dylib, dup_wcs components
CVE-2026-40860	9.8	CRIT		0.012	apache:camel	JmsBinding.extractBodyFromJms() in camel-jms, and the equivalent JmsBinding class in camel-sjms, deserialized the payload of incoming JMS ObjectMessage values via javax.jms.ObjectMessage.getObject() without applying any ObjectInputFilter, class allowlist or class denylist. Because this code path is reached whenever the mapJmsMessage option is enabled (the default) and Camel acts as a JMS consumer, an attacker able...
CVE-2026-41871	9.8	CRIT		0.008	apache:nutch	Missing Authorization, Use of Externally-Controlled Input to Select Classes or Code ('Unsafe Reflection') vulnerability in Apache Nutch Server (Nutch REST API). This issue affects Apache Nutch: from 1.10 through 1.22. Users are recommended to upgrade to version 1.23, which removes the Nutch Server. If an upgrade is not possible, user must restrict access to instances running the Nutch Service to trusted use...
CVE-2026-42027	9.8	CRIT		0.007	apache:opennlp	Arbitrary Class Instantiation via Model Manifest in Apache OpenNLP ExtensionLoader Versions Affected: before 1.9.5, before 2.5.9, before 3.0.0-M3 Description: The ExtensionLoader.instantiateExtension(Class, String) method loads a class by its fully-qualified name via Class.forName() and invokes its no-arg constructor, with the class name sourced from the manifest.properties entry of a model archive. Th...
CVE-2026-45018	9.8	CRIT		0.007		Chainlit is a Python framework for building production-ready conversational AI applications. From 2.4.0rc0 until 2.12.0, Chainlit deployments with features.mcp.enabled set to true in .chainlit/config.toml expose the POST /mcp endpoint without requiring authentication. For stdio transport, the endpoint accepts a user-controlled fullCommand string. The validate_mcp_command() function in backend/chainlit/mcp.py check...
CVE-2026-46670	9.8	CRIT		0.019		YesWiki is a wiki system written in PHP. Prior to version 4.6.4, an unauthenticated SQL injection in the Bazar form-import path (FormManager::create()) allows any unauthenticated visitor of a default YesWiki install to inject arbitrary SQL into an `INSERT` statement and read the full database, including `yeswiki_users.password` hashes. Version 4.6.4 fixes the issue.
CVE-2026-47698	9.8	CRIT		0.007		vm2 is an open source vm/sandbox for Node.js. Prior to 3.11.6, lib/bridge.js and lib/setup-sandbox.js fail to block stacked indirection through Function.prototype.call around dangerous host prototype getter and setter mutators, allowing sandbox code to sever a host intrinsic's prototype chain and reach e.constructor.constructor for arbitrary host command execution. This issue is fixed in version 3.11.6.
CVE-2026-49819	9.8	CRIT		0.008		UpSnap is a wake on lan web app. Versions 4.4.1 through 5.3.5 are vulnerable to a missing-authentication / privilege-escalation chain in `pb.HandlerInitSuperuser` (backend/pb/handlers.go:249), reachable as `POST /api/upsnap/init-superuser`. The vulnerable code lacks any authentication, setup token, IP allow-list, or rate limit and is gated only by a `totalSuperusers > 0` count check — a condition that is false o...
CVE-2026-50769	9.8	CRIT		0.004		The CRM+ application before and including version 2025.6 from Brainformatik is vulnerable to SQL Injection (time-based) vulnerability. The check conflict endpoint index.php?module=Appointments&action=CheckConflictOfDates&ajaxSkipHeader=true which is used to check any conflicts for user calendar is vulnerable to SQL injection allowing an attacker to execute arbitrary code.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-50774	9.8	CRIT		0.004		An issue in GAPTEQ Designer v.3.5 allows a remote attacker to escalate privileges via the Company Manger role.
CVE-2026-50775	9.8	CRIT		0.006		A blind SSRF attack in DataHub v.1.5.0.1 allows a remote attacker to execute arbitrary code via the server retrieving an image from a crafted URL, and it fails to return the content or any errors directly.
CVE-2026-50894	9.8	CRIT		0.005		easyadmin v2.0.2.2 is vulnerable to Unrestricted Upload of File with Dangerous Type in the background management interface which allows authenticated remote attackers to execute arbitrary code and gain server privileges via a crafted file upload.
CVE-2026-51190	9.8	CRIT		0.013		The "s init" command in Serverless-Devs @serverless-devs/s <= 3.1.11 passes unsanitized user input to child_process.spawn() with shell: true. A URL ending in ".git" bypasses the only input check, allowing OS command injection when a user runs "s init" with an attacker-controlled argument.
CVE-2026-51775	9.8	CRIT		0.003		SQL injection vulnerability in Fastadmin v.1.6.1.20250430 allows an attacker to exectue arbitrary code via the application/common/controller/Backend.php component
CVE-2026-52102	9.8	CRIT		0.018		An OS command injection vulnerability in the openmediavault-md plugin of OpenMediaVault v8.0.4-1 allows attackers to execute arbitrary commands as root via injecting shell metacharacters.
CVE-2026-52103	9.8	CRIT		0.006		A zero-click remote code execution (RCE) vulnerability in the /Terminal/Notification.hs component of SimpleX Chat before v6.5 allows attackers to execute arbitrary commands in the context of the application without user interaction via sending a crafted payload in a text message.
CVE-2026-52466	9.8	CRIT		0.003		Open Library Foundation VuFind v11.0.3 and v4.1 is vulnerable to tolnorrect Access Control. The application fails to stop processing an incoming request in VuFind\Controller\AbstractBase::validateAccessPermission after it has found that controller level access permissions do not allow access to the requested function. The requester receives a response indicating that access was denied, but the actual function is e...
CVE-2026-52490	9.8	CRIT		0.004		An issue in libtiff 85f2ac8e0b01cb7db2bbecf4a3b891bdbbef67938 allows an attacker to execute arbitrary code via the process_command_opts() function in tools/tiffcrop.c
CVE-2026-53545	9.8	CRIT		0.005		Termix is a web-based server management platform with SSH terminal, tunneling, and file editing capabilities. Prior to 2.3.2, the DELETE /ssh/tunnel/disconnect/:tunnelName teardown path in src/backend/ssh/tunnel.ts interpolates endpointPort, sourcePort, endpointUsername, and endpointIP into single-quoted skill -f patterns. An authenticated user who can edit a tunnel host field can include a single quote to termina...
CVE-2026-53611	9.8	CRIT		0.01		Looking Glass is a modern, stateless network-diagnostic platform — a single self-contained Go binary that fronts a fleet of routers over SSH and exposes ping / traceroute / BGP lookups through a gRPC (ConnectRPC) API, an embedded SvelteKit web UI, and a lg-cli client. Prior to version 1.3.5, there is an OS Command Injection vulnerability resulting from an unanchored regular expression in the input validation layer...
CVE-2026-54569	9.8	CRIT		0.008		SENAITE.CORE is the core framework for the SENAITE laboratory information management system. From 2.0.0 to 2.6.0, the SENAITE.CORE JSON API permits unauthenticated remote code execution through a two-request chain involving missing authorization and unsafe evaluation. The state-changing routes in src/bika/lims/jsonapi/update.py, including update, update_many, remove, doActionFor, doActionFor_many, and getusers, do...
CVE-2026-55546	9.8	CRIT		0.004		QWED-MCP is a deterministic verification gateway for MCP. Prior to 0.2.1, verify_math_expression() in src/qwed_mcp/engines/math_engine.py passes attacker-controlled expression and claimed_result strings directly to SymPy's parse_expr() after only normalizing caret syntax to Python exponent syntax, without restricting global_dict, removing Python built-ins, or validating the expression AST. Because parse_expr() cal...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-56207	9.8	CRIT		0.005	apache:impala	Signature of Bearer token is not verified in last step of SAML2 authentication for Impala's hs2-http interface, allowing altering user name and acting as another user. This issue affects Apache Impala: >=4.0.0. Users are recommended to upgrade to version 4.5.2, which fixes this issue.
CVE-2026-58240	9.8	CRIT		0.003		SAP NetWeaver Message Server does not sufficiently validate the authenticity of internal application server components during registration. An unauthenticated attacker with network access to the affected service could exploit this weakness to register an unauthorized component and potentially perform unauthorized actions within the application environment, resulting in a high impact on the confidentiality, integri...
CVE-2026-61808	9.8	CRIT		0.02		LightRAG provides simple and fast retrieval-augmented generation. Through version 1.5.4, the LightRAG API server binds to all network interfaces with authentication disabled by default, allowing an unauthenticated network attacker to read indexed document content, upload or delete documents, modify the knowledge graph, cancel pipelines, clear caches, and consume LLM resources. This issue is mitigated in version 1....
CVE-2026-67868	9.8	CRIT		0.008		A heap-based out-of-bounds write vulnerability exists in S2OPC 1.7.3 in server-side EventFilter handling during CreateMonitoredItems processing. This allows a remote attacker to execute arbitrary code.
CVE-2026-67917	9.8	CRIT		0.005		zuraCast versions up to and including 0.23.7 contain a SQL injection vulnerability in the backup restore functionality. The `azuracast:restore` command executes the `db.sql` file extracted from a backup archive without any content validation or sanitization. This allows a remote attacker to escalate privileges
CVE-2026-67919	9.8	CRIT		0.008		An issue in Halo 2.25.4 allows a remote attacker to execute arbitrary code via the PluginEndpoint.java, installFromUri method, and DefaultPluginApplicationContextFactory components
CVE-2026-67967	9.8	CRIT		0.005		Buffer Overflow vulnerability in Tenda W20E V16.01.0.6(2782) allows an attacker to execute arbitrary code. This is an incomplete fix for CVE-2025-44867 and CVE-2026-36819
CVE-2026-68004	9.8	CRIT		0.007		An issue in OSSRS SRS (Simple Realtime Server) <v5.0.213 allows a remote attacker to execute arbitrary code via RTMP publish authorization, vhost-level security configuration (security.enabled), SrsSecurity::check(), trunk/src/app/srs_app_security.cpp, and SRS RTMP listener components
CVE-2026-69408	9.8	CRIT		0.01		Integer overflow or wraparound in Microsoft Windows Media Foundation allows an unauthorized attacker to execute code over a network.
CVE-2026-69491	9.8	CRIT		0.009		Heap-based buffer overflow in Windows Microsoft DirectMusic allows an unauthorized attacker to execute code over a network.
CVE-2026-69493	9.8	CRIT		0.01		Out-of-bounds read in Windows Event Logging Service allows an unauthorized attacker to execute code over a network.
CVE-2026-69496	9.8	CRIT		0.01		Heap-based buffer overflow in Windows Compressed Folder allows an unauthorized attacker to execute code over a network.
CVE-2026-69586	9.8	CRIT		0.01		Integer overflow or wraparound in Microsoft Windows PDF allows an unauthorized attacker to execute code over a network.
CVE-2026-69590	9.8	CRIT		0.01		Remote Code Execution in Windows Routing and Remote Access Service (RRAS) allows attacker to gain an unauthorized access to victim's machine
CVE-2026-69595	9.8	CRIT		0.011		Use after free in Windows Services for NFS ONCRPC XDR Driver allows an unauthorized attacker to execute code over a network.
CVE-2026-69769	9.8	CRIT		0.009		Heap-based buffer overflow in Windows HTTP Print Provider allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69819	9.8	CRIT		0.009		Out-of-bounds write in RPC Runtime allows an unauthorized attacker to execute code over a network.
CVE-2026-71624	9.8	CRIT		0.005		An issue in esoTalk v.1.0.0g4 allows a remote attacker to execute arbitrary code via the core/models/ETMemberModel.class.php, core/controllers/ETMemberController.class.php, and core/lib/ET.class.php components
CVE-2026-71625	9.8	CRIT		0.004		An issue in slimkit plus ThinkSNS+ v.2.4 allows a remote attacker to escalate privileges via the ResetPasswordController.php component
CVE-2026-71801	9.8	CRIT		0.005		An issue was discovered in s-pms SPMS-Server through v1.0. The application contains a hardcoded default access token secret within its core configuration file, which is not overridden or removed in the production environment profile. A remote, unauthenticated attacker can locally forge valid administrative session tokens to completely bypass the authentication mechanism gaining full unauthorized access to protecte...
CVE-2026-71805	9.8	CRIT		0.004		An arbitrary file upload and path traversal vulnerability exists in LZ-litchi 1.0.0. Unauthenticated remote attackers can upload arbitrary files and write them outside the intended storage directory via the directory parameter in POST /app-api/infra/file/upload.
CVE-2026-72920	9.8	CRIT		0.004		SeaweedFS is a distributed storage system. Prior to 4.24, the filer registers the SeaweedIdentityAccessManagement gRPC service without mandatory authentication when jwt.filer_signing.key is unset, allowing any client that can reach the filer gRPC port to invoke CreateUser, CreateAccessKey, PutPolicy, and related IAM RPCs to mint credentials and gain S3 administrative control. This issue is fixed in versions 4.24.
CVE-2026-72979	9.8	CRIT		0.01		Use after free in Windows DHCP Server allows an unauthorized attacker to execute code over a network.
CVE-2026-72982	9.8	CRIT		0.009		Stack-based buffer overflow in Windows Netlogon allows an unauthorized attacker to execute code over a network.
CVE-2026-72983	9.8	CRIT		0.009		Use after free in Windows Internet Connection Sharing (ICS) allows an unauthorized attacker to execute code over a network.
CVE-2026-73009	9.8	CRIT		0.009		Use after free in Windows Secure Socket Tunneling Protocol (SSTP) allows an unauthorized attacker to execute code over a network.
CVE-2026-73010	9.8	CRIT		0.009		Use after free in Windows Failover Cluster allows an unauthorized attacker to execute code over a network.
CVE-2026-73025	9.8	CRIT		0.009		Weak authentication in Windows iSCSI allows an unauthorized attacker to bypass a security feature over a network.
CVE-2026-73211	9.8	CRIT		0.004		PeerTube is an ActivityPub-federated video streaming platform. Prior to 8.1.6, ActorFollowModel.updateScore() interpolates the attacker-controlled ActivityPub actor inboxUrl into an SQL query, allowing an unauthenticated remote server to read and write PeerTube database tables, including OAuthToken.accessToken, and take over administrator accounts. This issue is fixed in version 8.1.6.
CVE-2026-75325	9.8	CRIT		0.003		DWSurvey v6.14.0 is vulnerable to authentication bypass via the '/api/dwsurvey/none/' and '/api/dwsurvey/up/**' parameters.
CVE-2026-75337	9.8	CRIT		0.004		The static resource interface /api/static/{deployKey}/ of Yu AI Code Mother v4.3 is vulnerable to path traversal. The user-controlled path is concatenated to the preview root directory without any normalization, allowing anonymous attackers to read files outside the preview root.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75338	9.8	CRIT		0.003		disconf (Distributed Configuration Management Platform) 2.6.36 is vulnerable to Incorrect Access Control. The config-fetching APIs /api/config/item, /api/config/file, /api/config/list and /api/config/simple/list are exposed without authentication. The LoginInterceptor explicitly whitelists these four paths, so any anonymous attacker can read every configuration item and configuration file managed by the config cen...
CVE-2026-76904	9.8	CRIT		0.018		GeoTools is an open source Java library that provides tools for geospatial data. Starting in version 30.5 and prior to versions 33.6, 34.5, and 33.6, an SQL Injection Vulnerability is present when executing OGC Filters with PostGIS DataStore implementation: `jsonArrayContains` function; Requires PostGIS 12 or greater with a String or JSON field. For PostGIS 12 and greater `jsonArrayContains(<column>, <pointer>, <v...
CVE-2026-77649	9.8	CRIT		0.004		The internment crate 0.8.7 for Rust can trigger execution of malicious code when compiling a project that uses the crate, because it has a rogue dependency that registers with a command-and-control server to offer arbitrary code execution.
CVE-2026-77650	9.8	CRIT		0.004		The append-only-vec crate 0.1.9 for Rust can trigger execution of malicious code when compiling a project that uses the crate, because it has a rogue dependency that registers with a command-and-control server to offer arbitrary code execution.
CVE-2026-77651	9.8	CRIT		0.005		The arrayref crate 0.3.10 for Rust can trigger execution of malicious code when compiling a project that uses the crate, because it has a rogue dependency that registers with a command-and-control server to offer arbitrary code execution.
CVE-2026-78509	9.8	CRIT		0.01	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Heap-based buffer overflow in Microsoft Office Outlook allows an unauthorized attacker to execute code over a network.
CVE-2026-78510	9.8	CRIT		0.01	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-7861	9.8	CRIT		0.003		Deserialization of untrusted data vulnerability in Next4Biz Information Technologies Inc. CSM (Customer Service Management) allows Code Injection. This issue affects CSM (Customer Service Management): before 8.0.3.
CVE-2026-78745	9.8	CRIT		0.007		An issue in HiDPT/ Weyon HiDPTAndroid Hi3751V350 Hi3751V352E_DMO allows a remote attacker to execute arbitrary code via the Android Debug Bridge (ADB) daemon (adbd)
CVE-2026-79391	9.8	CRIT		0.004		No authentication exists in the MQTT service of Trueview 6.0.23.4. The MQTT broker accepts client connections on TCP port 1883 without requiring authentication, allowing a remote attacker with network access to establish an MQTT session and perform unauthorized publish or subscribe operations.
CVE-2026-79569	9.8	CRIT		0.004		Movie_Recommend v1.0.0 was discovered to contain a SQL injection vulnerability in the sort parameter at /loadingmore. This vulnerability allows attackers to access sensitive database information via a crafted SQL statement.
CVE-2026-79570	9.8	CRIT		0.003		mfish-nocode-pro v1.0.0 was discovered to contain a SQL injection vulnerability in the tableName parameter at /sys/dbConnect/data. This vulnerability allows attackers to access sensitive database information via a crafted SQL statement.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-79574	9.8	CRIT		0.005		An issue in the gateway server of mpush v0.8.1 allows attackers to execute arbitrary code via sending a crafted broadcast message.
CVE-2026-79576	9.8	CRIT		0.003		An issue in the Single-Sign On (SSO) component of Digital-Infrastructure v9.6.7 allows attackers to authenticate as any user, including the Admin, without a password.
CVE-2026-79689	9.8	CRIT		0.019	dell:secure_connect_gateway	Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to script injection.
CVE-2026-79941	9.8	CRIT		0.019	dell:secure_connect_gateway	Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Neutralization of Special Elements used in a Command ('Command Injection') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to script injection.
CVE-2026-80129	9.8	CRIT		0.004	dell:secure_connect_gateway	Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to remote execution.
CVE-2026-80131	9.8	CRIT		0.005	dell:secure_connect_gateway	Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal') vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to remote execution.
CVE-2026-80172	9.8	CRIT		0.003	dell:secure_connect_gateway	Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Insufficient Verification of Data Authenticity vulnerability. An unauthenticated attacker with remote access could exploit this, leading to unauthorized access. This vulnerability is considered critical as an unauthenticated attacker can repeatedly reuse a captured request to generate ADMIN ac...
CVE-2026-84372	9.8	CRIT		0.004		Predis is a flexible and feature-complete Redis and Valkey client for PHP. From version 3.0.0-RC1 until version 3.3.0, pipeline handling on aggregate cluster and replication connections reparses an already serialized RESP buffer in AbstractAggregateConnection::write() by splitting it with explode("\r\n") instead of honoring RESP length prefixes. Attacker-controlled keys or values containing CRLF sequences can ther...
CVE-2026-85102	9.8	CRIT		0.003		Improper certificate trust validation during VPN negotiation in Check Point Quantum Security Gateway may allow an unauthenticated remote attacker to execute arbitrary code on the Gateway.
CVE-2026-85103	9.8	CRIT		0.004		A heap-based buffer overflow in VPN certificate ASN.1 decoding may allow an unauthenticated remote attacker to execute arbitrary code on Check Point Quantum Security Management and Quantum Security Gateway systems.
CVE-2026-85506	9.8	CRIT		0.004		ipmi-oem in FreeIPMI before 1.6.19 has a stack-based buffer overflow in _get_dell_system_info_idrac_info in ipmi-oem/ipmi-oem-dell.c (idrac-info subcommand to dell get-system-info).
CVE-2026-86478	9.8	CRIT		0.004		In JetBrains YouTrack before 2025.3.161254, 2026.1.14042 improper authentication in YouTrack Helpdesk allowed unauthenticated account takeover via a self-asserted email address
CVE-2026-86480	9.8	CRIT		0.003		In JetBrains Hub before 2026.2.52442 an unauthenticated attacker could register a trusted service and gain superuser privileges

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-87534	9.8	CRIT		0.002	google:android, google:chrome	Missing authorization in WebView in Google Chrome on on Android prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to bypass system access restrictions via crafted network traffic. (Chromium security severity: Medium)
CVE-2026-87544	9.8	CRIT		0.003	google:chrome	Incorrect authorization in Extensions in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to bypass system access restrictions into a privileged page via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-87595	9.8	CRIT		0.003	google:chrome	Server-side request forgery in Mobile in Google Chrome prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to bypass system access restrictions via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-47705	9.6	CRIT		0.005		TypeBot is a chatbot builder tool. Version 3.16.1 has a CSV injection vulnerability in the result export functionality. The application does not sanitize or escape user-supplied input when generating CSV files. An attacker can inject spreadsheet formulas into input fields, which are later executed when an administrator opens the exported CSV in spreadsheet software such as Microsoft Excel or LibreOffice Calc. Vers...
CVE-2026-50540	9.6	CRIT		0.004		Kata Containers is an open source project focusing on a standard implementation of lightweight Virtual Machines (VMs) that perform like containers. Prior to version 4.0.0, kata-runtime is vulnerable to host code execution via an unvalidated configuration path annotation. The runtime accepts an arbitrary io.katacontainers.config_path pod annotation and loads the referenced host TOML file without restriction. As a r...
CVE-2026-53546	9.6	CRIT		0.004		Termix is a web-based server management platform with SSH terminal, tunneling, and file editing capabilities. Prior to 2.3.2, the terminal WebSocket accepts a user-controlled hostConfig.id and src/backend/ssh/host-resolver.ts resolves that host without requiring ownership or explicit access. When no credential is shared with the requester, resolveHostById performs an owner credential fallback, and src/backend/ssh/...
CVE-2026-53548	9.6	CRIT		0.004		Termix is a web-based server management platform with SSH terminal, tunneling, and file editing capabilities. Prior to 2.6.1, the GET /host/db/host/:id/password endpoint in src/backend/database/routes/host.ts accepts an authenticated user's numeric host ID and the field=password or field=sudoPassword query without enforcing host ownership during credential resolution. A failed requester-scoped lookup can resolve t...
CVE-2026-53649	9.6	CRIT		0.002		Joro is a web exploitation framework. Prior to version 1.1.1, Joro's default proxy mode exposes a local API on 127.0.0.1:9090 that performs no authentication and applies a wildcard CORS policy. Because plugin uploads use the CORS-safelisted multipart/form-data content type, cross-origin JavaScript on any page the operator visits can reach privileged endpoints - including uploading a native plugin and triggering a ...
CVE-2026-54523	9.6	CRIT		0.004		Kyverno is a policy engine designed for cloud native platform engineering teams. From 1.18.0 until 1.18.2, the NamespacedMutatingPolicy CEL compiler exposes the generator library to matchConditions, allowing a namespace-scoped policy to invoke generator.apply(namespace, resources) with an arbitrary target namespace. The validation in pkg/cel/policies/mpol/validate.go checks that the policy compiles but does not en...
CVE-2026-54694	9.6	CRIT		0.003		SkillTree is a micro-learning gamification platform. Prior to version 4.4.2, two independent code flaws combine into a single exploitable attack chain, with three distinct exploitation paths of escalating impact. `StringHighlighter.js` builds an HTML string by interpolating raw `value` substrings directly into a template literal with no HTML entity encoding. `HighlightedValue.vue` renders that string — and all unf...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-54754	9.6	CRIT		0.003		Klever-Go is the Go implementation of the Klever blockchain protocol. Prior to 1.7.19, marketplace settlement in core/kapp/market/market.go reads MarketOrderData.ReferralPercentage from the listing while reading asset.Royalties.MarketPercentage live at purchase time. An asset owner can create a valid listing and then use AssetTrigger.UpdateRoyalties to make the combined referral and royalty percentages exceed the ...
CVE-2026-54755	9.6	CRIT		0.004		Klever-Go is the Go implementation of the Klever blockchain protocol. Prior to 1.7.19, split-royalty fields decoded in core/kapp/builtInFunctions/utlis.go can contain values greater than core.HundredPercent, and core/kapp/kda/create.go and core/kapp/kda/trigger.go sum those values in uint32 accumulators. Crafted values such as two 0x80000000 entries wrap the validation sum to zero and pass CheckValid100Params. Roy...
CVE-2026-55085	9.6	CRIT		0.005		Etherpad is a real-time collaborative editor. Prior to 3.3.1, result.appendSpan in src/static/js/domline.ts interpolates the start attribute of a numbered list directly into an unquoted ol start attribute before assigning the generated markup to node.innerHTML. ImportEtherpad.setPadRaw in src/node/utlis/ImportEtherpad.ts accepts attacker-controlled attribute-pool values from a crafted .etherpad import, including l...
CVE-2026-65669	9.6	CRIT		0.007		Improper neutralization of special elements in output used by a downstream component ('injection') in SQL Server allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-71193	9.6	CRIT		0.004		In OpenStack Designate before 22.0.1, zone creation checks (_is_subzone, _is_superzone, and the duplicate-zone DB constraint) are scoped to the target pool only. An authenticated user can bypass these checks by scheduling a zone to a different pool via the AttributeFilter scheduler, creating an overlapping zone that conflicts with another tenant's zone. This enables cross-tenant DNS hijack (redirecting traffic to ...
CVE-2026-87438	9.6	CRIT		0.006	google:android, google:chrome	Out of bounds write in WebGL in Google Chrome on on Android prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-87448	9.6	CRIT		0.005	google:chrome	Use after free in DevTools in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-87455	9.6	CRIT		0.004	google:chrome	Use after free in Aura in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87464	9.6	CRIT		0.006	google:chrome	Use after free in WebGL in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-87470	9.6	CRIT		0.004	apple:macos, google:chrome	Improper quantity validation in Tint in Google Chrome on on Mac prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87474	9.6	CRIT		0.005	google:chrome	Use after free in Payments in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87488	9.6	CRIT		0.005	google:android, google:chrome	Use after free in WebGL in Google Chrome on on Android prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-87492	9.6	CRIT		0.003	google:chrome	Incorrect authorization in DevTools in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87494	9.6	CRIT		0.003	google:chrome, microsoft:windows	Use after free in Browser in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-87500	9.6	CRIT		0.003	google:chrome	Improper validation of array index in ANGLE in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87504	9.6	CRIT		0.004	google:chrome	Use after free in Core in Google Chrome prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to execute arbitrary code outside the sandbox via a crafted Chrome extension. (Chromium security severity: Medium)
CVE-2026-87512	9.6	CRIT		0.005	google:chrome, microsoft:windows	Use after free in ANGLE in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87520	9.6	CRIT		0.004	google:android, google:chrome	Use after free in Dawn in Google Chrome on on Android prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87526	9.6	CRIT		0.004	google:chrome	Use after free in Passwords in Google Chrome prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to potentially execute arbitrary code outside the sandbox via UI Interaction. (Chromium security severity: Medium)
CVE-2026-87527	9.6	CRIT		0.005	google:chrome	Buffer overflow in WebGL in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Critical)
CVE-2026-87528	9.6	CRIT		0.003	google:chrome, microsoft:windows	Type confusion in Rust in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87529	9.6	CRIT		0.005	google:chrome	Numeric truncation error in Media in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87547	9.6	CRIT		0.004	google:chrome	Incorrect reference resolution in FileSystem in Google Chrome prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87558	9.6	CRIT		0.004	apple:macos, google:chrome	Use after free in Payments in Google Chrome on on Mac prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87581	9.6	CRIT		0.004	google:chrome	Use after free in Payments in Google Chrome prior to 153.0.8010.36 allowed a remote attacker leveraging social engineering to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87607	9.6	CRIT		0.004	apple:macos, google:chrome	Use after free in Device in Google Chrome on on Mac prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87609	9.6	CRIT		0.004	apple:iphone_os, google:chrome	Use after free in Sharing in Google Chrome on on iOS prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via crafted network traffic. (Chromium security severity: Medium)
CVE-2026-87621	9.6	CRIT		0.003	google:chrome, microsoft:windows	Out of bounds write in ANGLE in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87634	9.6	CRIT		0.004	google:chrome	Use after free in WebPackaging in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Low)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-87637	9.6	CRIT		0.003	apple:macos, google:chrome	Use after free in Extensions in Google Chrome on on Mac prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87638	9.6	CRIT		0.003	google:chrome	Out of bounds write in Media in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87643	9.6	CRIT		0.004	google:android, google:chrome	Integer overflow in GPU in Google Chrome on on Android prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87646	9.6	CRIT		0.004	google:chrome	Use after free in Web Authentication in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87650	9.6	CRIT		0.003	google:chrome	Out of bounds read in WebGL in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-87654	9.6	CRIT		0.004	google:chrome, microsoft:windows	Buffer overflow in ANGLE in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker to execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)
CVE-2026-11841	9.4	CRIT		0.005		An attacker may perform unauthenticated read and write operations on sensitive filesystem areas via the AppEngine Fileaccess over HTTP due to improper access restrictions. A critical filesystem directory was unintentionally exposed through the HTTP-based file access feature, allowing access without authentication. This includes device parameter files, enabling an attacker to read and modify application settings, i...
CVE-2026-39975	9.4	CRIT		0.003		Combodo iTop is a web-based IT service management tool. Prior to 3.2.3, unauthenticated users could delete the .readonly file on iTop instances, leading to code execution. This file, created during the setup process, prevents users from performing write actions. This issue has been fixed in version 3.2.3.
CVE-2026-41242	9.4	CRIT		0.008	protobufjs_project:protobufjs	protobufjs compiles protobuf definitions into JavaScript (JS) functions. In versions prior to 8.0.1 and 7.5.5, attackers can inject arbitrary code in the "type" fields of protobuf definitions, which will then execute during object decoding using that definition. Versions 8.0.1 and 7.5.5 patch the issue.
CVE-2026-45272	9.4	CRIT		0.004		MyBooks is an enhanced and easy-to-use personal ebook management web server also known as Talebook. In 3.41.2 and earlier, the AdminSettings.post handler in webserver/handlers/admin.py accepts SOCIAL_AUTH key names without validating quotes or newline characters, and SettingsLoader.dumpfile in webserver/loader.py concatenates those names into the generated Python source file auto.py without escaping them. An admin...
CVE-2026-50561	9.4	CRIT		0.004		Yuxi is a large-model-based intelligent knowledge base and knowledge graph agent development platform. Prior to version 0.6.2, the project's authentication mechanism contains a flaw. In affected versions, the system does not sufficiently validate the identity token in the Authorization header — only performing a validity check. This allows an administrator token generated in another deployment instance or local te...
CVE-2026-62668	9.4	CRIT		0.004		Grav API Plugin is a RESTful API for Grav CMS that provides full headless access to your site's content. Prior to 1.0.6, the Grav API plugin WebhookController.php accepts webhook URLs after only FILTER_VALIDATE_URL syntax validation, and WebhookDispatcher.php initializes cURL without CURLOPT_PROTOCOLS or CURLOPT_REDIR_PROTOCOLS restrictions. An account with api.webhooks.write can submit file, dict, gopher, private...
CVE-2026-6881	9.4	CRIT		0.002		A SQL Injection in the Giving Reports functionality in Ellucian Advance Web and Legacy Advance allows an authenticated attacker to extract sensitive information from databases via a crafted SQL query in the class credit field. This issue affects Advance Web: all versions; Legacy Advance: all versions. Ellucian CRM Advance is not impacted.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-72841	9.4	CRIT		0.005		luci-app-ovpn fails to properly validate the instance_name2 parameter during file upload, allowing authenticated users to perform path traversal and write arbitrary files outside the intended directory. Attackers can upload malicious payloads to gain persistent root code execution by placing SSH keys in system directories accessible on reboot.
CVE-2026-72842	9.4	CRIT		0.004		luci-app-lxc contains an ACL inconsistency vulnerability that allows low-privileged authenticated LuCI users to access backend container management routes without proper authorization checks. Attackers can exploit path traversal via `/.%2E` in the `lxc_name` parameter to escape container directories and control host-side scripts executed through `lxc.hook.start-host`, achieving root code execution on the OpenWrt h...
CVE-2026-73653	9.4	CRIT		0.006		Vitest is a testing framework powered by Vite. Prior to versions 3.2.7, 4.1.10, and 5.0.0-beta.6, Browser Mode provider commands including upload, takeScreenshot, screenshotMatcher, stopChunkTrace, deleteTracing, and annotateTraces accept browser-supplied file paths without enforcing the allowWrite permission gate or confining paths to the project root. A client that can reach the Browser Mode API can read arbitra...
CVE-2025-31114	9.3	CRIT		0.007		Foocus is an image generating software. In versions 2.5.5 and prior, the Foocus web UI is vulnerable to remote code execution due to the unsafe use of eval when processing metadata JSON. An attacker with access to the Foocus web UI may be able to execute arbitrary code on the instance. As of time of publication, no known patched versions are available, but a suggested fix pull request is available.
CVE-2026-16876	9.3	CRIT		0.003		An authentication bypass vulnerability exists in the WebGUI of Series UNIVERGE IX-R/IX-V. A user could bypass authentication and execute arbitrary CLI commands by tampering with WebGUI messages and sending them to the device via internet.
CVE-2026-19264	9.3	CRIT		0.008		Postiz is an open-source social media scheduling tool. The route that serves locally stored media joins URL-supplied path segments onto the upload directory and streams the file without normalising the path or confining it to that directory, and the route requires no authentication. Raw dot-segments are collapsed before routing, but URL-encoded separators survive route matching and are decoded only once they reach...
CVE-2026-21102	9.3	CRIT		0.001	samsung:android	Use after free in DualDAR prior to SMR Sep-2026 Release 1 allows local privileged attackers to execute arbitrary code with root privilege.
CVE-2026-41452	9.3	CRIT		0.025		Krayin CRM 2.2.4 contains a missing authentication vulnerability in the installer middleware that allows unauthenticated remote attackers to overwrite the primary administrator account by sending a crafted HTTP POST request with the X-Requested-With: XMLHttpRequest header to bypass the CanInstall middleware redirect check. Attackers can supply arbitrary name, email, and password values to the admin-config-setup en...
CVE-2026-47156	9.3	CRIT		0.005		MantisBT is an open source bug tracker. Versions 2.28.3 and earlier contain a critical authentication bypass in the SOAP API's mci_check_login() function. Any user knowing any valid cookie_string can authenticate as any other user (knowing their username), including the administrator, without knowing the target's password. The vulnerability is exploitable with zero prior access on default MantisBT installations be...
CVE-2026-47187	9.3	CRIT		0.004		SSHFS is a network filesystem client for connecting to SSH servers. Prior to version 3.7.6, a rogue SFTP server can return absolute symlink targets or relative targets containing parent-directory components that SSHFS passes through FUSE for resolution by the client kernel against the local filesystem. The documented transform_symlinks mitigation does not contain relative targets because transform_symlink() return...
CVE-2026-47754	9.3	CRIT		0.003		Metacat is data repository software that helps researchers preserve, share, and discover data. Versions 2.x through 2.19.1 and all 1.x versions contain an unauthenticated path traversal in the `archiveEntryName` parameter of the `action=read` endpoint that is part of the original 1.x Metacat API. `ArchiveHandler.readArchiveEntry()` concatenates the user-supplied parameter into a filesystem path without validation,...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-48046	9.3	CRIT		0.003		Streambert is a cross-platform Electron Desktop App to stream and download video content. Versions prior to 2.5.0 contain an unvalidated auto-updater URL vulnerability that allows a compromised renderer process to make the main process download and execute an arbitrary binary, resulting in remote code execution. Version 2.5.0 contains a patch.
CVE-2026-48158	9.3	CRIT		0.004		use-context-selector is a React useContextSelector hook in userland Between 2026-05-18 15:57:18 and 2026-05-19 15:24:34, the default branch contained malicious commits 9d8481a513b7b0d1c0941b220c69b25de748641b through 6f2dae054ca014068bdbbb4db96006424d674124 that executed remote attacker-controlled code on developer machines during `npm install`. The commits were removed by force-push, but local clones, forks, and ...
CVE-2026-48160	9.3	CRIT		0.004		react-tracked provides state usage tracking with Proxies. Between 2026-05-18 19:26:36 and 2026-05-19 15:22:45, the default branch contained malicious commits 6978272a7d6ca02225cb747ea69f427512e33699 through 949f1a3d6bb1ff7d1a0dec892afd773e742627e8 that executed remote attacker-controlled code on developer machines during `npm install`. The commits were removed by force-push, but local clones, forks, and direct-SHA...
CVE-2026-48996	9.3	CRIT		0.002		Trilium is an open-source hierarchical note-taking application. In versions up to and including 0.103.0, the default-on "Safe import" filter does not sanitize note titles, and the GeoMap note view interpolates a marker note's title into raw HTML that is rendered as innerHTML, allowing an attacker-supplied import archive to inject script that runs when the map is displayed. Because Safe import neutralizes scripts b...
CVE-2026-51106	9.3	CRIT		0.002		An issue in TokTok qTox v1.18.4 allows a local attacker to cause a denial of service via the src/persistence/serialize.cpp component
CVE-2026-52735	9.3	CRIT		0.003		ZEBRA is a Zcash node written entirely in Rust. Prior to 4.5.0, Zebra can accept a block that zcashd rejects because the P2SH signature-operation counter undercounts redeem scripts containing a disabled opcode followed by signature opcodes. In zebra-script/src/lib.rs, p2sh_input_sigop_count used the pure-Rust script::Code::sig_op_count path, whose try_fold parser stops at disabled opcodes such as OP_CODESEPARATOR ...
CVE-2026-53578	9.3	CRIT		0.002		Trilium is an open-source hierarchical note-taking application. In versions up to and including 0.103.0, the default-on "Safe import" filter sanitizes HTML only for text notes and excludes the mindMap note type, whose JSON content is stored without sanitization, allowing an attacker-supplied import archive to embed a payload that renders as arbitrary HTML. A mind map node can carry a dangerouslySetInnerHTML proper...
CVE-2026-53579	9.3	CRIT		0.002		Trilium is an open-source hierarchical note-taking application. In versions up to and including 0.103.0, the default-on "Safe import" filter sanitizes HTML only for text notes and excludes the book note type, whose content is stored without sanitization and later rendered as HTML, allowing an attacker-supplied import archive to embed a payload that executes as script. A book note's content is routed through the sa...
CVE-2026-53670	9.3	CRIT		0.003		PREVAIL is a Polynomial-Runtime EBPF Verifier using an Abstract Interpretation Layer. Prior to version 0.2.4, in the Prevail eBPF verifier, EbpfTransformer::add() silently skips offset-variable updates when the destination register carries a non-singleton typeset (two or more simultaneously possible pointer types). Subsequent bounds checks use the stale offset and accept out-of-bounds memory accesses, so a crafted...
CVE-2026-53671	9.3	CRIT		0.003		PREVAIL is a Polynomial-Runtime EBPF Verifier using an Abstract Interpretation Layer. Prior to version 0.2.4, the abstract transformer in prevail treats writes through a T_CTX-typed base register as a silent no-op: do_mem_store in src/crab/ebpf_transformer.cpp only models T_STACK stores, and the checker's T_CTX bounds arm never tests AccessType::write. An attacker can craft an eBPF program that overwrites a contex...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-55220	9.3	CRIT		0.005		Pimcore is an Open Source Data & Experience Management Platform. Prior to 11.5.19, 12.3.10, and 2026.1.6, Pimcore\Mode\DataObject\ClassDefinition\Data\Hotspotimage::getDataFromResource() in models\DataObject\ClassDefinition\Data\Hotspotimage.php passes the field __hotspots object-store column to Pimcore\Tool\Serialize::unserialize() without an allowed-classes restriction after JSON decoding fails. An attacker wit...
CVE-2026-55378	9.3	CRIT		0.006		JS Recon is a JavaScript enumeration and SAST tool. From 1.2.1-beta.1 until 1.3.1-beta.2, the PR Branch Checker workflow in .github/workflows/pr_checker.yml places github.head_ref and github.event.pull_request.head.repo.full_name into BRANCH_NAME and SOURCE_REPO and interpolates those untrusted values into a shell gh pr comment command. A remote user who opens a pull request can use shell metacharacters in a branc...
CVE-2026-57910	9.3	CRIT		0.002		Improper authentication in the WatchGuard Agent allows an unauthenticated attacker with network access to cause the agent to execute arbitrary code with elevated privileges.
CVE-2026-61514	9.3	CRIT		0.005		Puwell IP Camera firmware versions 2.x through 4.x contains an authentication bypass vulnerability that allows unauthenticated attackers to access device functions by sending protocol-conforming packets over TCP port 23456 without credentials. Attackers can exploit the unvalidated Session field in the proprietary control protocol header to access live video streams, control pan and tilt motors, activate audio func...
CVE-2026-61515	9.3	CRIT		0.016		Puwell IP Camera firmware versions 2.x through 4.x contains an unauthenticated command injection vulnerability that allows remote attackers to execute arbitrary operating system commands by sending a crafted JSON payload to the DebugShell interface exposed on TCP port 34567. Attackers can exploit the lack of authentication and input sanitization in the binary protocol service to pass arbitrary commands directly to...
CVE-2026-62681	9.3	CRIT		0.007		Orval generates type-safe JavaScript clients in TypeScript from OpenAPI v3 and Swagger v2 specifications. Prior to 8.21.0, an unescaped backtick in an OpenAPI path is emitted into request URL template literals generated for axios, fetch, react-query, and SWR clients without safe encoding. This permits attacker-controlled JavaScript to be evaluated when a generated request, URL-builder, or query-key function is cal...
CVE-2026-62682	9.3	CRIT		0.006		Orval generates type-safe JavaScript clients in TypeScript from OpenAPI v3 and Swagger v2 specifications. Prior to 8.21.0, an unescaped backtick in servers[0].url is emitted into request URL template literals generated when output.baseUrl.getBaseUrlFromSpecification is enabled without safe encoding. This permits attacker-controlled JavaScript to be evaluated when a generated request or URL-builder function is call...
CVE-2026-63106	9.3	CRIT		0.003		ReadyEcommerce before 4.5.2 contains an unauthenticated SQL injection vulnerability in the product listing API where the rating parameter from the products endpoint is concatenated directly into a MySQL HAVING clause without parameterization in ProductController.php. Attackers can perform time-based blind SQL injection through the unsanitized rating parameter to extract the full database contents, including user c...
CVE-2026-64827	9.3	CRIT		0.005		Telenia Software TVox 26.5.3 and prior 26.x versions, and 24.9.21 and prior 24.x versions, contain an authentication bypass vulnerability in set_env.php where the redirectToLoginAdminIfRequestHaveAccessToken() function derives the current page name from PHP_SELF and skips authentication when the value matches 'login_admin.php'. Attackers can append '/login_admin.php' to the path of any target PHP script to cause th...
CVE-2026-65641	9.3	CRIT		0.005		A vulnerability allowing an unauthenticated network attacker to coerce SMB authentication from the service account.
CVE-2026-66747	9.3	CRIT		0.007		Zbtlink router firmware ships an embedded remote-control implant, ENDLESSDOORS, present in every published build across the product line. It is the open-source ycsunjane/rctl tool built in as an OpenWrt package (librctl.so), started at boot and run as root under the process name kworker to blend in with the kernel's [kworker/*] threads. It opens no listening port; it phones home over cleartext TCP to a hardcoded c...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-67308	9.3	CRIT		0.005		Wazuh workflows before 44bf114 contain a shell injection vulnerability in GitHub Actions that allows attackers to execute arbitrary commands by submitting pull requests with crafted VERSION.json files. Attackers can inject shell metacharacters into environment variables that are directly interpolated into run steps, enabling command execution and exfiltration of secrets including GITHUB_TOKEN and AWS credentials o...
CVE-2026-68770	9.3	CRIT		0.006		sentence-transformers contains a security control bypass vulnerability that allows attackers to achieve arbitrary code execution by exploiting a logic flaw in the import_module_class helper within sentence_transformers/util/misc.py, where the guard condition includes an 'or os.path.exists(model_name_or_path)' clause that satisfies the trust gate whenever the supplied path exists on the local filesystem, regardless...
CVE-2026-68771	9.3	CRIT		0.008		ComfyUI v0.23.0 contains an unsafe deserialization vulnerability in the LoadTrainingDataset node that allows unauthenticated remote attackers to execute arbitrary Python code by uploading a crafted pickle file and triggering its deserialization. Attackers can upload a malicious shard_*.pkl file via the unauthenticated POST /upload/image endpoint and then queue a workflow graph via POST /prompt referencing the uplo...
CVE-2026-68929	9.3	CRIT		0.003		FastGPT is an open-source LLM platform for building AI applications on a knowledge base. In versions prior to 4.15.2, the WeChat (iLink) share-channel endpoints authorize requests using only the public shareId, with no authenticated identity or team-ownership check. As a result, an unauthenticated attacker who knows a victim team's shareId can take that team's WeChat bot offline or hijack the channel to their own ...
CVE-2026-71864	9.3	CRIT		0.006		Orval generates type-safe JavaScript clients in TypeScript from OpenAPI v3 and Swagger v2 specifications. Prior to 8.21.0, a double quote in a header parameter name is emitted into the generated request-validation zod.object({...}) schema without safe encoding. This permits attacker-controlled JavaScript to be evaluated when the generated zod schema module is imported, resulting in code execution in the developer,...
CVE-2026-71865	9.3	CRIT		0.005		Orval generates type-safe JavaScript clients in TypeScript from OpenAPI v3 and Swagger v2 specifications. Prior to 8.21.0, a double quote in a query parameter name is emitted into the generated request-validation zod.object({...}) schema without safe encoding. This permits attacker-controlled JavaScript to be evaluated when the generated zod schema module is imported, resulting in code execution in the developer, ...
CVE-2026-71866	9.3	CRIT		0.005		Orval generates type-safe JavaScript clients in TypeScript from OpenAPI v3 and Swagger v2 specifications. From version 8.19.0 until 8.21.0, a double quote in a schema property name is emitted into the generated zod.object({...}) schema without safe encoding. This permits attacker-controlled JavaScript to be evaluated when the generated zod schema module is imported, resulting in code execution in the developer, CI...
CVE-2026-71867	9.3	CRIT		0.006		Orval generates type-safe JavaScript clients in TypeScript from OpenAPI v3 and Swagger v2 specifications. Prior to 8.21.0, a single quote in a schema property name is emitted into single-quoted object keys in generated MSW mock factories without safe encoding. This permits attacker-controlled JavaScript to be evaluated when the generated mock factory is called by tests or an MSW handler, resulting in code executio...
CVE-2026-71868	9.3	CRIT		0.006		Orval generates type-safe JavaScript clients in TypeScript from OpenAPI v3 and Swagger v2 specifications. Prior to 8.21.0, a \${...} expression or backtick in an enum default is emitted into a module-level template literal emitted by zod schema generation without safe encoding. This permits attacker-controlled JavaScript to be evaluated when the generated zod schema module is imported, resulting in code execution i...
CVE-2026-71869	9.3	CRIT		0.006		Orval generates type-safe JavaScript clients in TypeScript from OpenAPI v3 and Swagger v2 specifications. Prior to 8.21.0, a \${...} expression or backtick in an array item default is emitted into a module-level template literal emitted by zod schema generation without safe encoding. This permits attacker-controlled JavaScript to be evaluated when the generated zod schema module is imported, resulting in code execu...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-71871	9.3	CRIT		0.005		Orval generates type-safe JavaScript clients in TypeScript from OpenAPI v3 and Swagger v2 specifications. Prior to 8.21.0, a \${...} expression or backtick in a header parameter default is emitted into a module-level template literal emitted by zod schema generation without safe encoding. This permits attacker-controlled JavaScript to be evaluated when the generated zod schema module is imported, resulting in code ...
CVE-2026-71960	9.3	CRIT		0.005		Cudy WR3000 2.0 running firmware before 2.5.24 contains a hard-coded JWT HMAC signing secret vulnerability in the Mosquitto MQTT broker's authentication plugin that allows unauthenticated attackers to forge valid JWT tokens by extracting the secret from the firmware image. Attackers can use the extracted secret to craft arbitrary JWT tokens and authenticate to the MQTT broker without legitimate credentials, gainin...
CVE-2026-72716	9.3	CRIT		0.007		Orval generates type-safe JavaScript clients in TypeScript from OpenAPI v3 and Swagger v2 specifications. Prior to 8.21.0, a \${...} expression or backtick in a query parameter default is emitted into a module-level template literal emitted by zod schema generation without safe encoding. This permits attacker-controlled JavaScript to be evaluated when the generated zod schema module is imported, resulting in code e...
CVE-2026-72717	9.3	CRIT		0.007		Orval generates type-safe JavaScript clients in TypeScript from OpenAPI v3 and Swagger v2 specifications. Prior to 8.21.0, a \${...} expression or backtick in a schema default is emitted into a module-level template literal emitted by zod schema generation without safe encoding. This permits attacker-controlled JavaScript to be evaluated when the generated zod schema module is imported, resulting in code execution ...
CVE-2026-73080	9.3	CRIT		0.004		SeaweedFS is a distributed storage system. Prior to 4.24, VolumeServer.FetchAndWriteNeedle in weed/server/volume_grpc_remote.go fetches a caller-supplied remote endpoint through weed/remote_storage/s3/s3_storage_client.go and writes the response into a needle. The RPC performs no authentication and no target validation, allowing anyone who can reach a volume server's gRPC port to cause requests to arbitrary hosts,...
CVE-2026-73090	9.3	CRIT		0.002		PeerTube is an ActivityPub-federated video streaming platform. Prior to 8.2.2, processUpdateActivity and processUpdateVideo accept an ActivityPub Update containing a Video object without verifying that byActor.url is authorized for the host in videoObject.id, allowing a malicious federated server to rewrite another server's video metadata, visibility, media file, and HLS URLs. This issue is fixed in version 8.2.2.
CVE-2026-73251	9.3	CRIT		0.002		Mongoose is an embedded web server and network library. Prior to 7.23, a network attacker can impersonate a TLS server to a Mongoose client configured with a multi-certificate CA bundle. In src/tls_builtin.c, the mg_tls_init() function stores the bundle in tls->ca_bundle_der while tls->ca_der.len remains zero, and mg_tls_recv_cert() uses tls_bundle_find() to accept a Common Name match without calling mg_tls_verify...
CVE-2026-73532	9.3	CRIT		0.005		Fluent Forms Pro 6.2.7 contains an embedded malicious code vulnerability introduced via a tampered plugin build served through a decommissioned update server. The tampered build introduced a rogue PHP file (libs/class-license-sync.php), loaded via a require_once directive added to fluentformpro.php, that established a backdoor REST API endpoint, dropped persistent PHP files in mu-plugins and uploads directories, i...
CVE-2026-73533	9.3	CRIT		0.004		Ninja Tables Pro 5.2.11 contains an embedded malicious code vulnerability introduced via a tampered plugin build served through a decommissioned update server. The tampered build introduced a rogue PHP file (app/Library/updater/NinjaTableDataSync.php) that established a backdoor REST API endpoint, dropped persistent PHP files in mu-plugins and uploads directories, installed a passwordless administrator account, an...
CVE-2026-76200	9.3	CRIT		0.005	adobe:commerce, adobe:commerce_b2b, adobe:magento	Adobe Commerce is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by an attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field, potentially gaining elevated access or control over the victim's account or session. Scope is changed.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-76201	9.3	CRIT		0.005	adobe:commerce, adobe:commerce_b2b, adobe:magento	Adobe Commerce is affected by a stored Cross-Site Scripting (XSS) vulnerability that could be abused by an attacker to inject malicious scripts into vulnerable form fields. Malicious JavaScript may be executed in a victim's browser when they browse to the page containing the vulnerable field, potentially gaining elevated access or control over the victim's account or session. Scope is changed.
CVE-2026-77413	9.3	CRIT		0.005		JSONata is a JSON query and transformation language. Prior to 1.8.8 and 2.2.0, the src/functions.js lookup function lacked an Object.prototype.hasOwnProperty check and allowed crafted expressions to access inherited prototype members. An attacker able to supply an expression could use inherited prototype setters and getters, constructor access, valueOf, and process.getBuiltinModule to reach the child_process modul...
CVE-2026-77414	9.3	CRIT		0.004		JSONata is a JSON query and transformation language. Prior to 1.8.8 and 2.2.1, the src/jsonata.js environment.lookup function used a bypassable hasOwnProperty check. Crafted expressions could use \$hasOwnProperty, \$spread, \$string, prototype access, and \$constructor to reach the object prototype and invoke process.getBuiltinModule with child_process, executing arbitrary code with the privileges of the host process....
CVE-2026-77415	9.3	CRIT		0.006		JSONata is a JSON query and transformation language. Prior to 1.8.8 and 2.2.1, crafted JSONata expressions could chain several object-integrity weaknesses to execute arbitrary code. The chain could overwrite \$clone to mutate objects through evaluateTransformExpression, expose and deconstruct JSONata functions or lambdas through \$merge.*, replace proc.arguments.forEach used by applyProcedure, and forge internal lam...
CVE-2026-77644	9.3	CRIT		0.003		A critical bypass access control vulnerability has been reported in PTC Windchill Risk and Reliability (WRR) Enterprise Edition.
CVE-2026-77776	9.3	CRIT		0.003		Headroom's LLM proxy derives the memory owner from the x-headroom-user-id request header. The header is read directly at several points in headroom/proxy/handlers/openai.py, including the chat completion and websocket paths, and nothing binds the value to the caller. A client can therefore name another user's identifier and read or write that user's stored LLM memory. The fix introduces a single resolve_memory_ide...
CVE-2026-78997	9.3	CRIT		0.003		UC Browser for Android (package com.UCMobile.intl, version 13.7.8.1314) contains a Universal Cross-Site Scripting vulnerability that allows an attacker to execute arbitrary JavaScript in the context of any origin. An attacker hosts a specially crafted URL on a UC-owned domain (via a reflected XSS) that leverages the browser's internal JavaScript bridge to register a deferred callback, navigate the tab to a victim ...
CVE-2026-85391	9.3	CRIT		0.003		Peppermint through 0.5.5 contains a hardcoded JWT signing secret in docker-compose.yml that allows unauthenticated attackers to forge session tokens for any account. Attackers can use the published secret to mint valid tokens for arbitrary user IDs and access protected endpoints without credentials.
CVE-2026-86738	9.3	CRIT		0.003	snipeitapp:snipe-it	Snipe-IT versions before 8.7.0 contain a CSS injection vulnerability in the Custom CSS field due to incomplete sanitization that reverses HTML encoding on greater-than and double-quote characters. Superusers can plant malicious CSS payloads using @import and url() references to exfiltrate CSRF tokens from other superusers via attribute-selector rules, enabling account takeover.
CVE-2026-87929	9.3	CRIT		0.003		MaxSite CMS through 109.6 ships with a hardcoded session encryption key in application/config/config.php that is never changed during installation, allowing unauthenticated attackers to forge administrator session cookies. Attackers can mint a malicious ci_session cookie with administrator privileges by computing an HMAC-SHA1 using the publicly known encryption key, bypassing authentication checks in is_login() an...
CVE-2026-88069	9.3	CRIT		0.003		Pandora contains a path traversal vulnerability in its archive extraction worker. When processing a specially crafted archive or disk image, attacker-controlled file paths could be used without ensuring that the resulting destination remained within the intended extraction directory. An attacker able to submit a malicious file for analysis could use path traversal sequences or crafted paths to cause extracted con...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-13737	9.2	CRIT		0.005	commvault:commvault	CommServe contained an allowlist bypass vulnerability affecting command execution authorization. Software customers upgrade to resolved maintenance release. Update all Commvault installations, including Commserve, Webserver, Command Center, Media Agents, Clients and HyperScale X.
CVE-2026-21095	9.2	CRIT		0.005	samsung:android	Heap-based buffer overflow in DNG decoder of libimagecodec.quram.so prior to SMR Sep-2026 Release 1 allows remote attackers to execute arbitrary code.
CVE-2026-21096	9.2	CRIT		0.005	samsung:android	Heap-based buffer overflow in JPEG decoder of libimagecodec.quram.so prior to SMR Sep-2026 Release 1 allows remote attackers to execute arbitrary code.
CVE-2026-39923	9.2	CRIT		0.003		Flarum before 1.8.16 contains a password reset token expiry bypass vulnerability that allows unauthenticated attackers to reuse expired password reset tokens by submitting them directly to the reset processing endpoint. The SavePasswordController::handle() method calls PasswordToken::findOrFail() without performing any expiry validation, allowing attackers to bypass the 24-hour token lifetime enforced only during ...
CVE-2026-47243	9.2	CRIT		0.004		Kata Containers is an open source project focusing on a standard implementation of lightweight Virtual Machines (VMs) that perform like containers. Prior to 3.31.0, the runtime-rs standalone virtio-fs path is vulnerable to a guest-root to host-root escape. In this configuration, Kata runs the host virtiofsd as root with --sandbox none --seccomp none, so an attacker with root-equivalent access inside the guest can ...
CVE-2026-63382	9.2	CRIT		0.006		Libevent is an event notification library. Prior to 2.1.13 and 2.2.2-alpha, the libevent evhttp parser in http.c inconsistently handles duplicate Transfer-Encoding headers, comma-separated Transfer-Encoding values, and bare line feeds in chunked framing. evhttp_find_header can select only the first header, evhttp_check_transfer_encoding_ was absent so the previous whole-string comparison fails to recognize valid l...
CVE-2026-63385	9.2	CRIT		0.004		Libevent is an event notification library. Prior to 2.1.13 and 2.2.2-alpha, libevent has two HTTP parsing weaknesses in http.c. evhttp_decode_uri_internal decodes percent-encoded %00 bytes into literal NUL characters, which can cause downstream C string operations to truncate a path and bypass validation performed on a different representation. evhttp_header_is_valid_value also accepts obsolete line folding in hea...
CVE-2026-67276	9.2	CRIT		0.002		RouterOS does not compare the complete RSA public key when matching an SSH authentication request to an authorized user key, checking the key type and modulus but omitting the exponent. Because signature verification uses the client-supplied key, an attacker knowing an authorized RSA modulus can supply a key with exponent one, forge a valid signature, and open an SSH command channel as the target user without the ...
CVE-2026-67367	9.2	CRIT		0.008		A vulnerability has been identified in SIMOVE Fleetmanager V3.1 (All versions < V3.1.13), SIMOVE Fleetmanager V3.2 (All versions < V3.2.4), SIMOVE Fleetmanager V3.3 (All versions < V3.3.2), SIMOVE Fleetmanager V4.0 (All versions < V4.0.1), SIPLANT V1.7 (All versions), SIPLANT V2.2 (All versions), SIPLANT V3.0 (All versions), SIPLANT V3.1 (All versions < V3.1.4). Affected devices do not properly validate and neutra...
CVE-2026-67402	9.2	CRIT		0.003		An insecure Apache configuration in ConfigServer Security & Firewall maps /usr/bin as CGI programs through the Messenger v3 HTTPS virtual host. A remote unauthenticated attacker whose address is blocked can request a mapped executable and run arbitrary commands as the Apache user. The vulnerability affects installations where CSF Messenger v3 and its HTTPS mode are enabled. WebPros addressed the vulnerability in v...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-67443	9.2	CRIT		0.006		FUXA is a web-based Process Visualization (SCADA/HMI/Dashboard) software. In 1.3.2 and earlier, the allowDashboard authorization gate in server/integrations/node-red/index.js calls authJwt.verify for /nodered without inspecting the decoded identity. When nodeRedEnabled is true, secureEnabled is true, and nodeRedAuthMode is secure, a remote unauthenticated attacker can obtain a signed guest token from POST /api/hea...
CVE-2026-73414	9.2	CRIT		0.005		Shescape is a simple shell escape library for JavaScript. Prior to 2.1.14 and 3.0.1, getEscapeFunction in src/internal/win/cmd.js does not escape `(` and `)` when applications use the escape or escapeAll APIs on Windows with shell set to cmd.exe, or with shell set to true when CMD is the default. An attacker-controlled argument can break out of a parenthesized CMD construct and inject shell syntax depending on the...
CVE-2026-77635	9.2	CRIT		0.003		CakePHP is a rapid development framework for PHP. Prior to versions 5.1.10, 5.2.15, and 5.3.7 on their respective release lines, FunctionsBuilder::jsonValue() with PostgresDriver is vulnerable to SQL injection when user-controlled data is supplied to the jsonPath parameter. This issue is fixed in versions 5.1.10, 5.2.15, and 5.3.7.
CVE-2026-77645	9.2	CRIT		0.005		A critical remote code execution (RCE) vulnerability has been reported in PTC Windchill and PTC FlexPLM. The vulnerability may be exploited through the deserialization of untrusted data.
CVE-2026-82090	9.2	CRIT		0.003		Pocket through 8.33.0.0 allows XSS because "Save to Pocket" injects external HTML into the DOM. JavaScript code can alter the application state via native bridge methods.
CVE-2026-84197	9.2	CRIT		0.002		In Eclipse Ditto's Node.js JavaScript client, all released versions of @eclipse-ditto/ditto-javascript-client-node from 2.0.0 to 3.9.0 and of its predecessor package @eclipse-ditto/ditto-javascript-client-node_1.0 from 1.0.0 to 2.1.0, the WebSocket transport hard-codes rejectUnauthorized: false when creating the underlying ws WebSocket. Certificate chain and hostname validation are therefore disabled for every wss...
CVE-2026-87930	9.2	CRIT		0.003		MaxSite CMS through 109.6 passes the ci_session cookie to unserialize() without class restrictions, allowing unauthenticated attackers to inject PHP objects. Attackers can forge valid session cookies using the hardcoded encryption key to trigger magic methods and corrupt application state or achieve code execution if gadget classes exist.
CVE-2025-51679	9.1	CRIT		0.004		An issue was discovered in openRISC OR1200 commit 83ac6b. A mismatch between the RTL and netlist can lead to unexpected behavior.
CVE-2026-16272	9.1	CRIT		0.001		Use of less trusted source vulnerability in PayTR Payment and Electronic Money Institution Inc. PayTR Virtual Pos iFrame API (v9x) WHMCS Module allows Exploitation of Trusted Identifiers. This issue affects PayTR Virtual Pos iFrame API (v9x) WHMCS Module: from v9.0.0 before v9.0.3.
CVE-2026-18753	9.1	CRIT		0.003		The product firmware contains an embedded, static RSA private key utilized by the Lighttpd web server for TLS termination. Exposure of this private key allows malicious actors to breach the confidentiality and integrity of HTTPS communications, enabling traffic decryption and server spoofing.
CVE-2026-18754	9.1	CRIT		0.003		The product firmware contains an embedded, static RSA private key utilized by the Lighttpd web server for TLS termination. Exposure of this private key allows malicious actors to breach the confidentiality and integrity of HTTPS communications, enabling traffic decryption and server spoofing.
CVE-2026-22590	9.1	CRIT		0.004		eprosima Fast DDS is a C++ implementation of the DDS (Data Distribution Service) standard of the OMG (Object Management Group). Versions prior to 2.6.12, 2.14.6, 3.2.4, 3.3.1, and 3.4.2 have a remotely triggerable Out-of-Bounds Read while processing RTPS `DATA_FRAG` submessages. An attacker can craft a `DATA_FRAG` with a large `sampleSize` but a small actual payload, and set `fragmentsInSubmessage` such that the r...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-41869	9.1	CRIT		0.008	apache:nutch	Missing Authorization, Improper Resource Shutdown and Job Interruption vulnerability in Apache Nutch Server (Nutch REST API). This issue affects Apache Nutch: from 1.10 through 1.22. Users are recommended to upgrade to version 1.23, which removes the Nutch Server. If an upgrade is not possible, user must restrict access to instances running the Nutch Service to trusted users only. Please, also visit the Ap...
CVE-2026-42579	9.1	CRIT		0.01	netty:netty	Netty is an asynchronous, event-driven network application framework. Prior to 4.2.13.Final and 4.1.133.Final, Netty's DNS codec does not enforce RFC 1035 domain name constraints during either encoding or decoding. This creates a bidirectional attack surface: malicious DNS responses can exploit the decoder, and user-influenced hostnames can exploit the encoder. This vulnerability is fixed in 4.2.13.Final and 4.1.1...
CVE-2026-47702	9.1	CRIT		0.002		TypeBot is a chatbot builder tool. In version 3.16.1, API tokens (bearer credentials used to authenticate against the builder API) are stored in the database as cleartext strings. An attacker who gains read access to the database (e.g., via SQL injection, backup exposure, or insider access) can extract all API tokens and impersonate any user without requiring a password or multi-factor authentication. Version 3.17...
CVE-2026-49849	9.1	CRIT		0.009		xShop is an open-source shop developed in Laravel. An Unrestricted File Upload vulnerability in xShop version 3.0.3 allows an authenticated administrator to upload executable files (e.g., .php). By uploading a specially crafted php file, an attacker can achieve Remote Code Execution (RCE) on the server, leading to a full system compromise. Version 3.0.4 fixes the issue.
CVE-2026-51346	9.1	CRIT		0.005		SQL Injection vulnerability in StudIP 6.0.x before 6.0.3 and 5.4.x before 5.4.12 allows a remote attacker to execute arbitrary code and obtain sensitive information via the store() functions.
CVE-2026-52766	9.1	CRIT		0.003		YesWiki is a wiki system written in PHP. Prior to version 4.6.6, the {{erasespamedcomments}} wiki action (actions/EraseSpamedCommentsAction.php) accepts a suppr[] array from POST and deletes every wiki page whose tag appears in that array, with no authorization check anywhere in the action body or in the page-deletion path it invokes. Combined with YesWiki's allow-by-default action ACL model, any user who has page...
CVE-2026-53939	9.1	CRIT		0.002		OpenIDC/cjose is a C library implementing the Javascript Object Signing and Encryption (JOSE). In versions 0.6.1 through 0.6.2.5, when cjose encrypts a JWE using an AES-CBC-HMAC content-encryption algorithm (`A128CBC-HS256`, `A192CBC-HS384`, or `A256CBC-HS512`) together with any key-management algorithm that generates a fresh content-encryption key (CEK), the CEK is all zero bytes instead of being randomly generat...
CVE-2026-55247	9.1	CRIT		0.003		plone.app.event provides the event content type for Plone. Prior to versions 5.2.4 and 6.0.1, the iCalendar import in src/plone/app/event/ical/importer.py accepts insufficiently restricted calendar and event URLs, does not adequately bound downloaded bytes or imported events, and commits work per event. A logged-in editor can make the server request internal network resources or local calendar files, exhaust resou...
CVE-2026-55248	9.1	CRIT		0.003		plone.app.portlets provides portlets and a Plone-specific user interface for plone.portlets. Prior to 5.0.8, 6.0.4, and 7.0.2, a member who can add an RSS portlet can set its feed URL to a very large response, causing src/plone/app/portlets/portlets/rss.py to download and retain excessive data in memory and deny service. The same RSS URL handling accepts internal hosts, IP addresses, single-word domains, and expli...
CVE-2026-55536	9.1	CRIT		0.003		PraisonAI is a multi-agent teams system. Prior to praisonai 4.6.58, Browser Server _handle_connection() checks Chrome extension origins with re.match() and the unanchored expression chrome-extension://[a-z0-9]{32}. Extra trailing characters pass before websocket.accept(), allowing start_session commands and unauthorized browser automation. This issue is fixed in version 4.6.58.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-55640	9.1	CRIT		0.005		Nextcloud MCP Server is a production-ready MCP server that connects AI assistants to a Nextcloud instance. Prior to 0.117.2, the POST /webhooks/nextcloud endpoint in nextcloud_mcp_server/vector/webhook_receiver.py has no authentication by default because WEBHOOK_SECRET defaults to None and startup validation does not require it. When WEBHOOK_SECRET is unset, handle_nextcloud_webhook() accepts unauthenticated reque...
CVE-2026-57499	9.1	CRIT		0.01		Liman is open source server management software. Prior to 2.2.2 - 1103, an OS command injection vulnerability in the log rotation configuration endpoint allows an authenticated administrator to execute arbitrary operating system commands on the Liman server. The `ip_address` parameter is embedded directly into a shell command without sanitization, enabling shell escape via single-quote injection. This is fixed in ...
CVE-2026-58400	9.1	CRIT		0.012		GeoNetwork is a catalog application to manage spatially referenced resources. Prior to versions 4.4.12 and 4.2.17, the Saxon XSLT processor used to render formatters is configured without secure processing (`FEATURE_SECURE_PROCESSING`) and without disabling Java extension functions (`ALLOW_EXTERNAL_FUNCTIONS`). Any stylesheet loaded by GeoNetwork can therefore invoke `java.lang.Runtime.exec()` or `java.lang.Proces...
CVE-2026-62862	9.1	CRIT		0.005		Typebot is an open-source chatbot builder. In self-hosted versions up to and including 3.17.1, the default passwordless email magic-link authentication is vulnerable to login-code brute forcing that leads to account takeover. The email provider overrides NextAuth's default cryptographically secure token with a 6-digit code generated using Math.random(), reducing the keyspace to 900,000 with a 10-minute expiry, and...
CVE-2026-67598	9.1	CRIT		0.002		Emlog Pro through 2.6.23 contains a disabled TLS certificate validation vulnerability in include/service/ai.php that allows network-adjacent attackers to intercept outbound HTTPS requests to configured LLM providers by presenting arbitrary TLS certificates, as CURLOPT_SSL_VERIFYPEER and CURLOPT_SSL_VERIFYHOST are unconditionally disabled across sendStream(), sendImageRequest(), send(), and fetchSearchHtml() with n...
CVE-2026-69641	9.1	CRIT		0.008		Missing authorization in Microsoft Exchange Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-73069	9.1	CRIT		0.004		Twenty is an open-source CRM (customer relationship management) platform. Prior to 2.15.0, Twenty allowed a workspace administrator with the DATA_MODEL permission to supply settings.asExpression for the system TS_VECTOR field searchVector through PATCH /rest/metadata/fields/:id or the updateOneField GraphQL mutation, causing buildSqlColumnDefinition in packages/twenty-server/src/engine/twenty-orm/workspace-schema-...
CVE-2026-73253	9.1	CRIT		0.002		Mongoose is an embedded web server and network library. Prior to version 7.22, an on-path network attacker with a wildcard certificate for a parent domain can impersonate deeper subdomains to a client using the built-in TLS stack. The mg_tls_verify_cert_san() and mg_tls_verify_cert_cn() functions in src/tls_builtin.c call mg_match(), whose wildcard can cross DNS label boundaries, so a pattern such as *.example.com...
CVE-2026-73256	9.1	CRIT		0.004		Mongoose is an embedded web server and network library. Prior to 7.22, a remote unauthenticated attacker can exploit an HTTP/1.0 reverse-proxy deployment by sending a request with Transfer-Encoding: chunked and conflicting framing. The http_cb() function in src/http.c tests hm.proto.len with an impossible greater-than-eight condition even though mg_http_parse() requires an eight-byte protocol string, so is_http_1_...
CVE-2026-73257	9.1	CRIT		0.005		Mongoose is an embedded web server and network library. Priro to version 7.22, a remote unauthenticated attacker can send an HTTP request containing both Content-Length and Transfer-Encoding: chunked. The cl_count and te_count checks in the mg_http_parse() and http_cb() paths in src/http.c accept both headers and prioritize chunked encoding, while a Content-Length-preferring reverse proxy can use a different reque...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-75340	9.1	CRIT		0.002		The device metadata import interface /device/instance/{productId}/property-metadata/import of jetlinks community 2.11 is vulnerable to Server-side request forgery (SSRF).
CVE-2026-75595	9.1	CRIT		0.003		Netty is an asynchronous, event-driven network application framework. Prior to 4.1.137.Final and 4.2.17.Final, io.netty.handler.ssl.SslClientHelloHandler#decode checks the wrong offset before reading the four-byte TLS handshake header, so a ClientHello whose handshake header spans records can cause an IndexOutOfBoundsException and invoke select(ctx, null). This selects the default SslContext instead of the SNI-spec...
CVE-2026-75746	9.1	CRIT		0.011		ColdFusion is affected by an Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability that could result in arbitrary code execution in the context of the current user. An attacker with high privileges could exploit this vulnerability to execute arbitrary code. Exploitation of this issue does not require user interaction. Scope is changed.
CVE-2026-77337	9.1	CRIT		0.004		CakePHP Authentication is an authentication plugin for CakePHP that can also be used in PSR-7 based applications. Versions before 2.11.2, from 3.0.0 through 3.3.6, and from 4.0.0 through 4.2.0 allow authentication bypass and potential CPU or memory exhaustion when CookieAuthenticator uses unencrypted, forgeable legacy tokens. This issue is fixed in versions 2.11.2, 3.3.7, and 4.2.1.
CVE-2026-79571	9.1	CRIT		0.003		Incorrect access control in the SellerAuthorizeAspect component of springboot-project v1.0.0 allows unauthenticated attackers to access all seller management interfaces and list all products/orders, put products on/off sale, finish/cancel orders, and modify categories without authentication.
CVE-2026-80164	9.1	CRIT		0.002	dell:secure_connect_gateway	Dell SCG 5.0 Appliance versions prior to 5.36.00.16 and Dell SCG 5.0 Application versions prior to 5.36.00.00, contains an Improper Certificate Validation vulnerability. An unauthenticated attacker with remote access could potentially exploit this vulnerability, leading to unauthorized access.
CVE-2026-87806	9.1	CRIT		0.003		Parse Server versions <= 8.6.87 and >= 9.0.0 < 9.10.1-alpha.7 contain an authentication bypass in the built-in LDAP authentication adapter. The adapter forwarded the client-supplied password to the directory without verifying that a password had been supplied, and treated any non-error response from the directory as proof of authentication. A zero-length credential turns an LDAP simple bind into the unauthenticate...
CVE-2026-53581	9.0	CRIT		0.003		OPNsense is a FreeBSD based firewall and routing platform. Prior to version 26.1.9 of opnsense/core and version 26.4_20 of BE/opnsense/core, a path traversal vulnerability in the NTP configuration module allows an attacker to overwrite arbitrary files on the system as the root user. By manipulating the GPS or PPS serial port parameter, an attacker with access to the NTP configuration can escape the intended direct...
CVE-2026-66768	9.0	CRIT		0.003		SAP GUI for Java does not correctly enforce the trust level policy for certain functions invoked from a connected backend system. A low-privileged attacker could exploit this weakness by manipulating a connected backend system to trigger affected functionality. This could allow arbitrary command execution on the victim's machine, leading to a high impact on the confidentiality, integrity, and availability of the a...
CVE-2026-67403	9.0	CRIT		0.002		Cash Collect contains an improper authorization vulnerability in the Sage AR Automation API. Insufficient tenant-level authorization checks allow authenticated users to access administrative resources belonging to other tenants by specifying a valid non predictable tenant identifier.
CVE-2026-68484	9.0	CRIT		0.002		Cash Collect contains an improper authorization vulnerability in the Sage AR Automation API. Administrative functions do not properly verify user privileges, allowing authenticated low-privileged users to create administrator accounts and obtain elevated privileges.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-71851	9.0	CRIT		0.003		crypto-js is a JavaScript library of crypto standards. Versions of crypto-js prior to 4.0.0 generate randomness in CryptoJS.lib.WordArray.random() using a custom variation of the Multiply-With-Carry pseudorandom number generator, seeded from Math.random(), instead of a cryptographically secure source. This generator was introduced in version 3.1.2-4 and remained present in nearly every 3.x release. Nominal request...
CVE-2026-75604	9.0	CRIT		0.025		Next.js is a React framework for building full-stack web applications. From 13.4.0 until 15.5.24 and 16.3.3, Next.js applications using Pages Router or App Router without Cache Components on Windows-hosted servers do not consistently escape backslashes in route segments before constructing incremental-cache paths. In packages/next/src/shared/lib/router/utils/escape-path-delimiters.ts and packages/next/src/server/l...
CVE-2026-87613	9.0	CRIT		0.004	google:chrome	Incorrect reference resolution in Extensions in Google Chrome prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code outside the sandbox via crafted network traffic. (Chromium security severity: Medium)
CVE-2026-87911	9.0	CRIT		0.01		An OS command injection weakness in the read-only enforcement of the SQL validation component in Amazon awslabs postgres-mcp-server before 1.1.7 might allow an unauthenticated actor to execute operating system commands on the host of a self-managed PostgreSQL server by placing a crafted COPY ... TO PROGRAM statement into content that is processed when an authenticated user interacts with the MCP server in its defa...

Watchlist matches (other priorities)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-19633	8.8	HIGH		0.004		PostgreSQL Anonymizer contains a vulnerability that allows unprivileged masked users to execute arbitrary code by abusing operators, domain casts, or view subqueries that carry untrusted expressions. When these objects are evaluated in the context of the extension's masking mechanisms, the malicious code can run with elevated privileges. The issue is fixed in PostgreSQL Anonymizer 3.1.4 and later versions
CVE-2026-32590	8.8	HIGH		0.004	redhat:mirror_registry_for_red_hat_openshift, redhat:quay	A flaw was found in Red Hat Quay's handling of resumable container image layer uploads. The upload process stores intermediate data in the database using a format that, if tampered with, could allow an attacker to execute arbitrary code on the Quay server.
CVE-2026-33001	8.8	HIGH		0.011	jenkins:jenkins	Jenkins 2.554 and earlier, LTS 2.541.2 and earlier does not safely handle symbolic links during the extraction of .tar and .tar.gz archives, allowing crafted archives to write files to arbitrary locations on the filesystem, restricted only by file system access permissions of the user running Jenkins. This can be exploited to deploy malicious scripts or plugins on the controller by attackers with Item/Configure pe...
CVE-2026-40858	8.8	HIGH		0.009	apache:camel	The camel-infinispan component's ProtoStream-based remote aggregation repository deserializes data read from a remote Infinispan cache using java.io.ObjectInputStream without applying any ObjectInputFilter. An attacker who can write to the Infinispan cache used by a Camel application can inject a crafted serialized Java object that, when read during normal aggregation repository operations such as get or recover, ...
CVE-2026-41870	8.8	HIGH		0.007	apache:nutch	Missing Authorization, Improper Control of Generation of Code ('Code Injection'), Improper Control of Dynamically-Managed Code Resources, Use of Externally-Controlled Input to Select Classes or Code ('Unsafe Reflection') vulnerability in Apache Nutch Server (Nutch REST API). This issue affects Apache Nutch: from 1.11 through 1.22. Users are recommended to upgrade to version 1.23, which removes the Nutch Ser...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-44829	8.8	HIGH		0.004		Gotenberg is a Docker-powered stateless API for PDF files. In 8.32.0 and earlier, filename handling in pkg/modules/api/context.go uses filepath.Base on Linux, which does not treat backslashes as path separators, so a multipart filename containing Windows-style parent directory components survives sanitization. The original filename flows through ctx.diskToOriginal and the multi-output PDF routes into archives.File...
CVE-2026-49050	8.8	HIGH		0.003	apache:dolphinscheduler	General user can mint admin access tokens via /access-tokens This issue affects Apache DolphinScheduler: before 3.4.2. Users are recommended to upgrade to version 3.4.2, which fixes the issue.
CVE-2026-49255	8.8	HIGH		0.005		electerm is an open-sourced terminal/ssh/sftp/telnet/serialport/RDP/VNC/Spice/ftp client. Prior to 3.11.11, electerm constructs operating system commands in src/app/lib/fs.js by interpolating untrusted file paths into the rmrf(), mv(), and cp() functions. A malicious SSH or SFTP server can provide a filename containing quote characters and shell metacharacters, and a victim can cause that filename to reach the aff...
CVE-2026-49467	8.8	HIGH		0.004		Pingvin Share X is a secure and easy self-hosted file sharing platform. A vulnerability in versions 1.5.0 through 1.18.0 allow an attacker to bypass password verification when managing Time-based One-Time Password (TOTP) settings. The root cause is a missing `await` keyword on calls to the asynchronous `verifyPassword` method in `authTotp.service.ts` and the `authenticateUser` method in `auth.service.ts`. In JavaS...
CVE-2026-50191	8.8	HIGH		0.003		4gaBoards is a boards system for realtime project management. Prior to 3.3.8, 4gaBoards is vulnerable to pre-account takeover when registrationEnabled, localRegistrationEnabled, and ssoRegistrationEnabled are enabled and Google, GitHub, Microsoft, or OIDC SSO is configured. The POST /api/register endpoint permits creation of an unverified local account with a victim's email address, and POST /api/access-tokens per...
CVE-2026-53277	8.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: KVM: arm64: Take the SRCU lock for page table walks in fault injection and AT emulation walk_s1() and kvm_walk_nested_s2() expect to be called while holding kvm->srcu to guard against memslot changes. While this is generally the case, __kvm_at_s12() and __kvm_find_s1_desc_level() call into the respective walkers without taking kvm->srcu. Fix by...
CVE-2026-53322	8.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: vfio/pci: Clean up DMABUFs before disabling function On device shutdown, make vfio_pci_core_close_device() call vfio_pci_dma_buf_cleanup() before the function is disabled via vfio_pci_core_disable(). This ensures that all access via DMABUFs is revoked before the function's BARs become inaccessible. This fixes an issue where, if the function is...
CVE-2026-54099	8.8	HIGH		0.001	redhat:openshift_container_platform, redhat:windows_machine_config_operator	A flaw was found in the Windows Machine Config Operator (WMCO) for Red Hat OpenShift Container Platform. The WICD CSR auto-approver validates that a Certificate Signing Request contains the organization system:wicd-nodes but does not reject additional organization values such as system:masters. A compromised Windows worker node that holds WICD credentials can submit a CSR that is auto-approved and signed by the cl...
CVE-2026-55485	8.8	HIGH		0.004		Piccolo Admin is an admin interface and content management system for Python, built on top of Piccolo. Prior to 1.14.0, piccolo_admin/endpoints.py uses superuser_validators to block PUT, PATCH, DELETE, and POST requests by non-superusers but permits GET requests to configured user and session tables, while piccolo_api/session_auth/tables.py exposes SessionsBase.token because the token column is not secret. In depl...
CVE-2026-55509	8.8	HIGH		0.004		WsgiDAV is a generic and extendable WebDAV server based on WSGI. Prior to 4.3.5, the sample MySQLBrowserProvider in wsgidav/samples/mysql_dav_provider.py concatenates the record key parsed from a request URL directly into SQL WHERE clauses. The affected _exists_record_by_primary_key, _get_field_by_primary_key, and _get_record_by_primary_key methods are part of a shipped example provider that is not enabled by defa...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-55585	8.8	HIGH		0.004		QWED is open-source AI verification infrastructure for deterministic verification of LLM outputs, tool calls, code, schemas, and agent state before production execution. Prior to 5.1.2, the qwed package passes caller-controlled math expressions directly to SymPy <code>parse_expr()</code> without restricted <code>global_dict</code> and <code>local_dict</code> namespaces, allowing Python <code>eval()</code> to resolve builtins and execute arbitrary Python code in the...
CVE-2026-55676	8.8	HIGH		0.003		Malcolm is a network traffic analysis tool suite. The file-upload component (FilePond PHP backend) accepts uploads at <code>`POST /server/php/submit.php`</code> and stores them in a directory served by the same nginx and php-fpm instance. The allow-list that should restrict accepted file types is an empty array by default (<code>`file-upload/php/config.php:16`</code>), so the type check is a no-op and every extension is accepted. The filen...
CVE-2026-57866	8.8	HIGH		0.006	apache:impala	Server side request forgery in Apache Impala versions 4.4.x and 4.5.x. Authenticated Impala users with permissions to execute the <code>ai_generate_text()</code> function can exfiltrate secrets provided by the credential providers configured in the <code>`hadoop.security.credential.provider.path`</code> property of <code>`core-site.xml`</code> . The secret's key must be known to the user.
CVE-2026-62316	8.8	HIGH		0.004		Microsoft UFO open-source framework for intelligent automation across devices and platforms. Prior to 3.0.8, <code>ufo/client/mcp/http_servers/linux_mcp_server.py</code> binds a FastMCP streamable HTTP server to <code>localhost:8010</code> but does not validate the Host, Origin, or Sec-Fetch-Site headers. An attacker-controlled web page can use DNS rebinding to reach the local /mcp endpoint, enumerate tool schemas through <code>tools/list</code> , and i...
CVE-2026-62744	8.8	HIGH		0.008		Heap-based buffer overflow in Microsoft Windows Media Foundation allows an unauthorized attacker to execute code over a network.
CVE-2026-65772	8.8	HIGH		0.009		Deserialization of untrusted data in Microsoft Dynamics 365 allows an authorized attacker to execute code over a network.
CVE-2026-69266	8.8	HIGH		0.004	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Integer overflow or wraparound in Windows DHCP Server allows an unauthorized attacker to execute code over a network.
CVE-2026-69268	8.8	HIGH		0.007	microsoft:sharepoint_server	Improper access control in Microsoft Office SharePoint allows an authorized attacker to execute code over a network.
CVE-2026-69273	8.8	HIGH		0.005	microsoft:sharepoint_server	Improper access control in Microsoft Office SharePoint allows an authorized attacker to execute code over a network.
CVE-2026-69282	8.8	HIGH		0.005	microsoft:sharepoint_server	Improper access control in Microsoft Office SharePoint allows an authorized attacker to execute code over a network.
CVE-2026-69285	8.8	HIGH		0.006	microsoft:365_apps, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Heap-based buffer overflow in Microsoft Office allows an unauthorized attacker to execute code over a network.
CVE-2026-69334	8.8	HIGH		0.008		Heap-based buffer overflow in Windows Volume Manager Extension Driver allows an unauthorized attacker to execute code over a network.
CVE-2026-69355	8.8	HIGH		0.008		External control of file name or path in Microsoft Exchange Server allows an authorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69360	8.8	HIGH		0.008		Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-69386	8.8	HIGH		0.008		Heap-based buffer overflow in Microsoft Windows Media Foundation allows an unauthorized attacker to execute code over a network.
CVE-2026-69434	8.8	HIGH		0.008		Heap-based buffer overflow in Windows URL Moniker allows an unauthorized attacker to execute code over a network.
CVE-2026-69439	8.8	HIGH		0.007		Heap-based buffer overflow in .NET and Visual Studio allows an unauthorized attacker to elevate privileges over a network.
CVE-2026-69442	8.8	HIGH		0.008	microsoft:365_apps, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Heap-based buffer overflow in Microsoft Office allows an unauthorized attacker to execute code over a network.
CVE-2026-69464	8.8	HIGH		0.009	microsoft:sharepoint_server	Execution with unnecessary privileges in Microsoft Office SharePoint allows an authorized attacker to elevate privileges over a network.
CVE-2026-69465	8.8	HIGH		0.008	microsoft:sharepoint_server	Missing authorization in Microsoft Office SharePoint allows an authorized attacker to execute code over a network.
CVE-2026-69494	8.8	HIGH		0.008		Out-of-bounds read in Windows Event Logging Service allows an unauthorized attacker to execute code over a network.
CVE-2026-69495	8.8	HIGH		0.008		Heap-based buffer overflow in Windows Event Logging Service allows an unauthorized attacker to execute code over a network.
CVE-2026-69511	8.8	HIGH		0.008		Heap-based buffer overflow in Microsoft Windows Media Foundation allows an unauthorized attacker to execute code over a network.
CVE-2026-69556	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-69598	8.8	HIGH		0.008		Incorrect calculation of buffer size in Windows iSCSI allows an unauthorized attacker to execute code over a network.
CVE-2026-69601	8.8	HIGH		0.008		Heap-based buffer overflow in Microsoft Windows Media Foundation allows an unauthorized attacker to execute code over a network.
CVE-2026-69603	8.8	HIGH		0.003		Heap-based buffer overflow in Windows Hyper-V allows an authorized attacker to execute code locally.
CVE-2026-69628	8.8	HIGH		0.009		Heap-based buffer overflow in Windows iSCSI allows an authorized attacker to execute code over a network.
CVE-2026-69629	8.8	HIGH		0.008	microsoft:365_apps, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, microsoft:outlook	Heap-based buffer overflow in Microsoft Office Outlook allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69632	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Use after free in Microsoft Office allows an unauthorized attacker to execute code over a network.
CVE-2026-69649	8.8	HIGH		0.008		Heap-based buffer overflow in Windows Raw Image Extension allows an unauthorized attacker to execute code over a network.
CVE-2026-69671	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-69676	8.8	HIGH		0.012		Authentication bypass by capture-replay in Windows Kerberos allows an authorized attacker to execute code over a network.
CVE-2026-69678	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Use after free in Microsoft Office PowerPoint allows an unauthorized attacker to execute code over a network.
CVE-2026-69686	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Stack-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-69712	8.8	HIGH		0.009		Use after free in Windows Key Distribution Center allows an authorized attacker to execute code over a network.
CVE-2026-69716	8.8	HIGH		0.009	microsoft:sharepoint_server	Improper neutralization of special elements used in an sql command ('sql injection') in Microsoft Office SharePoint allows an authorized attacker to elevate privileges over a network.
CVE-2026-69722	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Stack-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-69724	8.8	HIGH		0.008	microsoft:sharepoint_server	Missing authorization in Microsoft Office SharePoint allows an authorized attacker to execute code over a network.
CVE-2026-69740	8.8	HIGH		0.003		Use after free in Windows Hello allows an authorized attacker to elevate privileges locally.
CVE-2026-69742	8.8	HIGH		0.008	microsoft:365_apps, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, microsoft:publisher	Integer overflow or wraparound in Microsoft Office Publisher allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69759	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Stack-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-69764	8.8	HIGH		0.008	microsoft:365_apps, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, microsof	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-69767	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Use after free in Microsoft Office PowerPoint allows an unauthorized attacker to execute code over a network.
CVE-2026-69772	8.8	HIGH		0.008		Heap-based buffer overflow in Windows Network File System allows an unauthorized attacker to execute code over a network.
CVE-2026-69784	8.8	HIGH		0.003		Use after free in Windows Hello allows an authorized attacker to elevate privileges locally.
CVE-2026-69797	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Use after free in Microsoft Office PowerPoint allows an unauthorized attacker to execute code over a network.
CVE-2026-69857	8.8	HIGH		0.004	microsoft:azure_cosmos_db	Authorization bypass through user-controlled key in Azure Cosmos DB allows an authorized attacker to perform spoofing over a network.
CVE-2026-70351	8.8	HIGH		0.008		Integer overflow or wraparound in Microsoft WebP Image Extension allows an unauthorized attacker to execute code over a network.
CVE-2026-70586	8.8	HIGH		0.008		Heap-based buffer overflow in Windows Paint allows an unauthorized attacker to execute code over a network.
CVE-2026-71352	8.8	HIGH		0.007		Integer underflow (wrap or wraparound) in Windows Remote Access Connection Manager allows an authorized attacker to execute code over a network.
CVE-2026-71808	8.8	HIGH		0.004		A SQL Injection vulnerability in Siam Ordering (siam-server) 1.0.0 allows remote authenticated attackers to execute arbitrary SQL commands via the \${} string concatenation in AdminMapper.java and multiple other Mapper files (including MerchantWithdrawRecordMapper.java and MemberWithdrawRecordMapper.java).
CVE-2026-72933	8.8	HIGH		0.008		Heap-based buffer overflow in Microsoft WDAC OLE DB provider for SQL allows an unauthorized attacker to execute code over a network.
CVE-2026-72940	8.8	HIGH		0.008		Heap-based buffer overflow in Windows Schannel allows an unauthorized attacker to execute code over a network.
CVE-2026-72950	8.8	HIGH		0.009		Remote Code Execution in Windows Routing and Remote Access Service (RRAS) allows attacker to gain an unauthorized access to victim's machine

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-72959	8.8	HIGH		0.009		Remote Code Execution in Windows Routing and Remote Access Service (RRAS) allows attacker to gain an unauthorized access to victim's machine
CVE-2026-72960	8.8	HIGH		0.008		Heap-based buffer overflow in Windows Media Player allows an unauthorized attacker to execute code over a network.
CVE-2026-72972	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-72973	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-73012	8.8	HIGH		0.006		Heap-based buffer overflow in Windows Management Services allows an authorized attacker to elevate privileges over a network.
CVE-2026-73013	8.8	HIGH		0.006		Heap-based buffer overflow in Windows Imaging Component allows an unauthorized attacker to execute code over a network.
CVE-2026-73023	8.8	HIGH		0.006		Heap-based buffer overflow in Windows Imaging Component allows an unauthorized attacker to execute code over a network.
CVE-2026-73222	8.8	HIGH		0.002		Claude Code Templates is a CLI tool for configuring and monitoring Claude Code. Prior to 1.29.4, the Claude Code Studio server launched by the --studio option in cli-tool/src/sandbox-server.js binds to all interfaces on port 3444, permits cross-origin requests, and requires no authentication. The POST /api/execute endpoint passes the prompt request-body field to executeLocalTask(), and POST /api/install-agent pass...
CVE-2026-77504	8.8	HIGH		0.006		Double free in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-77901	8.8	HIGH		0.006	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Null pointer dereference in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-77908	8.8	HIGH		0.007		Improper control of generation of code ('code injection') in Microsoft Dynamics 365 allows an authorized attacker to execute code over a network.
CVE-2026-78439	8.8	HIGH		0.006		Stack-based buffer overflow in Microsoft Graphics Component allows an unauthorized attacker to execute code over a network.
CVE-2026-78442	8.8	HIGH		0.006		Heap-based buffer overflow in Windows OLE DB allows an unauthorized attacker to execute code over a network.
CVE-2026-78504	8.8	HIGH		0.006	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Stack-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-78505	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Heap-based buffer overflow in Microsoft Office allows an unauthorized attacker to execute code over a network.
CVE-2026-78507	8.8	HIGH		0.006	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Use after free in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-78511	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-78512	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Numeric truncation error in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-78514	8.8	HIGH		0.006	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Use after free in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-78517	8.8	HIGH		0.006	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-78518	8.8	HIGH		0.009	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to execute code over a network.
CVE-2026-78519	8.8	HIGH		0.006	microsoft:365_apps, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, microsoft:outlook	Use of uninitialized resource in Microsoft Office Outlook allows an unauthorized attacker to execute code over a network.
CVE-2026-78521	8.8	HIGH		0.006	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-78524	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Out-of-bounds write in Microsoft Office allows an unauthorized attacker to execute code over a network.
CVE-2026-78525	8.8	HIGH		0.008	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Use after free in Microsoft Office Outlook allows an unauthorized attacker to execute code over a network.
CVE-2026-78526	8.8	HIGH		0.006	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-80080	8.8	HIGH		0.006	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Double free in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-80081	8.8	HIGH		0.005	microsoft:365_apps	Use after free in Microsoft Office PowerPoint allows an unauthorized attacker to execute code over a network.
CVE-2026-80085	8.8	HIGH		0.005	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-80914	8.8	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: Bluetooth: ISO: fix use-after-free of listener socket in iso_conn_ready iso_conn_ready() looks up the BIS listener socket with iso_get_sock(), which takes a reference, and then, without re-checking its state, creates a child socket from it: parent = iso_get_sock(hdev, ...); if (!parent) return; lock_sock(parent); sk = i...
CVE-2026-80921	8.8	HIGH		0.001		In the Linux kernel, the following vulnerability has been resolved: KVM: s390: vsie: zero stale crypto bits When shadowing crypto access bits from a format0 apcb (crycb 0 or 1), the bits 64..255 are unchanged from whatever is in the vsie page in the crycb and thus in the apcb. This gives a nested guest potential access to a device no longer available. Zero out the remaining bits.
CVE-2026-81352	8.8	HIGH		0.005		Heap-based buffer overflow in Microsoft Windows Codecs Library allows an unauthorized attacker to execute code over a network.
CVE-2026-81385	8.8	HIGH		0.01	microsoft:365_apps, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, microsoft:publisher	Deserialization of untrusted data in Microsoft Office Publisher allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-81952	8.8	HIGH		0.006	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Heap-based buffer overflow in Microsoft Office Word allows an unauthorized attacker to execute code over a network.
CVE-2026-81955	8.8	HIGH		0.006		Heap-based buffer overflow in Microsoft Graphics Component allows an unauthorized attacker to execute code over a network.
CVE-2026-83996	8.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Error Reporting allows an authorized attacker to elevate privileges locally.
CVE-2026-85877	8.8	HIGH		0.004	microsoft:windows_11_24h2	Heap-based buffer overflow in Windows Print Spooler Components allows an unauthorized attacker to execute code over a network.
CVE-2026-87585	8.8	HIGH		0.003	google:chrome, microsoft:windows	Double free in PDFium in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker to potentially execute arbitrary code inside the sandbox via a crafted PDF file. (Chromium security severity: High)
CVE-2024-58374	8.7	HIGH		0.005		Hongjing e-HR contains an unauthenticated SQL injection vulnerability in the getSdutyTree servlet endpoint that allows remote unauthenticated attackers to access protected resources by supplying a path traversal sequence in the request URI to bypass the oauthservlet authentication filter. Attackers can inject UNION-based SQL payloads through the unsanitized codeitemid parameter into the underlying Microsoft SQL Se...
CVE-2026-3505	8.7	HIGH		0.008		Allocation of resources without limits or throttling, Uncontrolled Resource Consumption vulnerability in Legion of the Bouncy Castle Inc. BC-JAVA bcpg on all (pg modules). This vulnerability is associated with program files AEADEncDataPacket.Java, BcAEADUtil.Java, JceAEADUtil.Java, OperatorHelper.Java. This issue affects BC-JAVA: from 1.74 before 1.80.2, from 1.81 before 1.81.1, from 1.82 before 1.84.
CVE-2026-47683	8.7	HIGH		0.004		vm2 is an open source vm/sandbox for Node.js. Prior to 3.11.6, the bufferAllocLimit enforcement in lib/setup-sandbox.js does not cover Buffer.concat(list, totalLength) or Buffer.from(arrayLike) with an attacker-controlled length, allowing sandbox code to perform large synchronous host external-memory allocations that bypass the configured cap and can exhaust the host process. This issue is fixed in version 3.11.6.
CVE-2026-48006	8.7	HIGH		0.007	netty:netty	Netty is a network application framework for development of protocol servers and clients. Prior to versions 4.1.135.Final and 4.2.15.Final, the RedisArrayAggregator handler permanently leaks pooled direct-memory buffers when a Redis pipeline connection closes before a RESP array aggregate completes. The handler retains child messages in per-handler state (`depths` field) but defines no `channelInactive`, `handlerR...
CVE-2026-48026	8.7	HIGH		0.002		lakeFS is an open-source tool that transforms object storage into a Git-like repositories. Prior to version 1.81.1 of the open source edition and 1.84.0 of the enterprise edition, lakeFS Web UI renders markdown files from repository objects without sanitizing the resulting HTML. A user with write access to any repository branch can commit a `.md` object containing arbitrary HTML/JavaScript. Any other user who open...
CVE-2026-49478	8.7	HIGH		0.002		Fulcio is a certificate authority for issuing code signing certificates for an OpenID Connect (OIDC) identity. Versions through 1.8.5 improperly follow cross-host redirects and attach Kubernetes ServiceAccount tokens during OIDC discovery, allowing a malicious or compromised issuer to perform blind SSRF, substitute and cache malicious JWKS keys, or disclose ServiceAccount tokens to external hosts. Version 1.8.6 bl...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-61556	8.7	HIGH		0.004		LiquidJS is a Shopify / GitHub Pages compatible template engine in pure JavaScript. From 10.26.0 until 10.27.1, the strip_html filter in src/filters/html.ts can enter an infinite loop when an input string contains <, includes at least one preceding character, and has no later >. In strip_html, the search for the next opener advances It while the loop index remains unchanged when the closer search returns -1, and t...
CVE-2026-67195	8.7	HIGH		0.012		Perspective 5.0.0 contains a remote code execution vulnerability that allows unauthenticated attackers to execute arbitrary operating system commands by submitting crafted expression strings to the PolarsVirtualServer backend, which passes client-supplied input directly to Python's eval() with only __builtins__={} cleared. Attackers can exploit Python object attribute traversal through the interpreter's loaded cla...
CVE-2026-68899	8.7	HIGH		0.004		Wekan is open source kanban built with Meteor. Prior to 9.90, isValid() in models/fileValidation.js used the Unix file command for content-based MIME detection, but detectMimeFromFile() silently returned undefined when that binary was unavailable and the validation fell back to the attacker-controlled fileObj.type supplied through server/routes/attachmentApi.js. On deployments with WITH_API=true and no file bi...
CVE-2026-69096	8.7	HIGH		0.017		OpenWrt luci-app-dockerman (LuCI master and openwrt-25.12 snapshots containing the ucode docker_rpc.uc RPC backend after the JS/ucode conversion) contains an OS command injection vulnerability. The package's read ACL grants broad ubus access to docker.* / docker.container.*, which exposes the docker.container.ttyd_start method even though it performs mutating operations. The run_ttyd handler builds a shell command...
CVE-2026-71491	8.7	HIGH		0.003		sqlparse is a non-validating SQL parser module for Python. Prior to 0.6.0, group_comments in sqlparse/engine/grouping.py repeatedly rescans comment-only statements before the MAX_GROUPING_TOKENS guard, causing quadratic CPU consumption through sqlparse.parse() and sqlparse.format(sql, strip_comments=True). This issue is fixed in version 0.6.0.
CVE-2026-73413	8.7	HIGH		0.003		Shescape is a simple shell escape library for JavaScript. From 2.1.11 until 2.1.14 and 3.0.1, the flag-protection loop in compose in src/internal/compose.js repeatedly joins and slices flag fragments when flagProtection is enabled, which is the default, making processing quadratic in input size across the escape, escapeAll, quote, and quoteAll APIs. An attacker who can supply a large untrusted input containing man...
CVE-2026-75596	8.7	HIGH		0.004		Netty is an asynchronous, event-driven network application framework. Prior to 4.1.137.Final and 4.2.17.Final, the default io.netty.handler.ssl.SniHandler constructors use the pre-handshake ClientHello aggregation path in handler/src/main/java/io/netty/handler/ssl/SslClientHelloHandler.java at io.netty.handler.ssl.SslClientHelloHandler#decode, where handshakeBuffer.clear() and writeBytes() recopy all previously re...
CVE-2026-77101	8.7	HIGH		0.003	commvault:commvault, linux:linux_kernel, microsoft:windows	CommServe contained a stack-based buffer overflow issue affecting service availability. Software customers upgrade to resolved maintenance release. Update CommServe.
CVE-2026-77102	8.7	HIGH		0.003	commvault:commvault, linux:linux_kernel, microsoft:windows	CommServe contained a heap-based buffer overflow issue affecting service availability. Software customers upgrade to resolved maintenance release. Update CommServe.
CVE-2026-77103	8.7	HIGH		0.003	commvault:commvault, linux:linux_kernel, microsoft:windows	CommServe contained an authentication bypass issue affecting access authorization and information disclosure. Software customers upgrade to resolved maintenance release. Update CommServe.
CVE-2026-77105	8.7	HIGH		0.002	commvault:commvault, linux:linux_kernel, microsoft:windows	CommServe contained a cryptographic signature verification issue affecting privilege management. Software customers upgrade to resolved maintenance release. Update CommServe and Web Server.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-77357	8.7	HIGH		0.003		Mesop is a Python-based UI framework that allows users to build web applications. Prior to 1.3.3, applications running in debug mode expose a GET /hot-reload endpoint whose unbounded loop depends on the user-supplied counter parameter, allowing an unauthenticated attacker to hold worker threads with high counter values until the worker pool is exhausted and the server becomes unavailable. A single unauthenticated ...
CVE-2026-79756	8.7	HIGH		0.051		Nuclio is a "Serverless" framework for Real-Time Events and Data Processing. Prior to version 1.17.4, the fix for unauthenticated OS command injection in the nuclio dashboard on the local/Docker platform is incomplete. The fix added validateFunctionName for function names and common.Quote() for the named-resource shell command path, but the list-all resource path (triggered when no specific resource name is provid...
CVE-2026-84304	8.7	HIGH		0.004		gRPC-Go is the Go language implementation of gRPC. Prior to 1.83.1, internal/transport/transport.go stores each fragmented HTTP/2 DATA frame as a separate recvMsg in recvBuffer, so millions of one-byte frames can consume disproportionate heap memory even when payload bytes remain within connection and stream flow-control windows. An unauthenticated remote attacker can use concurrent multiplexed streams to exhaust ...
CVE-2026-87817	8.7	HIGH		0.003	gitpython_project:gitpython	GitPython before 3.1.60 fails to properly validate the git directory location, allowing attackers to impersonate the git directory using tracked files like gitdir, commondir, and HEAD. Attackers can execute arbitrary code by placing a malicious pre-commit hook in the tracked hooks directory that executes when a victim calls index.commit() on a cloned or opened repository.
CVE-2026-87819	8.7	HIGH		0.003	gitpython_project:gitpython	GitPython before 3.1.60 contains a regular expression denial of service vulnerability in Actor.name_email_regex that processes commit author and committer fields. Attackers can craft a commit object with a malformed author field containing an unterminated angle bracket to cause quadratic backtracking, exhausting CPU resources for over two minutes per commit access.
CVE-2026-21087	8.6	HIGH		0.001	samsung:android	Out-of-bounds write in libmdnie.so prior to SMR Sep-2026 Release 1 allows local attackers to execute arbitrary code with system server privilege.
CVE-2026-47727	8.6	HIGH		0.004		Trilium is an open-source hierarchical note-taking application. In versions prior to 0.104.0, the default-on "Safe import" filter fails to neutralize the shareTemplate relation because that relation is not marked as dangerous, allowing an attacker-supplied import archive to plant a server-side template that leads to remote code execution. The relation is omitted from the built-in list of dangerous attributes, so u...
CVE-2026-50553	8.6	HIGH		0.004		Note Mark is an open-source note-taking application. Prior to version 0.19.5, Note Mark validates book and note slug values with the OpenAPI/huma tag pattern:"[a-z0-9-]+". huma compiles this with regexp.MustCompile(s.Pattern) and tests it with patternRe.MatchString(str), an UNANCHORED match. Because the pattern is not anchored (^...\$), any string that merely CONTAINS one [a-z0-9-] substring passes validation. A sl...
CVE-2026-55848	8.6	HIGH		0.003		mapfish-print is a component of MapFish for printing templated cartographic maps. Prior to 3.28.30, 3.30.32, 3.31.24, 3.33.16, and 4.0.5, MapFish Print accepts an attacker-controlled GML layer url in requests to the /api/print3/print endpoint and fetches XML parsed by core/src/main/java/org/mapfish/print/map/geotools/GmlLayer.java without disabling external entities and external DTDs. A remote XML document and DTD...
CVE-2026-67608	8.6	HIGH		0.015		Telenia Software TVox 26.5.3 and prior 26.x versions, and 24.9.21 and prior 24.x versions, contain an OS command injection vulnerability in action_audio.php that allows authenticated attackers to execute arbitrary operating system commands by passing an unsanitized pid parameter into an exec() call when the action parameter is set to checkProcess. Attackers can inject malicious OS commands through the pid request ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-73247	8.6	HIGH		0.004		Kestra is an open-source, event-driven orchestration platform. Prior to 2.0.0, Kestra's core/src/main/java/io/kestra/core/runners/pebble/functions/HttpFunction.java passes the user-controlled http() uri argument to URI.create() and the server-side HTTP client without restricting private, loopback, or link-local destinations, allowing an unauthenticated attacker to import and execute a flow that accesses internal s...
CVE-2026-81889	8.6	HIGH		0.003		eFinder is an open-source file manager for web, written in JavaScript using jQuery UI. Prior to 2.1.70, eFinder URL uploads in php/eFinder.class.php can bypass server-side request forgery protections when PHP cURL is unavailable because validate_address() validates \$info['ip'], but get_remote_contents() selects fsock_get_contents(), which connects to \$arr['host'] and performs a second DNS resolution. An attacke...
CVE-2026-84452	8.6	HIGH		0.009		Windows ML CLI is a command line tool for building portable, performant, and high-quality AI models for Windows ML. Prior to 0.4.0, the src/winml/modelkit/serve/cli_api.py component exposes WinML CLI commands through a localhost HTTP API without authentication and configures the allow_origins setting as a wildcard in both src/winml/modelkit/serve/cli_api.py and src/winml/modelkit/serve/app.py. A malicious website ...
CVE-2026-86733	8.6	HIGH		0.003	snipeitapp:snipe-it	Snipe-IT before 8.7.0 streams the SQL entry from an uploaded backup archive directly into the MySQL/MariaDB command-line client ('mysql') without the --binary-mode flag, so the client interprets lines beginning with backslash commands such as '\!' as local shell commands. An authenticated superadministrator who uploads a crafted ZIP backup (POST /admin/backups/upload) and triggers a restore (POST /admin/backups/re...
CVE-2026-87794	8.6	HIGH		0.002		bestzip versions 2.2.6 and 3.0.2 contain an argument injection vulnerability in the nativeZip function that allows attackers to inject arbitrary arguments to the Info-ZIP backend. Attackers can supply a malicious destination path combined with crafted source entries to execute arbitrary commands with Node.js process privileges. Fixed in 2.2.7 and 3.0.3.
CVE-2026-54606	8.5	HIGH		0.004		SunEditor is a lightweight and powerful WYSIWYG editor in vanilla JavaScript with no dependencies. Prior to 3.1.4, the SunEditor Embed plugin in src/plugins/modal/embed.js parses attacker-controlled raw embed HTML with DOMParser and processes the resulting DOM nodes. When an external script element follows a valid iframe, the plugin recreates a script element from the attacker-controlled src attribute and appends ...
CVE-2026-57485	8.5	HIGH		0.003		Stirling-PDF is a locally hosted web application that facilitates various operations on PDF files. Prior to 2.9.0, the /api/v1/pipeline/handleData endpoint in app/core/src/main/java/stirling/software/SPDF/controller/api/pipeline/PipelineProcessor.java injects the STIRLING-PDF-BACKEND-API-USER API key into pipeline subrequests, allowing an authenticated ROLE_USER to retrieve the key through /api/v1/user/get-api-key...
CVE-2026-58113	8.5	HIGH		0.002		A vulnerability has been identified in Teamcenter V2412 (All versions < V2412.0013), Teamcenter V2506 (All versions < V2506.0010), Teamcenter V2512 (All versions < V2512.2607), Teamcenter V2606 (All versions < V2606.2607). Affected applications do not properly encode user-supplied input reflected into HTML attribute contexts within the authentication redirect flow (/auth/ endpoint). This could allow an unauthenti...
CVE-2026-67609	8.5	HIGH		0.001		Telenia Software TVox 26.5.3 and prior 26.x versions, and 24.9.21 and prior 24.x versions, contain a privilege escalation vulnerability that allows attackers with access to the apache account to execute arbitrary commands as root by exploiting an insecure sudoers configuration in /etc/sudoers.d/telenia. The configuration grants the apache user NOPASSWD execution of /bin/nice, which can be leveraged to invoke arbit...
CVE-2026-73233	8.5	HIGH		0.002		FreeCAD is a free and open-source multiplatform 3D parametric modeler. Prior to 1.1.2, the FEM Displacement Constraint task dialog in src/Mod/Fem/Gui/TaskFemConstraintDisplacement.cpp passes the xDisplacementFormula, yDisplacementFormula, and zDisplacementFormula fields of a Fem::ConstraintDisplacement object through TaskDlgFemConstraintDisplacement::accept() into Gui::Command::doCommand. The escaping helper neutr...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-73248	8.5	HIGH		0.002		calibre is an e-book manager. Prior to 9.12.0, calibre processes attacker-controlled composite_template metadata from a malicious EPUB, OPF, PDF, or similar file through program: and a nested template() call whose formatter does not inherit allow_python_templates=False, allowing a nested python: template to reach compile_python_template and execute arbitrary Python code when the file is opened or imported. This is...
CVE-2026-9854	8.5	HIGH		0.001	hitachienergy:microscada_x_sys600	A vulnerability exists in SYS600 RBAC mechanism where users having access to the engineering tools could elevate their privileges to administrator level on the underlying Windows host, granting themselves full control over the host machine.
CVE-2026-52491	8.4	HIGH		0.001		An issue in libtiff 85f2ac8e0b01cb7db2bbecf4a3b891bdbef67938 allows an attacker to execute arbitrary code via the libtiff/tools/thumbnail.c: main() component
CVE-2026-55581	8.4	HIGH		0.003		mcp-shell is an MCP server for running shell commands securely, auditably, and on demand. Prior to 0.6.0, the default Docker security.yaml includes /bin/bash in allowed_executables, while security.go validates only the first token and checkBlockedPatternsAndCommands does not reject the shell command-mode flag -c. A caller of the shell_exec MCP tool can provide the command argument `/bin/bash -c <arbitrary-command>...
CVE-2026-55582	8.4	HIGH		0.002		mcp-shell is an MCP server for running shell commands securely, auditably, and on demand. Prior to 0.6.0, the default security.yaml allows /usr/bin/git, while security.go omits ! from containsShellMetacharacters and containsDangerousShellConstructs and applies no per-executable argument policy. A caller of the shell_exec MCP tool can provide the command argument /usr/bin/git -c alias.pwn=!<arbitrary-command>, caus...
CVE-2026-87811	8.4	HIGH		0.002		SiYuan before v3.8.2 inserts persisted notebook template paths into HTML input value attributes without proper attribute encoding. Attackers can craft malicious template paths that break out of the attribute context and execute JavaScript when a victim opens notebook configuration, enabling same-origin API requests and application state manipulation.
CVE-2026-87813	8.4	HIGH		0.003		SiYuan before v3.8.2 contains a stored cross-site scripting vulnerability in the Search Assets result list where asset filenames are interpolated into HTML without escaping. Authenticated attackers can craft asset filenames containing malicious markup that executes JavaScript in the victim's browser when searching assets, enabling same-origin API requests and application state manipulation.
CVE-2026-87814	8.4	HIGH		0.002		SiYuan before v3.8.2 contains a stored cross-site scripting vulnerability in the search asset preview feature that fails to escape indexed asset content before inserting it into the DOM using innerHTML. Attackers who can place crafted text assets in a workspace can execute JavaScript in the SiYuan origin when victims preview the assets, enabling authenticated API requests and workspace manipulation.
CVE-2026-54100	8.3	HIGH		0.003	redhat:openshift_container_platform, redhat:windows_machine_config_operator	A flaw was found in the Windows Machine Config Operator (WMCO) for Red Hat OpenShift Container Platform. WMCO establishes SSH connections to Windows worker nodes without verifying the remote server host key. An adjacent-network attacker who can intercept or redirect WMCO's SSH session can capture WICD and kubelet bootstrap credentials transferred during node configuration, enabling compromise of Windows node ident...
CVE-2026-77104	8.3	HIGH		0.004	commvault:commvault, linux:linux_kernel, microsoft:windows	CommServe contained a path traversal issue affecting information disclosure. Software customers upgrade to resolved maintenance release. Update CommServe.
CVE-2026-87524	8.3	HIGH		0.003	google:chrome, microsoft:windows	Use after free in Core in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker who had compromised the renderer process to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: High)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-87616	8.3	HIGH		0.004	google:chrome, microsoft:windows	Improper initialization in Views in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker who had compromised the renderer process and leveraged social engineering to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87618	8.3	HIGH		0.003	google:chrome, microsoft:windows	Incorrect reference resolution in Storage in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker who had compromised the renderer process to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-87644	8.3	HIGH		0.003	google:chrome, microsoft:windows	Incorrect authorization in Views in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker who had compromised the renderer process and leveraged social engineering to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-87648	8.3	HIGH		0.003	google:chrome, microsoft:windows	Use after free in ANGLE in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker who had compromised the renderer process to potentially execute arbitrary code outside the sandbox via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-41604	8.2	HIGH		0.009	apache:thrift	Out-of-bounds Read vulnerability in Apache Thrift. This issue affects Apache Thrift: before 0.23.0. Users are recommended to upgrade to version 0.23.0, which fixes the issue.
CVE-2026-47719	8.2	HIGH		0.006		FUXA is a web-based Process Visualization (SCADA/HMI/Dashboard) software. Prior to 1.3.2, the DEVICE_WEBAPI_REQUEST and DEVICE_PROPERTY Socket.IO handlers in server/runtime/index.js omit isSocketWriteAuthorized and accept attacker-controlled property.address or endpoint connection data. A remote unauthenticated attacker can make server/runtime/devices/httprequest/index.js call axios.get against arbitrary HTTP or H...
CVE-2026-53938	8.2	HIGH		0.002		OpenIDC/cjose is a C library implementing the Javascript Object Signing and Encryption (JOSE). Prior to version 0.6.2.5, cjose's JWE decryption path for the AES Key Wrap key-management algorithms (`alg` = `A128KW`, `A192KW`, `A256KW`) does not validate the length of the attacker-supplied `encrypted_key` (JWE Encrypted Key) before unwrapping it into a fixed-size, heap-allocated Content Encryption Key (CEK) buffer. ...
CVE-2026-62673	8.2	HIGH		0.005		Grav is a file-based Web platform. Prior to 2.0.4, the Grav .htaccess and webserver-configs/htaccess.txt security rules omit the Apache [NC] flag and therefore compare sensitive directory and file-extension patterns case-sensitively. On a case-insensitive filesystem, an unauthenticated requester can use uppercase directory or extension variants to bypass the rules and retrieve files under user/accounts or user/con...
CVE-2026-63135	8.2	HIGH		0.003		YOURLS is a self-hosted, customizable URL shortener written in PHP. From 1.5.1 until 1.10.4, YOURLS stores the HTTP Referer header through yourls_get_referrer(), yourls_sanitize_url_safe(), and yourls_log_redirect(), then aggregates the value in yourls-infos.php and passes the derived domain through yourls_get_domain(), yourls_stats_pie(), and yourls_google_array_to_data_table(). The chart builder concatenates lab...
CVE-2026-63376	8.2	HIGH		0.004		toml-node is a TOML parser for Node.js and the browser. Prior to 4.1.2, toml.parse() in lib/compiler.js can be tricked by a table path such as a.b.y.__proto__.__proto__, allowing traversal from a scalar value into Number.prototype and Object.prototype. The currentPath tracking value uses both arrays and strings, so valueAssignments records a comma-joined path such as a.b.y while deepRef checks the dot-joined path ...
CVE-2026-63407	8.2	HIGH		0.003		Grav API Plugin is a RESTful API for Grav CMS that provides full headless access to your site's content. Prior to 1.0.0-rc.16, the Grav API plugin CorsMiddleware returns Access-Control-Allow-Origin: * and permissive OPTIONS responses for authenticated /api/v1 endpoints. JavaScript from any origin can submit an attacker-obtained JWT through the Authorization or X-API-Token header, read the authenticated response, a...
CVE-2026-72958	8.2	HIGH		0.003		Double free in Windows Credential Guard allows an authorized attacker to elevate privileges locally.
CVE-2026-72961	8.2	HIGH		0.003		Out-of-bounds read in Windows Hyper-V allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-72962	8.2	HIGH		0.003		Heap-based buffer overflow in Windows USB Video Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-73214	8.2	HIGH		0.004		Coturn is a free open source implementation of TURN and STUN Server. Prior to 4.16.0, dtls_server_input_handler() and create_new_connected_udp_socket() in src/apps/relay/dtls_listener.c retain OpenSSL dtls1_reassemble_fragment() state for a 35-byte fragmented ClientHello declaring a 650,000-byte handshake before cookie validation, allowing an unauthenticated remote sender using fresh UDP tuples to exhaust memory w...
CVE-2026-84370	8.2	HIGH		0.003		SVGO, short for SVG Optimizer, is a Node.js library and command-line application for optimizing SVG files. From version 1.0.0 until versions 2.8.4, 3.3.5, and 4.1.0, the opt-in removeScripts plugin, named removeScriptElement in versions 2 and 3, incompletely filters executable links in plugins/removeScripts.js and lib/svggo/tools.js. The plugin does not recognize namespace-prefixed SVG anchor elements such as svg:a...
CVE-2026-18147	8.1	HIGH		0.003		A flaw was found in FreeIPA. An unauthenticated remote attacker could exploit a DOM Cross-Site Scripting (XSS) vulnerability in the FreeIPA/IdM Web UI password reset page. By enticing a victim to click a specially crafted link and complete a password reset, the attacker could inject and execute arbitrary JavaScript code. This allows the attacker to perform actions within the victim's authenticated session, potenti...
CVE-2026-33997	8.1	HIGH		0.004	docker:engine	Moby is an open source container framework. Prior to version 29.3.1, a security vulnerability has been detected that allows plugins privilege validation to be bypassed during docker plugin install. Due to an error in the daemon's privilege comparison logic, the daemon may incorrectly accept a privilege set that differs from the one approved by the user. Plugins that request exactly one privilege are also affected,...
CVE-2026-46099	8.1	HIGH		0.003	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: net: ipv6: fix NOREF dst use in seg6 and rpl lwtunnels seg6_input_core() and rpl_input() call ip6_route_input() which sets a NOREF dst on the skb, then pass it to dst_cache_set_ip6() invoking dst_hold() unconditionally. On PREEMPT_RT, ksoftirqd is preemptible and a higher-priority task can release the underlying pcpu_rt between the lookup and th...
CVE-2026-55007	8.1	HIGH		0.007		Double free in Microsoft Exchange Server allows an unauthorized attacker to execute code over a network.
CVE-2026-65181	8.1	HIGH		0.006	apache:impala	Insufficient authorization of Data Source tables in Impala 2.7-4.5 allows a client with privileges to upload a file to remote storage and create a table to execute arbitrary Java code. Users are recommended to upgrade to version 4.5.2, which fixes this issue.
CVE-2026-69380	8.1	HIGH		0.007		Missing authorization in Microsoft Exchange Server allows an authorized attacker to elevate privileges over a network.
CVE-2026-69510	8.1	HIGH		0.007	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Stack-based buffer overflow in Windows DHCP Server allows an unauthorized attacker to execute code over a network.
CVE-2026-69524	8.1	HIGH		0.007		Use after free in Active Directory Domain Services allows an unauthorized attacker to execute code over a network.
CVE-2026-69546	8.1	HIGH		0.007		Use after free in Active Directory Domain Services allows an unauthorized attacker to execute code over a network.
CVE-2026-69732	8.1	HIGH		0.007		Heap-based buffer overflow in Windows Link Layer Topology Discovery Protocol allows an unauthorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69786	8.1	HIGH		0.007		Heap-based buffer overflow in Windows Text Shaping allows an unauthorized attacker to execute code over a network.
CVE-2026-72903	8.1	HIGH		0.004		Tabby (formerly Terminus) is a highly configurable terminal emulator. Prior to 1.0.235, a malicious SFTP server can return a backslash traversal filename through entry.name. In tabby-ssh/src/session/sftp.ts, SFTPSession.readdir() and _makeFile() use POSIX path processing that preserves the backslashes as ordinary filename characters. In tabby-ssh/src/components/sftpPanel.component.ts, downloadFolderRecursive() pro...
CVE-2026-72936	8.1	HIGH		0.006		Use after free in Windows SMB Client allows an unauthorized attacker to execute code over a network.
CVE-2026-73334	8.1	HIGH		0.004	apache:parquet	Potential problem for users of the org.apache.parquet.crypto.keytools package in Apache Parquet, versions 1.12 to 1.18. This package enables users to encrypt Parquet files via an envelope encryption mechanism that wraps (encrypts) data keys via a Key Management Service (KMS). On the reader side, the KMS URL can be application-controlled or file-controlled. If the user does not leverage application control for th...
CVE-2026-81891	8.1	HIGH		0.005		elFinder is an open-source file manager for web, written in JavaScript using jQuery UI. Prior to 2.1.70, checkExtractItems() in php/elFinderVolumeDriver.class.php calls mimeTypeInternalDetect() without passing the result through mimeTypeNormalize(). Because the .html, .phar, .php5, and .php3 extensions are absent from mime.types, the staticMimeMap entries that map them to text/x-php are not applied, and allowPutM...
CVE-2026-84381	8.1	HIGH		0.001		HTTPX2 is a next generation HTTP client for Python. Prior to 2.10.0, httpcore2 fails to start TLS in src/httpcore2/httpcore2/_sync/socks_proxy.py and src/httpcore2/httpcore2/_async/socks_proxy.py when the remote origin uses wss through a SOCKS5 proxy because the TLS upgrade condition only recognizes https. HTTPX2 exposes the flaw through Client.websocket() and AsyncClient.websocket() from 2.6.0 through 2.9.1, so t...
CVE-2026-86242	8.1	HIGH		0.006		Bifrost HTTP transport before 2.0.0 accepts an enabled custom plugin whose path is an HTTP URL through unauthenticated POST /api/plugins when management authentication is disabled (the default, governance.auth_config.is_enabled=false). The shared-object loader treats an http-prefixed path as a download URL, writes the body to a temporary .so, and passes it to Go's plugin.Open. After a successful open, optional Ini...
CVE-2026-87016	8.1	HIGH		0.004	openwebui:open_webui	Open WebUI is an extensible, feature-rich, and user-friendly self-hosted AI platform. From 0.6.41 until 0.11.1, get_user_by_oauth_sub and get_user_by_scim_external_id in backend/open_webui/models/users.py used JSON contains matching that compiled to SQL LIKE substring matching on SQLite. An OAuth subject containing percent or underscore wildcard characters could resolve to a different stored identity, potentially ...
CVE-2026-87457	8.1	HIGH		0.001	google:chrome, microsoft:windows	Race condition in Updater in Google Chrome on on Windows prior to 153.0.8010.36 allowed a local attacker to execute arbitrary code outside the sandbox via a local program. (Chromium security severity: Medium)
CVE-2026-87467	8.1	HIGH		0.001	google:chrome, microsoft:windows	Race condition in Updater in Google Chrome on on Windows prior to 153.0.8010.36 allowed a local attacker to potentially execute arbitrary code outside the sandbox via a local program. (Chromium security severity: High)
CVE-2026-87509	8.1	HIGH		0.001	google:chrome, microsoft:windows	Incorrect authorization in Updater in Google Chrome on on Windows prior to 153.0.8010.36 allowed a local attacker to execute arbitrary code outside the sandbox via a local program. (Chromium security severity: Low)
CVE-2026-87530	8.1	HIGH		0.001	google:chrome, microsoft:windows	Uncontrolled search path element in CredentialProvider in Google Chrome on on Windows prior to 153.0.8010.36 allowed a local attacker to execute arbitrary code outside the sandbox via a local program. (Chromium security severity: Medium)
CVE-2026-87554	8.1	HIGH		0.001	google:chrome, microsoft:windows	Race condition in Chromoting in Google Chrome on on Windows prior to 153.0.8010.36 allowed a local attacker to execute arbitrary code outside the sandbox via a local program. (Chromium security severity: High)

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-87874	8.1	HIGH		0.004		A flaw was found in the memcached cache plugin of the community.general Ansible collection. Although its documentation states that records are stored in JSON format, the plugin performs no explicit serialization and relies on python-memcached, which pickles values on write and unpickles them on read. Because memcached is unauthenticated and cache keys are predictable, an attacker able to reach a network-exposed or...
CVE-2026-52831	8.0	HIGH		0.003		Nuclio is a "Serverless" framework for Real-Time Events and Data Processing. Prior to version 1.16.4, the Nuclio controller builds a curl invocation string for each cron trigger and stores it as the args of a Kubernetes CronJob container (/bin/sh, -c, <command>). Two fields in the trigger specification flow into this string without adequate sanitization: event.headers keys and event.body. This issue has been patch...
CVE-2026-52833	8.0	HIGH		0.003		Nuclio is a "Serverless" framework for Real-Time Events and Data Processing. Prior to version 1.16.5, Nuclio's Java runtime generates a build.gradle file during function builds using Go's text/template package. The template renders runtimeAttributes.repositories[] values with the {{ . }} action, which performs no escaping. An attacker can embed a closing brace }) to break out of the repositories {} block and appe...
CVE-2026-68827	8.0	HIGH		0.004		Integer underflow (wrap or wraparound) in Windows GDI+ allows an authorized attacker to elevate privileges over a network.
CVE-2026-68876	8.0	HIGH		0.007		Heap-based buffer overflow in Windows Program Compatibility Assistant Service allows an authorized attacker to elevate privileges over a network.
CVE-2026-68878	8.0	HIGH		0.005		Stack-based buffer overflow in Windows Fast FAT Driver allows an authorized attacker to elevate privileges over a network.
CVE-2026-68880	8.0	HIGH		0.004		Heap-based buffer overflow in Windows Win32K allows an authorized attacker to elevate privileges over a network.
CVE-2026-68894	8.0	HIGH		0.006		Heap-based buffer overflow in Windows Error Reporting allows an authorized attacker to elevate privileges over a network.
CVE-2026-69301	8.0	HIGH		0.008		Stack-based buffer overflow in Windows Win32K allows an authorized attacker to elevate privileges over a network.
CVE-2026-69346	8.0	HIGH		0.007		Heap-based buffer overflow in Windows Print Spooler Components allows an authorized attacker to elevate privileges over a network.
CVE-2026-69365	8.0	HIGH		0.007		Out-of-bounds read in Microsoft Local Security Authority Server (lsasrv) allows an authorized attacker to elevate privileges over a network.
CVE-2026-69371	8.0	HIGH		0.007		Heap-based buffer overflow in Windows Overlay Filter allows an authorized attacker to elevate privileges over a network.
CVE-2026-69412	8.0	HIGH		0.005	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Stack-based buffer overflow in Windows DHCP Server allows an authorized attacker to execute code over an adjacent network.
CVE-2026-69427	8.0	HIGH		0.007		Out-of-bounds read in Windows VOLSnap.SYS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69458	8.0	HIGH		0.007		Out-of-bounds read in Windows BitLocker allows an authorized attacker to elevate privileges over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69462	8.0	HIGH		0.007		Heap-based buffer overflow in Windows Error Reporting allows an authorized attacker to elevate privileges over a network.
CVE-2026-69512	8.0	HIGH		0.008		Heap-based buffer overflow in Windows Spaceport.sys allows an authorized attacker to elevate privileges over a network.
CVE-2026-69619	8.0	HIGH		0.008		Out-of-bounds read in Windows exFAT File System allows an authorized attacker to elevate privileges over a network.
CVE-2026-69623	8.0	HIGH		0.009		Heap-based buffer overflow in Windows HTTP Print Provider allows an authorized attacker to execute code over a network.
CVE-2026-69625	8.0	HIGH		0.007		Heap-based buffer overflow in Windows Connected User Experiences and Telemetry allows an authorized attacker to elevate privileges over a network.
CVE-2026-69643	8.0	HIGH		0.008		Heap-based buffer overflow in Windows Spaceport.sys allows an authorized attacker to elevate privileges over a network.
CVE-2026-69689	8.0	HIGH		0.008		Out-of-bounds read in Windows Win32K allows an authorized attacker to elevate privileges over a network.
CVE-2026-69714	8.0	HIGH		0.008		Stack-based buffer overflow in Windows Device Association Service allows an authorized attacker to elevate privileges over a network.
CVE-2026-69717	8.0	HIGH		0.007		Untrusted pointer dereference in Windows Group Policy allows an authorized attacker to elevate privileges over a network.
CVE-2026-69762	8.0	HIGH		0.007		Stack-based buffer overflow in Windows Win32K allows an authorized attacker to elevate privileges over a network.
CVE-2026-69807	8.0	HIGH		0.009		Improper limitation of a pathname to a restricted directory ('path traversal') in Windows PowerShell allows an authorized attacker to elevate privileges over a network.
CVE-2026-79755	8.0	HIGH		0.004		Nuclio is a "Serverless" framework for Real-Time Events and Data Processing. Prior to version 1.17.4, on the Nuclio local Docker platform, the function namespace is interpolated—unvalidated—into a double-quoted docker ps --filter "label=nuclio.io/namespace=<value>" command that is executed via the host shell (/bin/sh -c). Because the default auth kind is nop (unauthenticated), a remote attacker can inject arbitrar...
CVE-2026-44629	7.9	HIGH		0.001		Improper access control to the Synergis Softwire installation folder. This vulnerability affects Streamvault all-in-one appliances (SV-100E and SV-300E series) and Synergis Softwire installed on Windows servers.
CVE-2026-17499	7.8	HIGH		0.001	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a local attacker to execute arbitrary commands due to improper neutralization of special elements used in an OS command.
CVE-2026-30512	7.8	HIGH		0.001		A local privilege escalation vulnerability exists in the Restricted Access (Kiosk) Mode implementation of Scheidt & Bachmann entervo HMI prior to V2 R5 P0 M5. The vulnerability affects the external PDF viewer functionality used to display the application manual and its interaction with the underlying Windows operating system. An authenticated low-privileged user can escape the kiosk environment by opening the appl...
CVE-2026-34398	7.8	HIGH		0.002		FreeCAD is a free and open-source multiplatform 3D parametric modeler. From 0.19 until 1.1.1, src/Mod/BIM/bimcommands/BimProjectManager.py in the BIM Project Manager Load Template flow passes attacker-controlled FCStd Meta property values for wpposition, wpu, wpv, and wpaxis directly to eval(), allowing arbitrary Python code execution when a user loads a malicious BIM project template. This issue is fixed in versi...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-34399	7.8	HIGH		0.001		FreeCAD is a free and open-source multiplatform 3D parametric modeler. From 0.19 until 1.1.1, FreeCAD's BIM Workbench contains an eval() call on untrusted data from SVG template files. When a user creates a TechDraw page from a malicious SVG template, arbitrary Python code executes. The vulnerable code is in src/Mod/BIM/bimcommands/BimTDPPage.py (line 87). This issue is fixed in version 1.1.1.
CVE-2026-46145	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: RDMA/mana: Validate rx_hash_key_len Sashiko points out that rx_hash_key_len comes from a uAPI structure and is blindly passed to memcpy, allowing the userspace to trash kernel memory. Bounds check it so the memcpy cannot overflow.
CVE-2026-46189	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: RDMA/vmw_pvrDMA: Fix double free on pvrDMA_alloc_ucontext() error path Sashiko points out that pvrDMA_uar_free() is already called within pvrDMA_dealloc_ucontext(), so calling it before triggers a double free.
CVE-2026-53009	7.8	HIGH		0.001	linux:linux_kernel, redhat:enterprise_linux	In the Linux kernel, the following vulnerability has been resolved: ice: fix double-free of tx_buf skb If ice_tso() or ice_tx_csum() fail, the error path in ice_xmit_frame_ring() frees the skb, but the 'first' tx_buf still points to it and is marked as valid (ICE_TX_BUF_SKB). 'next_to_use' remains unchanged, so the potential problem will likely fix itself when the next packet is transmitted and the tx_buf gets o...
CVE-2026-53185	7.8	HIGH		0.001	linux:linux_kernel	In the Linux kernel, the following vulnerability has been resolved: zram: fix use-after-free in zram_bvec_write_partial() zram_read_page() picks the sync or async backing device read path based on whether the parent bio is NULL. zram_bvec_write_partial() passes its parent bio down, so for ZRAM_WB slots the read is dispatched asynchronously and zram_read_page() returns 0 while the bio is still in flight. The ca...
CVE-2026-54757	7.8	HIGH		0.002		Compliance-trestle (Trestle) is a Python SDK and command-line tool for managing OSCAL compliance documents. In versions before 3.12.4 and versions 4.0.0 through 4.0.3, Trestle is vulnerable to server-side template injection that can lead to remote code execution. This occurs because the MDInclude and MDSectionInclude Jinja2 tags re-parse untrusted Markdown content as template source code using a non-sandboxed...
CVE-2026-55426	7.8	HIGH		0.002		linuxfabrik-lib provides Python modules for database access, caching, shell execution, and API integrations, and Linuxfabrik Monitoring Plugins uses those modules to run external monitoring commands. From the earliest affected releases until linuxfabrik-lib 5.0.0 and Linuxfabrik Monitoring Plugins 6.0.0, check plugins embedded user-controlled values in command strings passed to lib.shell.shell_exec(), which split ...
CVE-2026-56177	7.8	HIGH		0.003		Use after free in Windows Server allows an authorized attacker to elevate privileges locally.
CVE-2026-56198	7.8	HIGH		0.002		Out-of-bounds read in Microsoft Trace Data Helper allows an authorized attacker to elevate privileges locally.
CVE-2026-57170	7.8	HIGH		0.002		Compliance-trestle (Trestle) is a Python SDK and command-line tool for managing OSCAL compliance documents. In versions prior to 3.12.4 and 4.0.0 through 4.0.3, the custom Jinja2 include tags mdsection_include and md_clean_include re-parse the content of an included Markdown file as Jinja2 template code in a non-sandboxed environment, allowing server-side template injection that can lead to arbitrary code executio...
CVE-2026-58599	7.8	HIGH		0.003		Heap-based buffer overflow in Microsoft Windows Codecs Library allows an unauthorized attacker to execute code locally.
CVE-2026-58600	7.8	HIGH		0.003		Heap-based buffer overflow in Microsoft Windows Codecs Library allows an unauthorized attacker to elevate privileges locally.
CVE-2026-62697	7.8	HIGH		0.003		Use after free in Windows Push Notifications allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-62810	7.8	HIGH		0.002		Heap-based buffer overflow in Active Directory Certificate Services (AD CS) allows an authorized attacker to elevate privileges locally.
CVE-2026-68508	7.8	HIGH		0.003		Hydra is a framework for elegantly configuring complex applications. Prior to 1.3.4, hydra.utils.instantiate() resolves and calls Python objects selected by configuration through _resolve_target() in hydra/_internal/instantiate/_instantiate2.py, allowing attacker-controlled target values and arguments to choose dangerous callables. A consuming application, library, CLI workflow, or model loader that passes untrust...
CVE-2026-68845	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Program Compatibility Assistant Service allows an authorized attacker to elevate privileges locally.
CVE-2026-68848	7.8	HIGH		0.002		Heap-based buffer overflow in Windows Print Spooler Components allows an authorized attacker to elevate privileges locally.
CVE-2026-68850	7.8	HIGH		0.002		Heap-based buffer overflow in Microsoft Account allows an authorized attacker to elevate privileges locally.
CVE-2026-68888	7.8	HIGH		0.003		Heap-based buffer overflow in Microsoft Standard XPS allows an authorized attacker to elevate privileges locally.
CVE-2026-68896	7.8	HIGH		0.004		Absolute path traversal in Microsoft Windows Search Component allows an authorized attacker to elevate privileges locally.
CVE-2026-69269	7.8	HIGH		0.003		Integer underflow (wrap or wraparound) in Microsoft Standard XPS allows an authorized attacker to elevate privileges locally.
CVE-2026-69277	7.8	HIGH		0.003		Stack-based buffer overflow in Microsoft Local Security Authority Server (lsasrv) allows an authorized attacker to elevate privileges locally.
CVE-2026-69283	7.8	HIGH		0.002		Heap-based buffer overflow in Windows CD-ROM Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69289	7.8	HIGH		0.004		Improper link resolution before file access ('link following') in Windows Setup Files Cleanup allows an authorized attacker to elevate privileges locally.
CVE-2026-69324	7.8	HIGH		0.003		Access of resource using incompatible type ('type confusion') in Windows Performance Monitor allows an authorized attacker to elevate privileges locally.
CVE-2026-69328	7.8	HIGH		0.003		Untrusted search path in Windows Storage allows an authorized attacker to elevate privileges locally.
CVE-2026-69348	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69359	7.8	HIGH		0.003		Heap-based buffer overflow in Active Directory Domain Services allows an authorized attacker to elevate privileges locally.
CVE-2026-69368	7.8	HIGH		0.002		Heap-based buffer overflow in Windows Overlay Filter allows an authorized attacker to elevate privileges locally.
CVE-2026-69377	7.8	HIGH		0.003		Missing authorization in Windows Modern Device Management (MDM) allows an authorized attacker to elevate privileges locally.
CVE-2026-69389	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Storage Management Provider allows an authorized attacker to elevate privileges locally.
CVE-2026-69392	7.8	HIGH		0.003		Use after free in Windows Shell allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69424	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Distributed File System (DFS) allows an authorized attacker to elevate privileges locally.
CVE-2026-69433	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Error Reporting allows an authorized attacker to elevate privileges locally.
CVE-2026-69436	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Error Reporting allows an authorized attacker to elevate privileges locally.
CVE-2026-69444	7.8	HIGH		0.003		Heap-based buffer overflow in Microsoft Windows Speech allows an authorized attacker to elevate privileges locally.
CVE-2026-69445	7.8	HIGH		0.004		Improper limitation of a pathname to a restricted directory ('path traversal') in Windows Compressed Folder allows an authorized attacker to elevate privileges locally.
CVE-2026-69447	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Audio Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69450	7.8	HIGH		0.003		Out-of-bounds read in Windows Error Reporting allows an authorized attacker to elevate privileges locally.
CVE-2026-69455	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Remote Access Connection Manager allows an authorized attacker to elevate privileges locally.
CVE-2026-69459	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Power Dependency Coordinator allows an authorized attacker to elevate privileges locally.
CVE-2026-69478	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Device Association Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69480	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Partition Management Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69508	7.8	HIGH		0.003		Stack-based buffer overflow in Windows MIDI Service Module allows an authorized attacker to elevate privileges locally.
CVE-2026-69509	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Fax Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69513	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Error Reporting allows an authorized attacker to elevate privileges locally.
CVE-2026-69528	7.8	HIGH		0.003		Missing authentication for critical function in Windows Shell allows an authorized attacker to elevate privileges locally.
CVE-2026-69534	7.8	HIGH		0.006		Improper neutralization of special elements used in a command ('command injection') in Windows Program Compatibility Assistant Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69535	7.8	HIGH		0.002		Numeric truncation error in Windows Spaceport.sys allows an authorized attacker to elevate privileges locally.
CVE-2026-69538	7.8	HIGH		0.002		Out-of-bounds read in Windows Spaceport.sys allows an authorized attacker to execute code locally.
CVE-2026-69542	7.8	HIGH		0.002		Heap-based buffer overflow in Windows Camera Frame Server Monitor allows an authorized attacker to elevate privileges locally.
CVE-2026-69544	7.8	HIGH		0.003		Heap-based buffer overflow in Windows SMB Client allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69561	7.8	HIGH		0.003		Out-of-bounds read in Windows CD-ROM Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69582	7.8	HIGH		0.003		Buffer over-read in Windows Volume Manager Extension Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69592	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Universal Disk Format File System Driver (UDFS) allows an authorized attacker to elevate privileges locally.
CVE-2026-69604	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Audio Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69612	7.8	HIGH		0.004		Absolute path traversal in Windows Error Reporting allows an authorized attacker to elevate privileges locally.
CVE-2026-69685	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Kerberos allows an authorized attacker to elevate privileges locally.
CVE-2026-69691	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Spaceport.sys allows an authorized attacker to elevate privileges locally.
CVE-2026-69720	7.8	HIGH		0.003		Heap-based buffer overflow in Windows MIDI Service Module allows an authorized attacker to elevate privileges locally.
CVE-2026-69725	7.8	HIGH		0.003		Double free in Windows Hello allows an authorized attacker to elevate privileges locally.
CVE-2026-69758	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Universal Disk Format File System Driver (UDFS) allows an authorized attacker to elevate privileges locally.
CVE-2026-69785	7.8	HIGH		0.003		Untrusted search path in Windows Smart Card allows an authorized attacker to elevate privileges locally.
CVE-2026-69790	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Credential Providers allows an authorized attacker to elevate privileges locally.
CVE-2026-69799	7.8	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Hello allows an authorized attacker to elevate privileges locally.
CVE-2026-69801	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Audio Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69821	7.8	HIGH		0.003		Improper encoding or escaping of output in Active Directory Certificate Services (AD CS) allows an authorized attacker to elevate privileges locally.
CVE-2026-70583	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Core Messaging allows an authorized attacker to elevate privileges locally.
CVE-2026-70584	7.8	HIGH		0.003		Access of resource using incompatible type ('type confusion') in Windows Core Messaging allows an authorized attacker to elevate privileges locally.
CVE-2026-71345	7.8	HIGH		0.003		Out-of-bounds write in Windows Spaceport.sys allows an authorized attacker to execute code locally.
CVE-2026-72929	7.8	HIGH		0.002		Improper validation of integrity check value in Windows Installer allows an authorized attacker to elevate privileges locally.
CVE-2026-72944	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Fax Service allows an authorized attacker to elevate privileges locally.
CVE-2026-72953	7.8	HIGH		0.003		Heap-based buffer overflow in Windows USB Driver allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-72957	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Deployment Services allows an authorized attacker to execute code locally.
CVE-2026-72967	7.8	HIGH		0.003		Heap-based buffer overflow in Windows Network Connection Broker allows an authorized attacker to elevate privileges locally.
CVE-2026-73024	7.8	HIGH		0.002		Heap-based buffer overflow in Windows Services for NFS ONCRPC XDR Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-73231	7.8	HIGH		0.002		Faker generates massive amounts of fake data in the browser and Node.js. Prior to 10.5.0, the faker.helpers.fake method in src/modules/helpers/eval.ts allows attacker-controlled fake templates to access the Function constructor through fakeEval.resolveProperty when a function returns another function, enabling arbitrary JavaScript code execution. This issue is fixed in version 10.5.0.
CVE-2026-76967	7.8	HIGH		0.002		SAP NetWeaver Business Client does not perform sufficient validation when processing certain locally stored data during application startup. An attacker with low privileges on the local system could replace this data with specially crafted content. When the application is next launched, the crafted content is processed and could lead to arbitrary code execution in the context of the user. This results in a high im...
CVE-2026-77503	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows NTFS allows an unauthorized attacker to elevate privileges locally.
CVE-2026-78447	7.8	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-81386	7.8	HIGH		0.003	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Heap-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81388	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Stack-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81396	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Stack-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81397	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Heap-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-81398	7.8	HIGH		0.003	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Heap-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81947	7.8	HIGH		0.003	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Heap-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81948	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Heap-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81949	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Integer overflow or wraparound in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81950	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Double free in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81951	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Heap-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81953	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Stack-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81954	7.8	HIGH		0.003	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Use after free in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81956	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81957	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to execute code locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-81959	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Heap-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-81960	7.8	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Heap-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-83975	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83986	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows Biometric Service allows an authorized attacker to elevate privileges locally.
CVE-2026-83995	7.8	HIGH		0.003	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Heap-based buffer overflow in Windows NTFS allows an authorized attacker to elevate privileges locally.
CVE-2026-15140	7.7	HIGH		0.002		A privilege-escalation issue in the Portworx Operator when deployed on Red Hat OpenShift (OCP). Only under specific conditions during the initial provisioning of a Portworx storage cluster, a user holding only limited, namespace-scoped permissions could cause the operator to grant broader access than intended, potentially resulting in elevated privileges within the Kubernetes cluster.
CVE-2026-44293	7.7	HIGH		0.004	protobufjs_project:protobufjs	protobufjs compiles protobuf definitions into JavaScript (JS) functions. Prior to 7.5.6 and 8.0.2, protobufjs generated JavaScript for toObject conversion could include an unsafe expression derived from a schema-controlled bytes field default value. A crafted descriptor with a non-string default value for a bytes field could cause attacker-controlled code to be emitted into the generated conversion function. This ...
CVE-2026-54493	7.7	HIGH		0.003		Koel is a free, open-source music streaming solution. Prior to 9.7.0, the Subsonic-compatible createInternetRadioStation.view and updateInternetRadioStation.view routes accept an authenticated user's streamUrl without the SafeUrl and HasAudioContentType checks used by the regular radio API. app/Http/Requests/Subsonic/CreateInternetRadioStationRequest.php and app/Http/Requests/Subsonic/UpdateInternetRadioStationReq...
CVE-2026-57171	7.7	HIGH		0.002		Compliance-trestle (Trestle) is a Python SDK and command-line tool for managing OSCAL compliance documents. In versions before 3.12.4 and versions 4.0.0 through 4.0.3, the catalog-generate, profile-generate, and ssp-generate author commands write generated Markdown to an attacker-influenced output path without path-traversal validation, allowing arbitrary file write outside the Trestle workspace. These commands jo...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-66738	7.7	HIGH		0.004		SPIP before 4.4.18 contains a code injection vulnerability in SQLite-backed installations. The navigation menu endpoint improperly handles array-typed user input, which bypasses input sanitization and allows the value to break out of an internal quoted string context when evaluated as PHP. An authenticated attacker with at minimum editor (redacteur) privileges can submit a single crafted GET request to /ecrire/?ex...
CVE-2026-66767	7.7	HIGH		0.003		SAP NetWeaver Application Server for ABAP and ABAP Platform allows an unauthenticated user to send a specially crafted packet that triggers reprocessing of a previously buffered user request, potentially hijacking another user's session under narrow timing conditions. Successful exploitation could result in high impact on confidentiality and integrity, with low impact on availability of the application.
CVE-2026-69683	7.7	HIGH		0.008	microsoft:sharepoint_server	Server-side request forgery (ssrf) in Microsoft Office SharePoint allows an authorized attacker to disclose information over a network.
CVE-2026-73217	7.7	HIGH		0.003		Cursor is a code editor built for programming with AI. Prior to 3.1.2, Cursor IDE for macOS allows an agent running in Auto-Run Sandbox mode to replace a virtual environment's Python executable with a malicious wrapper that the Microsoft Python extension invokes outside the sandbox, allowing arbitrary host commands with the user's privileges, including modifying files outside the workspace and launching applicatio...
CVE-2026-73218	7.7	HIGH		0.008		Cursor is a code editor built for programming with AI. Prior to 3.0.0, Cursor IDE for macOS allows an agent running in Auto-Run Sandbox mode, when Docker Desktop and the Dev Containers CLI are installed, to launch a privileged container and mount Docker's virtiofs0, granting read and write access to the user's home directory and enabling host command execution with the user's privileges without an additional permi...
CVE-2026-77775	7.7	HIGH		0.004		Headroom's LLM proxy lets a client choose the upstream destination with the x-headroom-base-url request header. _resolve_openai_upstream_base in headroom/proxy/handlers/openai.py accepts the header value, requires only that it parse with an http or https scheme and a hostname, and returns it for use as the upstream base; _select_passthrough_base_url in headroom/providers/proxy_routes.py reads the same header for t...
CVE-2026-87996	7.7	HIGH		0.002	openwebui:open_webui	Open WebUI is an extensible, feature-rich, and user-friendly self-hosted AI platform. From 0.9.6 until 0.11.1, SafePlaywrightURLLoader in backend/open_webui/retrieval/web/utlis.py validated a user-controlled hostname in Python and then let the Playwright browser resolve it again in the sync and async request interceptors. An authenticated user controlling authoritative DNS could return a public address to validati...
CVE-2026-47666	7.6	HIGH		0.002		Penpot is an open-source design and prototyping platform. In versions up to and including 2.14.3, Penpot is vulnerable to stored cross-site scripting through custom font family names, which are interpolated into a @font-face CSS rule and injected into the page as HTML without sanitization. Because the backend accepts an arbitrary font-family string and the frontend writes the resulting style through innerHTML, a n...
CVE-2026-53958	7.6	HIGH		0.004		4gaBoards is a boards system for realtime project management. Prior to 3.3.9, 4gaBoards allows an authenticated user to modify ssoGoogleId, ssoGoogleEmail, ssoGithubId, ssoGithubUsername, ssoGithubEmail, ssoMicrosoftId, ssoMicrosoftEmail, ssoOidcId, and ssoOidcEmail through PATCH /api/users/:id. The whitelist in server/api/controllers/users/update.js mass assigns these backend-managed identity attributes from user...
CVE-2026-54245	7.6	HIGH		0.003		Fleet is an open-source device management platform built on osquery. In versions prior to 4.86.2, the Okta conditional access integration in Fleet Premium is vulnerable to SQL injection through a host-supplied value that is used in a database query without proper parameterization, allowing an attacker who controls a single enrolled host to read or modify arbitrary data in the Fleet database. The value is reported ...
CVE-2026-73083	7.6	HIGH		0.002		Activepieces is an open source AI workflow automation platform. Prior to 0.80.0, in SANDBOX_CODE_ONLY mode, the engine loads the compiled user module with importFresh(), a wrapper around Node.js require(), before the V8 isolate is applied. Top-level module code can therefore call require('child_process'), access fs, and use other Node.js APIs in the host engine process outside the sandbox. An authenticated user wh...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2025-69223	7.5	HIGH		0.006	aiohttp:aiohttp	AIOHTTP is an asynchronous HTTP client/server framework for asyncio and Python. Versions 3.13.2 and below allow a zip bomb to be used to execute a DoS against the AIOHTTP server. An attacker may be able to send a compressed request that when decompressed by AIOHTTP could exhaust the host's memory. This issue is fixed in version 3.13.3.
CVE-2026-17470	7.5	HIGH		0.004	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote attacker to cause a denial of service due to a buffer overflow.
CVE-2026-23490	7.5	HIGH		0.008	debian:debian_linux, pyasn1:pyasn1	pyasn1 is a generic ASN.1 library for Python. Prior to 0.6.2, a Denial-of-Service issue has been found that leads to memory exhaustion from malformed RELATIVE-OID with excessive continuation octets. This vulnerability is fixed in 0.6.2.
CVE-2026-33231	7.5	HIGH		0.012	nlTK:nlTK	NLTK (Natural Language Toolkit) is a suite of open source Python modules, data sets, and tutorials supporting research and development in Natural Language Processing. In versions 3.9.3 and prior, `nlTK.app.wordnet_app` allows unauthenticated remote shutdown of the local WordNet Browser HTTP server when it is started in its default mode. A simple `GET /SHUTDOWN%20THE%20SERVER` request causes the process to terminat...
CVE-2026-35172	7.5	HIGH		0.005	distribution:distribution	Distribution is a toolkit to pack, ship, store, and deliver container content. Prior to 3.1.0, distribution can restore read access in repo a after an explicit delete when storage.cache.blobdescriptor: redis and storage.delete.enabled: true are both enabled. The delete path clears the shared digest descriptor but leaves stale repo-scoped membership behind, so a later Stat or Get from repo b repopulates the shared ...
CVE-2026-41602	7.5	HIGH		0.012	apache:thrift	Integer Overflow or Wraparound vulnerability in Apache Thrift TFramedTransport Go language implementation This issue affects Apache Thrift: before 0.23.0. Users are recommended to upgrade to version 0.23.0, which fixes the issue.
CVE-2026-43003	7.5	HIGH		0.01	openstack:ironic_python_agent	An issue was discovered in OpenStack ironic-python-agent 1.0.0 through 11.5.0. Ironic Python Agent (IPA) sometimes executes grub-install from within a chroot of the deployed partition image, leading to code execution in the case of a malicious image.
CVE-2026-44250	7.5	HIGH		0.005	netty:netty	Netty is a network application framework for development of protocol servers and clients. In netty-codec-redis prior to versions 4.1.135.Final and 4.2.15.Final, an attacker can cause DoS by sending a crafted Redis payload with deeply nested arrays. This forces the server to allocate a massive number of state objects and collections, leading to memory exhaustion and an OutOfMemoryError. Versions 4.1.135.Final and 4...
CVE-2026-44890	7.5	HIGH		0.005	netty:netty	Netty is a network application framework for development of protocol servers and clients. In netty-codec-redis prior to versions 4.1.135.Final and 4.2.15.Final, an attacker can cause DoS by sending crafted Redis payloads across multiple connections without `\\n`. This exhausts the server's direct memory pool (OutOfDirectMemoryError), preventing legitimate connections from being processed. Versions 4.1.135.Final a...
CVE-2026-45741	7.5	HIGH		0.008		Gotenberg is a Docker-powered stateless API for PDF files. In 8.32.0 and earlier, the IsPublicIP function in pkg/gotenberg/outbound.go does not reject the 2002::/16 6to4 prefix, the 64:ff9b::/96 and 64:ff9b:1::/48 NAT64 prefixes, the fec0::/10 deprecated site-local prefix, Teredo, and other transition prefixes that can embed or route to non-public IPv4 destinations. The addr.Unmap operation only handles IPv4-mappe...
CVE-2026-45742	7.5	HIGH		0.006		Gotenberg is a Docker-powered stateless API for PDF files. From 8.10.0 until 8.33.0, the newContext function in pkg/modules/api/context.go starts one errgroup.Go goroutine for each multipart downloadFrom entry and allows those goroutines to concurrently write to the shared ctx.files, ctx.diskToOriginal, and ctx.filesByField maps and slices. Go maps and slices are not safe for concurrent mutation, so a crafted mult...
CVE-2026-46625	7.5	HIGH		0.009	js-cookie:javascript_cookie, redhat:3scale_api_management, redhat:ansible_automation_platform, redhat:enterprise_linux,	JavaScript Cookie is a JavaScript API for handling cookies, client-side. Prior to version 3.0.7, js-cookie's internal assign() helper copies properties with for...in + plain assignment. When the source object is produced by JSON.parse, the JSON object's "__proto__" member is an own enumerable property, so the for...in enumerates it and the target[key] = source[key] write triggers the Object.prototype.__proto__ sette...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-50011	7.5	HIGH		0.005	netty:netty	Netty is a network application framework for development of protocol servers and clients. Prior to versions 4.1.135.Final and 4.2.15.Final, RedisArrayAggregator pre-allocates ArrayList with initial capacity equal to the RESP array element count declared in an array header. That count is taken from the wire before the corresponding child messages exist. A small malicious header can claim a huge initial capacity. Ve...
CVE-2026-52880	7.5	HIGH		0.003		Klever-Go is the Go implementation of the Klever blockchain protocol. Versions from 1.7.14 through 1.7.17 are vulnerable to a remotely triggerable denial of service. Both REST APIs are started with the Gin Engine.Run convenience method, which serves requests through Go's default HTTP server with no ReadHeaderTimeout, ReadTimeout, or MaxHeaderBytes configured. As a result, incoming connections that never complete t...
CVE-2026-54293	7.5	HIGH		0.006	nlk:nltk	NLTK (Natural Language Toolkit) is a suite of open source Python modules, data sets, and tutorials supporting research and development in Natural Language Processing. Prior to 3.10.0-rc1, nltk.data.load() in NLTK is vulnerable to path traversal via URL-encoded path separators and traversal segments when using the nltk: URL scheme. The unsafe-path regex check is performed before url2pathname() decodes the %xx seque...
CVE-2026-55099	7.5	HIGH		0.004		icalendar is an RFC 5545 compatible parser and generator of iCalendar files for Python. From 7.1.0 until 7.1.3, the Component equality method in src/icalendar/cal/component.py compares nested subcomponents with two membership loops, and each membership test invokes the same method on child components, causing O(2^n) work relative to nesting depth. Component.from_ical accepts arbitrarily nested BEGIN:VEVENT blocks ...
CVE-2026-55553	7.5	HIGH		0.004		urllib is an HTTP client for Node.js that supports authentication, redirects, timeouts, and other request features. Prior to 4.9.1 and 2.44.1, urllib follows redirects through followRedirect but reuses caller-supplied options across origins. In src/HttpClient.ts, #requestInternal recursively calls this.#requestInternal(nextUrl.href, options, requestContext), causing options.headers and auth or digestAuth values to...
CVE-2026-55620	7.5	HIGH		0.004		eml_parser serves as a python module for parsing eml files and returning various information found in the e-mail as well as computed information. Prior to 3.0.2, eml_parser.routing.noparenthesis in eml_parser/routing.py removes parenthesized CFWS comments from Received: headers with a regex-based fix-point loop whose running time is quadratic in the nesting depth. A single Received: header with 5,000 nested parent...
CVE-2026-55841	7.5	HIGH		0.004		Graylog is a free and open log management platform. Prior to Graylog Server versions 6.3.12, 7.0.7, and 7.1.2 and Graylog Forwarder version 7.3, the FortiGate key-value syslog parser in graylog2-server/src/main/java/org/graylog2/inputs/codecs/GLFortiGateSyslogEvent.java and graylog2-server/src/main/java/org/graylog2/inputs/codecs/SyslogCodec.java mishandles field-like text inside quoted values. GLFortiGateSyslogEv...
CVE-2026-62295	7.5	HIGH		0.003		HAPI FHIR is a complete implementation of the HL7 FHIR standard for healthcare interoperability in Java. Prior to 6.9.11, the JSON utility parser in org.hl7.fhir.utilities.json.parser.JsonParser enforces no maximum nesting depth for arrays or objects. As a result, a small but deeply nested, syntactically valid FHIR JSON document can trigger unbounded readArray() or readObject() recursion, raising a StackOverflowEr...
CVE-2026-62296	7.5	HIGH		0.003		HAPI FHIR is a complete implementation of the HL7 FHIR standard for healthcare interoperability in Java. Prior to 6.9.11, XhtmlParser.java imposes no maximum element nesting depth, so a deeply nested text.div narrative triggers unbounded recursion between parseElementInner() and parseElement(), raising a StackOverflowError. An attacker who can submit FHIR resources containing such narratives can thus crash a parsi...
CVE-2026-62759	7.5	HIGH		0.003		Authentication bypass by spoofing in Windows Netlogon allows an unauthorized attacker to perform spoofing over an adjacent network.
CVE-2026-62813	7.5	HIGH		0.006		Use after free in Active Directory Domain Services allows an authorized attacker to execute code over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-63408	7.5	HIGH		0.004		Grav API Plugin is a RESTful API for Grav CMS that provides full headless access to your site's content. Prior to 1.0.0-rc.16, the Grav API plugin JwtAuthenticator::extractBearerToken() accepts a JWT from the token URL query parameter on every /api/v1 route, including state-changing endpoints. Request URLs consequently expose valid access tokens through Apache, proxy, and CDN logs, browser history, and Referer he...
CVE-2026-63421	7.5	HIGH		0.005		Keystone is a content management system for Node.js. Prior to 6.5.3, the findMany resolver in packages/core/src/lib/core/queries/resolvers.ts compares the signed take argument directly with graphql.maxTake, allowing a remote unauthenticated GraphQL client to provide a negative take value whose magnitude exceeds the configured bound. The bypass also applies to relationship queries and can return more records than t...
CVE-2026-66373	7.5	HIGH		0.006		Redis before 8.8.0, in the unusual case where an authenticated attacker can execute RESTORE, allows remote code execution via a RESTORE payload where the same NACK (pending entry) is referenced by more than one consumer, because deleting both consumers via XGROUP DELCONSUMER leads to a double free. NOTE: this issue exists because of an incomplete fix for CVE-2026-25243.
CVE-2026-69222	7.5	HIGH		0.004		LiquidJS is a Shopify / GitHub Pages compatible template engine in pure JavaScript. Prior to 10.27.2, the join filter in src/filters/array.ts computes complexity from array.length and separator length instead of the total string length produced by array.join(sep). The concat filter can cheaply double arrays of references, after which join materializes the referenced content while charging only for element count, a...
CVE-2026-69342	7.5	HIGH		0.011	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an unauthorized attacker to deny service over a network.
CVE-2026-69397	7.5	HIGH		0.006		Use after free in OpenSSH for Windows allows an unauthorized attacker to execute code over a network.
CVE-2026-69429	7.5	HIGH		0.006		Heap-based buffer overflow in Windows IKE Extension allows an authorized attacker to execute code over a network.
CVE-2026-69607	7.5	HIGH		0.006		Use after free in Windows Deployment Services allows an unauthorized attacker to execute code over a network.
CVE-2026-69710	7.5	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Hello allows an authorized attacker to elevate privileges locally.
CVE-2026-69739	7.5	HIGH		0.009	microsoft:365_apps, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Out-of-bounds read in Microsoft Office allows an unauthorized attacker to disclose information over a network.
CVE-2026-69793	7.5	HIGH		0.008		Improper validation of consistency within input in Windows TCP/IP allows an unauthorized attacker to bypass a security feature over a network.
CVE-2026-69804	7.5	HIGH		0.005	microsoft:sharepoint_server	Time-of-check time-of-use (toctou) race condition in Microsoft Office SharePoint allows an authorized attacker to execute code over a network.
CVE-2026-69805	7.5	HIGH		0.005		External control of file name or path in .NET allows an unauthorized attacker to elevate privileges over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-70570	7.5	HIGH		0.004		Remote Code Execution in Windows Routing and Remote Access Service (RRAS) allows attacker to gain an unauthorized access to victim's machine
CVE-2026-72943	7.5	HIGH		0.006		Use after free in Windows Deployment Services allows an authorized attacker to execute code over a network.
CVE-2026-72954	7.5	HIGH		0.006		Use after free in Windows Deployment Services allows an authorized attacker to execute code over a network.
CVE-2026-73088	7.5	HIGH		0.004		Browserslist is a configuration tool for sharing target browsers and Node.js versions between front-end tools. Prior to 4.28.7, normalizeStats() in node.js, reached unconditionally through getStat() and loadStat() on every browserslist() call, processes untrusted browserslist-stats.json, opts.stats, and CLI --stats data with an unguarded for...in loop and plain-object bracket access and assignment, allowing inheri...
CVE-2026-73089	7.5	HIGH		0.005		Browserslist is a configuration tool for sharing target browsers and Node.js versions between front-end tools. Prior to 4.28.7, index.js retains every distinct `(queries, context)` result in cache and every parseQueries() AST in parseCache without a size cap, TTL, or eviction, allowing an attacker who can influence repeated browserslist() query values, including valid since ` <year><-<month>-<day>` queries, to bypas...</year>
CVE-2026-73246	7.5	HIGH		0.004		Kestra is an open-source, event-driven orchestration platform. Prior to 2.0.0-rc6, Kestra's worker/src/main/java/io/kestra/worker/endpoint/WorkerEndpoint.java serves GET /worker without authentication and serializes the complete live Task object, which can expose commands, environment variables, HTTP headers, connection details, plaintext credentials, and execution identifiers while the main API on port 8080 remai...
CVE-2026-73507	7.5	HIGH		0.005		Netty is an asynchronous, event-driven network application framework. Prior to 4.1.136.Final and 4.2.16.Final, io.netty.handler.codec.xml.XmlFrameDecoder.decode() failed to preserve closing-tag parser state across invocations, so an unauthenticated remote attacker could trickle-feed repeated </ sequences that repeatedly rescanned the accumulated buffer and exhausted an EventLoop thread's CPU, causing denial of ser...
CVE-2026-74761	7.5	HIGH		0.004		Improper input validation in TopicRegion in Apache ActiveMQ, Apache ActiveMQ Broker, and Apache ActiveMQ All on all platforms. An authenticated client can spoof clientId when removing a durable topic subscription. This issue affects Apache ActiveMQ Broker: before 5.19.11, from 6.0.0 before 6.3.2; Apache ActiveMQ All: before 5.19.11, from 6.0.0 before 6.3.2; Apache ActiveMQ: before 5.19.11, from 6.0.0 before...
CVE-2026-75328	7.5	HIGH		0.003		In DocSys-master V2.02.85, the downloadDocEx interface in src/com/DocSystem/controller/DocController.java has an arbitrary file read vulnerability:
CVE-2026-76098	7.5	HIGH		0.003		Mistune is a Python Markdown parser with renderers and plugins. Versions 3.3.0 through 3.3.2 are vulnerable to DoS through deeply nested tokens. HTML rendering creates deeply nested emphasis tokens from consecutive asterisk characters, and recursive rendering in HTMLRenderer.render_token() can exceed Python's recursion limit and raise RecursionError, allowing crafted Markdown to crash a parsing process. This issue...
CVE-2026-77384	7.5	HIGH		0.003		libp2p is a JavaScript implementation of the libp2p networking stack. Prior to version 4.2.9, the reservation refresh path in reservation-store.ts reuses the same retimeableSignal but unconditionally registers another abort listener on every refresh. As a result, a remote peer can repeatedly send valid RESERVE requests for the same reservation, causing unbounded listener and closure growth in @libp2p/circuit-relay...
CVE-2026-77438	7.5	HIGH		0.002		Trilium is an open-source hierarchical note-taking application. In versions up to and including 0.103.0, the public share-search endpoint does not enforce the per-note shareCredentials and shareHiddenFromTree controls, allowing an unauthenticated visitor to read the titles, tree paths, and content of protected shared notes. The endpoint authorizes only the ancestor note supplied in the request and then runs a full...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-77465	7.5	HIGH		0.004		toml-node is a TOML parser for Node.js and the browser. Prior to 4.2.0, toml.parse() uses a Peggy 5.1.0 generated recursive-descent parser in lib/parser.js whose peg\$parsevalue, peg\$parsearray, and peg\$parseinline_table_entry functions recurse through nested arrays and inline tables without a depth limit. A remote unauthenticated application parsing an attacker-controlled TOML document containing a few thousand ne...
CVE-2026-77898	7.5	HIGH		0.005	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Heap-based buffer overflow in Microsoft Office allows an unauthorized attacker to execute code over a network.
CVE-2026-78543	7.5	HIGH		0.004	ibm:app_connect_enterprise, ibm:integration_bus_for_zVos	IBM App Connect Enterprise 13.0.1.0 through 13.0.8.1, and 12.0.1.0 through 12.0.12.28 and IBM Integration Bus for z/OS 10.1.0.0 through 10.1.0.7 could allow a remote attacker to cause a denial of service due to an infinite loop.
CVE-2026-80924	7.5	HIGH		0.002		In the Linux kernel, the following vulnerability has been resolved: crypto: krb5 - use kfree_sensitive() for derived key buffers crypto_krb5_prepare_encryption() and crypto_krb5_prepare_checksum() free the buffer holding the freshly derived keys with plain kfree(), leaving the key material behind in the freed slab object.
CVE-2026-82397	7.5	HIGH		0.004		Tornado is a Python web framework and asynchronous networking library. Prior to 6.5.8, Tornado parses application/x-www-form-urlencoded request bodies with urllib.parse.parse_qs in tornado/escape.py without passing max_num_fields. RequestHandler._execute in tornado/web.py parses the body before handler dispatch through HTTPServerRequest._parse_body and parse_body_arguments in tornado/httputil.py, so an unauthentic...
CVE-2026-83989	7.5	HIGH		0.009	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows Services for NFS ONCRPC XDR Driver allows an unauthorized attacker to deny service over a network.
CVE-2026-84001	7.5	HIGH		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Out-of-bounds read in Windows Key Distribution Center allows an unauthorized attacker to deny service over a network.
CVE-2026-84375	7.5	HIGH		0.004		js-yaml is a JavaScript YAML parser and dumper. From 3.0.0 until 3.15.2 and 4.3.2, maxTotalMergeKeys in lib/js-yaml/loader.js and lib/loader.js does not count empty mapping sources while processing the merge key <<. An attacker can alias a large sequence of empty mappings into many merge targets, causing O(N * K) processing while totalMergeKeys remains unchanged and the configured resource limit is never reached. ...
CVE-2026-84382	7.5	HIGH		0.004		HTTPX2 is a next generation HTTP client for Python. Prior to 2.12.0, the HTTPX2 content decoders in src/httpx2/httpx2/_decoders.py fully inflate each gzip, deflate, br, or zstd network chunk before iter_bytes() or aiter_bytes() yields bounded pieces to the application. A 64 KiB compressed chunk can expand to approximately 64 MiB in one intermediate allocation, so an attacker-controlled or compromised server can ca...
CVE-2026-19651	7.4	HIGH		0.003		IBM Enterprise Build of Quarkus 3.27.1 through 3.27.5, and 3.33.1 through 3.33.3 could allow an attacker to bypass authorization by manipulating URL query parameters due to incorrect mapping of values to untrusted query string input.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-54550	7.4	HIGH		0.004		IzPack is a widely used tool for packaging applications on the Java platform as cross-platform installers. In 5.2.6 and earlier, UnpackerBase.unpack() in izpack-installer/src/main/java/com/izforge/izpack/installer/unpacker/UnpackerBase.java obtains an attacker-controlled PackFile targetPath, passes it through IoHelper.translatePath(), which only converts separators, and constructs a File without normalizing parent...
CVE-2026-69347	7.4	HIGH		0.003		Heap-based buffer overflow in Windows Fast FAT Driver allows an unauthorized attacker to execute code locally.
CVE-2026-73086	7.4	HIGH		0.003		nanoid is a secure, URL-friendly, unique string ID generator for JavaScript. Prior to versions 3.3.12 and 5.1.11, the nanoid(size) function in index.js and index.cjs coerces the user-influenced size parameter to a signed 32-bit integer, allowing a value of 2147483648 to become -2147483648 and corrupt the process-wide CSPRNG poolOffset in fillPool(), which causes subsequent session tokens, CSRF tokens, API keys, an...
CVE-2026-78254	7.4	HIGH		0.005	apache:ant	The ftp and scp tasks of Apache Ant can download files from a remote server. A malicious server can provide relative paths that allow it to write outside of the dedicated target directory for the download, making it possible to overwrite files of the attacker's choice using the permissions of the user running Ant in versions prior to Ant 1.10.18. In order to exploit this vulnerability, the server would either...
CVE-2026-84366	7.4	HIGH		0.002		Scrapy is a high-level web crawling and scraping framework for Python. Prior to 2.17.0, in scrapy/core/downloader/handlers/s3.py, Scrapy's S3DownloadHandler converts an S3-scheme bucket and key request into a plaintext HTTP request to the corresponding S3 endpoint unless request.meta["is_secure"] is explicitly enabled, then signs and sends the plaintext request with configured AWS credentials. A network attacker w...
CVE-2026-87812	7.4	HIGH		0.002		SiYuan before v3.8.2 contains a stored cross-site scripting vulnerability in Bazaar package cards where the iconURL metadata is inserted directly into HTML img src attributes without escaping. Attackers can inject malicious URLs with event handlers that execute JavaScript in the authenticated SiYuan origin when users view Bazaar listings, enabling API requests and application state manipulation.
CVE-2026-40542	7.3	HIGH		0.006	apache:httpClient	Missing critical step in authentication in Apache HttpClient 5.6 allows an attacker to cause the client to accept SCRAM-SHA-256 authentication without proper mutual authentication verification. Users are recommended to upgrade to version 5.6.1, which fixes this issue.
CVE-2026-41605	7.3	HIGH		0.009	apache:thrift	Integer Overflow or Wraparound vulnerability in Apache Thrift. This issue affects Apache Thrift: before 0.23.0. Users are recommended to upgrade to version 0.23.0, which fixes the issue.
CVE-2026-43869	7.3	HIGH		0.006	apache:thrift	Improper Validation of Certificate with Host Mismatch vulnerability in Apache Thrift. This issue affects Apache Thrift: before 0.23.0. Users are recommended to upgrade to version 0.23.0, which fixes the issue.
CVE-2026-63404	7.3	HIGH		0.002		Faktory is a language-agnostic background job server. In versions prior to 1.10.0, the embedded Redis bootstrapper is vulnerable to an insecure temporary file flaw that lets a local unprivileged user hijack the Redis configuration and escalate to root. It writes its startup configuration to a fixed, predictable, world-writable path, /tmp/redis.conf, only creating the file if it does not already exist and never val...
CVE-2026-41567	7.2	HIGH		0.002		Moby is an open source container framework. In versions prior to 29.5.1 and in moby/moby v2 prior to v2.0.0-beta.14, when a compressed archive is uploaded to a container via `PUT /containers/{id}/archive` or piped through `docker cp`, the daemon resolves decompression binaries (such as `xz` or `unpigz`) from the container's filesystem rather than the host's due to incorrect ordering of operations. A malicious co...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-45019	7.2	HIGH		0.003		Chainlit is a Python framework for building production-ready conversational AI applications. From 2.4.0rc0 until 2.12.0, Chainlit deployments with features.mcp.enabled set to true in .chainlit/config.toml expose the POST /mcp endpoint without requiring authentication. For sse and streamable-http transports, ConnectSseMCPRequest and ConnectStreamableHttpMCPRequest in backend/chainlit/types.py accept a user-controll...
CVE-2026-73624	7.2	HIGH		0.003		GitPython versions before 3.1.54 contain an arbitrary file overwrite vulnerability in the Diffable.diff method that fails to validate git options passed through kwargs. Attackers can supply the --output argument via the other parameter or output kwarg to write patch content to attacker-chosen file paths at process privilege level.
CVE-2026-81349	7.2	HIGH		0.007		Improper neutralization of special elements used in an os command ('os command injection') in Azure HDInsights allows an authorized attacker to elevate privileges over a network.
CVE-2026-17627	7.1	HIGH		0.002	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.10.2 could allow a remote authenticated attacker to obtain sensitive information and inject messages into workflow history due to improper authorization.
CVE-2026-18737	7.1	HIGH		0.003		Shlink contains a blind SQL injection vulnerability that allows any authenticated API key holder to inject arbitrary SQL fragments by supplying an unvalidated direction value in the orderBy query parameter of the tag statistics endpoint. Attackers can craft a malicious direction string containing SQL subqueries that flows unsanitized into a Doctrine QueryBuilder ORDER BY clause, enabling time-based, boolean-oracle...
CVE-2026-48494	7.1	HIGH		0.004		TypeBot is a chatbot builder tool. In version 3.16.1, an authenticated user who has read access to any typebot can resume a WhatsApp preview webhook session that belongs to a different typebot by mixing an authorized `typebotId` and `blockId` and a foreign preview phone number tied to another preview session. The WhatsApp test-webhook handler authorizes the parent typebot first, but then resolves the preview chat ...
CVE-2026-55520	7.1	HIGH		0.004		Protego is a pure-Python robots.txt parser with support for modern conventions. Prior to 0.6.2, protego._urlpattern._URLPattern._prepare_pattern_for_regex translates every asterisk in an Allow or Disallow directive into a lazy regular-expression wildcard, so a directive containing many asterisks creates exponential backtracking. After protego.Protego.parse processes a crafted robots.txt file, protego.Protego.can_f...
CVE-2026-55673	7.1	HIGH		0.004		PowSyBI (Power System Blocks) is a framework to build power system oriented software. Prior to 7.2.2, UnixLocalCommandExecutor and WindowsLocalCommandExecutor concatenate command arguments and environment variables into strings interpreted through bash -c or cmd /c without sufficient escaping. Attacker-controlled values reaching UnixLocalCommandExecutor.execute, WindowsLocalCommandExecutor.execute, LocalComputatio...
CVE-2026-62680	7.1	HIGH		0.003		Orval generates type-safe JavaScript clients in TypeScript from OpenAPI v3 and Swagger v2 specifications. Prior to 8.22.0, Orval resolves remote and local external \$ref values without an allowlist or confinement to the input directory. Processing an attacker-controlled OpenAPI description can cause requests from the developer or CI host to attacker-selected or internal HTTP services, read absolute or out-of-tree l...
CVE-2026-63177	7.1	HIGH		0.002		Malcolm is a network traffic analysis tool suite. Prior to version 26.07.0, role-based access control enforced in the Nginx OpenResty Lua layer evaluates the raw, unnormalized `ngx.var.request_uri`, while Nginx itself routes requests using the normalized path. An authenticated low-privilege user can prepend a traversal segment (for example `/x/./upload/...`) so that Nginx routes the request to a restricted backen...
CVE-2026-64816	7.1	HIGH		0.003		RapidRAW before 1.6.0 does not validate the lutPath field in preset files before passing it to File::open() in lut_processing.rs. On Windows, a UNC path in lutPath causes an outbound SMB connection to an attacker-controlled host, leaking the victim's NTLMv2 credentials. The vulnerable code path is reachable through two vectors: community presets fetched automatically from the remote preset repository when the vict...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-66003	7.1	HIGH		0.003		Frappe is a full-stack web application framework written in Python and JavaScript. Prior to version 15.115.0, an access control bypass in the REST API allows a user to read data from Linked DocTypes that they are not authorized to access. When a document references another document through a Link field, the framework does not consistently enforce the linked DocType's own permissions when the record is retrieved th...
CVE-2026-68553	7.1	HIGH		0.003		Coturn is a free open source implementation of TURN and STUN Server. Prior to 4.13.0, an authenticated TURN user can place printf-style format specifiers in the STUN USERNAME or REALM attribute, which passes is_secure_string() validation and is embedded into Redis keys at nine call sites in src/apps/relay/ns_ioalib_engine_impl.c. send_message_to_redis() in src/apps/relay/hiredis_libevent2.c then passes the attacke...
CVE-2026-68835	7.1	HIGH		0.005		Use after free in Windows Print Spooler Components allows an authorized attacker to elevate privileges over a network.
CVE-2026-69272	7.1	HIGH		0.004		Heap-based buffer overflow in Microsoft Standard XPS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69274	7.1	HIGH		0.004		Use after free in Windows Win32K allows an authorized attacker to elevate privileges over a network.
CVE-2026-69314	7.1	HIGH		0.005		Use after free in Windows Device Association Broker service allows an authorized attacker to elevate privileges over a network.
CVE-2026-69336	7.1	HIGH		0.005		Heap-based buffer overflow in Microsoft Standard XPS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69337	7.1	HIGH		0.007		Double free in Windows Registry allows an authorized attacker to elevate privileges over a network.
CVE-2026-69357	7.1	HIGH		0.004		Use after free in Windows NDIS allows an authorized attacker to elevate privileges over a network.
CVE-2026-69364	7.1	HIGH		0.005		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Print Spooler Components allows an authorized attacker to elevate privileges over a network.
CVE-2026-69451	7.1	HIGH		0.007		Use after free in Windows Management Instrumentation allows an authorized attacker to elevate privileges over a network.
CVE-2026-69553	7.1	HIGH		0.005		Missing authorization in Windows Hyper-V allows an authorized attacker to elevate privileges over a network.
CVE-2026-69597	7.1	HIGH		0.006		Use after free in Windows HTTP.sys allows an authorized attacker to elevate privileges over a network.
CVE-2026-69602	7.1	HIGH		0.006		Use after free in Windows PrintWorkflowUserSvc allows an authorized attacker to elevate privileges over a network.
CVE-2026-69706	7.1	HIGH		0.004		Use after free in Windows Win32K allows an authorized attacker to elevate privileges over a network.
CVE-2026-69757	7.1	HIGH		0.007		Use after free in Windows TCP/IP allows an authorized attacker to elevate privileges over a network.
CVE-2026-69761	7.1	HIGH		0.005		Use after free in Windows TCP/IP allows an authorized attacker to elevate privileges over a network.
CVE-2026-71553	7.1	HIGH		0.003		ApostropheCMS is an open-source Node.js content management system. In 4.32.0 and earlier, PATCH /api/v1/article/:id accepts the inherited path toString.call and passes it through the utility module to apos.util.set() and apos.util.get(), allowing an authenticated editor to overwrite the shared Object.prototype.toString function's call property and cause a persistent process-wide denial of service until restart.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-79754	7.1	HIGH		0.004		Nuclio is a "Serverless" framework for Real-Time Events and Data Processing. From version 1.6.19 to before version 1.17.2, Nuclio's Dashboard build pipeline does not sanitize the spec.build.tempDir field before using it to construct a shell command. When the Kaniko container builder is enabled, a user with function-create permission can inject shell metacharacters into this field and achieve arbitrary command exec...
CVE-2026-87818	7.1	HIGH		0.002	gitpython_project:gitpython	GitPython 3.1.59 fails to restrict the --no-index option in the high-level diff API, allowing attackers to read arbitrary filesystem paths as repository operands. Attackers can combine --no-index with -l/--ignore-matching-lines to create a content-dependent Boolean oracle, repeatedly querying local files to recover single-line secrets through distinguishable success or error responses.
CVE-2026-87999	7.1	HIGH		0.002	openwebui:open_webui	Open WebUI is an extensible, feature-rich, and user-friendly self-hosted AI platform. Prior to 0.11.1, POST /api/v1/retrieval/process/web and POST /api/v1/retrieval/process/web/search in backend/open_webui/retrieval/web/utils.py treated Python's globally routable address classification as proof that a destination was external. An authenticated user could make an Azure-hosted instance fetch and return content from ...
CVE-2026-34789	7.0	HIGH		0.002		FreeCAD is a free and open-source multiplatform 3D parametric modeler. Prior to 1.1.2, src/App/PropertyPythonObject.cpp in PropertyPythonObject::Restore() passes the attacker-controlled module attribute from serialized PropertyPythonObject XML directly to PyImport_ImportModule() while restoring a crafted FCStd document, which executes module-level Python code, and the legacy pickle branch also imports an attacker-...
CVE-2026-50349	7.0	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Ancillary Function Driver for WinSock allows an authorized attacker to elevate privileges locally.
CVE-2026-62694	7.0	HIGH		0.003		Use after free in Windows Installer allows an authorized attacker to elevate privileges locally.
CVE-2026-68825	7.0	HIGH		0.003		Use after free in Windows Bind Filter Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-68837	7.0	HIGH		0.002		Use after free in Windows File History Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69279	7.0	HIGH		0.003		Use after free in Windows Cloud Files Mini Filter Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69280	7.0	HIGH		0.002		Use after free in Windows Push Notifications allows an authorized attacker to elevate privileges locally.
CVE-2026-69300	7.0	HIGH		0.002		Use after free in Windows Push Notifications allows an authorized attacker to elevate privileges locally.
CVE-2026-69309	7.0	HIGH		0.003		Double free in Windows Print Spooler Components allows an authorized attacker to elevate privileges locally.
CVE-2026-69311	7.0	HIGH		0.003		Use after free in Windows Audio Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69331	7.0	HIGH		0.002		Use after free in Windows Remote Access Connection Manager allows an authorized attacker to elevate privileges locally.
CVE-2026-69333	7.0	HIGH		0.003		Use after free in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69335	7.0	HIGH		0.003		Use after free in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69341	7.0	HIGH		0.003		Use after free in Windows Image Acquisition allows an authorized attacker to elevate privileges locally.
CVE-2026-69362	7.0	HIGH		0.003		Use after free in Windows Error Reporting allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69383	7.0	HIGH		0.002		External control of file name or path in Windows Shell allows an authorized attacker to elevate privileges locally.
CVE-2026-69385	7.0	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows TCP/IP allows an authorized attacker to elevate privileges locally.
CVE-2026-69388	7.0	HIGH		0.003		Use after free in Windows Bluetooth Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69394	7.0	HIGH		0.003		Heap-based buffer overflow in Windows Audio Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69398	7.0	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Bluetooth Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69404	7.0	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows TCP/IP allows an authorized attacker to elevate privileges locally.
CVE-2026-69410	7.0	HIGH		0.003		Use after free in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69440	7.0	HIGH		0.002		Time-of-check time-of-use (toctou) race condition in Windows MIDI Service Module allows an authorized attacker to elevate privileges locally.
CVE-2026-69441	7.0	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Installer allows an authorized attacker to elevate privileges locally.
CVE-2026-69448	7.0	HIGH		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Bluetooth Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69468	7.0	HIGH		0.003		Heap-based buffer overflow in Windows Volume Manager Extension Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69488	7.0	HIGH		0.003		Use after free in Windows Device Association Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69492	7.0	HIGH		0.003		Heap-based buffer overflow in Windows Partition Management Driver allows an authorized attacker to elevate privileges locally.
CVE-2026-69498	7.0	HIGH		0.003		Use after free in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69500	7.0	HIGH		0.003		Use after free in Windows Image Acquisition allows an authorized attacker to elevate privileges locally.
CVE-2026-69517	7.0	HIGH		0.003		Use after free in Windows Wireless Networking allows an authorized attacker to elevate privileges locally.
CVE-2026-69540	7.0	HIGH		0.003		Use after free in Windows Audio Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69560	7.0	HIGH		0.003		Use after free in Windows Work Folder Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69563	7.0	HIGH		0.002		Heap-based buffer overflow in Windows Program Compatibility Assistant Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69564	7.0	HIGH		0.003		Heap-based buffer overflow in Windows Online Certificate Status Protocol (OCSP) allows an authorized attacker to elevate privileges locally.
CVE-2026-69581	7.0	HIGH		0.002		Use after free in Windows Device Association Service allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69606	7.0	HIGH		0.003		Use after free in Windows Shell allows an authorized attacker to elevate privileges locally.
CVE-2026-69610	7.0	HIGH		0.003		Buffer over-read in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69613	7.0	HIGH		0.003		Use after free in Windows Image Acquisition allows an authorized attacker to elevate privileges locally.
CVE-2026-69617	7.0	HIGH		0.003		Out-of-bounds read in Windows Resilient File System (ReFS) allows an authorized attacker to elevate privileges locally.
CVE-2026-69621	7.0	HIGH		0.003		Heap-based buffer overflow in Windows Fax Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69630	7.0	HIGH		0.003		Out-of-bounds read in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69648	7.0	HIGH		0.003		Use after free in Windows Notification allows an authorized attacker to elevate privileges locally.
CVE-2026-69652	7.0	HIGH		0.003		Use after free in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-69654	7.0	HIGH		0.003		Use after free in Windows Accounts Control allows an authorized attacker to elevate privileges locally.
CVE-2026-69682	7.0	HIGH		0.002		Use after free in Windows Host Guardian Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69692	7.0	HIGH		0.003		Use after free in Windows Audio Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69693	7.0	HIGH		0.003		Use after free in Windows Device Association Broker service allows an authorized attacker to elevate privileges locally.
CVE-2026-69708	7.0	HIGH		0.003		Use after free in Windows Web Platform Storage allows an authorized attacker to elevate privileges locally.
CVE-2026-69711	7.0	HIGH		0.003		Use after free in Windows Device Association Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69735	7.0	HIGH		0.003		Use after free in Windows Broadcast DVR User Service allows an authorized attacker to elevate privileges locally.
CVE-2026-69779	7.0	HIGH		0.002		Time-of-check time-of-use (toctou) race condition in Windows Win32K allows an authorized attacker to elevate privileges locally.
CVE-2026-70578	7.0	HIGH		0.003		Heap-based buffer overflow in Windows Credential Guard allows an authorized attacker to elevate privileges locally.
CVE-2026-70585	7.0	HIGH		0.003		Use after free in Windows Services for NFS ONCRPC XDR Driver allows an authorized attacker to execute code locally.
CVE-2026-71351	7.0	HIGH		0.003		Double free in Windows Routing and Remote Access Service (RRAS) allows an authorized attacker to elevate privileges locally.
CVE-2026-71353	7.0	HIGH		0.002		Double free in Windows Routing and Remote Access Service (RRAS) allows an authorized attacker to elevate privileges locally.
CVE-2026-72926	7.0	HIGH		0.003		Use after free in Windows Internet Connection Sharing (ICS) allows an authorized attacker to elevate privileges locally.
CVE-2026-72930	7.0	HIGH		0.003		Use after free in Windows Secure Socket Tunneling Protocol (SSTP) allows an authorized attacker to execute code locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-72952	7.0	HIGH		0.003		Out-of-bounds read in Windows Spaceport.sys allows an authorized attacker to execute code locally.
CVE-2026-73003	7.0	HIGH		0.002		Use after free in Windows Modern Device Management (MDM) allows an authorized attacker to elevate privileges locally.
CVE-2026-73005	7.0	HIGH		0.002		Use after free in Windows Authentication Methods allows an authorized attacker to elevate privileges locally.
CVE-2026-81389	7.0	HIGH		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Heap-based buffer overflow in Microsoft Office Excel allows an unauthorized attacker to execute code locally.
CVE-2026-85360	7.0	HIGH		0.002	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:wi	Use after free in Windows Kernel allows an authorized attacker to elevate privileges locally.
CVE-2026-21098	6.9	MEDI		0.001		Improper access control in Link to Windows prior to SMR Sep-2026 Release 1 allows local attackers to establish a connection with the PC without proper user interaction.
CVE-2026-52873	6.9	MEDI		0.003		Streambert is a cross-platform Electron Desktop App to stream and download video content. From version 2.5.0 until version 2.6.0, the wyzie-open-redeem IPC handler in index.js creates the partition:wyzie-redeem Electron session and registers an onHeadersReceived hook that removes the Content-Security-Policy header from every response in that session. The redeem window also lacks a setWindowOpenHandler restriction,...
CVE-2026-54272	6.9	MEDI		0.004		ip-address is a library for parsing and manipulating IPv4 and IPv6 addresses in JavaScript. Versions 10.1.1 through 10.2.0 are vulnerable to SSRF through misclassification of IPv4-mapped/NAT64 IPv6 addresses. Address6.getType() classifies an address by matching it against a table of known IPv6 special-use prefixes, returning Global unicast when nothing matches. That table had no entry for the IPv4-mapped range (:...
CVE-2026-55758	6.9	MEDI		0.004		CC: Tweaked is a mod for Minecraft which adds programmable computers, turtles, and more to the game. Prior to 1.120.0, the SSRF protection in projects/core/src/main/java/dan200/computercraft/core/apis/http/options/AddressPredicate.java blocks the RFC 6052 64:ff9b::/96 NAT64 prefix but omits the RFC 8215 64:ff9b:1::/48 local-use prefix. On a dual-stack server using RFC 8215 NAT64, an unauthenticated user who can ex...
CVE-2026-69092	6.9	MEDI		0.003		Admidio versions before 5.0.11 contain a reflected cross-site scripting vulnerability in the SSO/SAML endpoint that echoes unencoded exception messages to the HTTP response. Unauthenticated attackers can inject arbitrary JavaScript through SAML Issuer elements or LightSaml library parameters to execute code in users' browsers and hijack sessions.
CVE-2026-71313	6.9	MEDI		0.003		rclone is a command-line program to sync files and directories to and from different cloud storage providers. From v1.51.0 until v1.75.0, the local backend in backend/local/local.go relies on the configurable filename encoder to prevent remote filename data from becoming operating-system path syntax, so a local destination using Slash, None, Raw, or on Windows an encoding that preserves backslash can decode a stan...
CVE-2026-78325	6.9	MEDI		0.001		Cross-site scripting in the Evernote and Google Keep note importers in Standard Notes for Android through 3.201.24 allows an attacker to execute arbitrary JavaScript in the application context when a victim imports a crafted .enex or Google Keep HTML file, leading to theft of encryption keys and note data, and arbitrary invocation of native device APIs.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-82398	6.9	MEDI		0.003		pypdf is a free and open-source pure-python PDF library. Prior to 6.15.0, an attacker can craft a PDF that causes long runtimes when the pypdf/_utils.py function read_until_whitespace reads a stream containing a long run of bytes without whitespace. The function repeatedly performs immutable bytes concatenation in a one-byte loop, causing quadratic processing cost for the long non-whitespace input. This issue is f...
CVE-2026-84309	6.9	MEDI		0.001		pypdf is a free and open-source pure-python PDF library. Prior to 6.16.0, an attacker can craft a PDF whose cyclic tree structure causes pypdf/generic/_data_structures.py TreeObject.insert_child to follow /Next links indefinitely when a writing code path inserts a child, producing an infinite loop. This issue is fixed in version 6.16.0.
CVE-2026-86431	6.9	MEDI		0.002	thephpleague:commonmark	league/commonmark (thephpleague/commonmark) versions >= 2.7.0 and < 2.9.1 contain a cross-site scripting vulnerability in the AttributesExtension. Prefixing an attribute name with a single U+000C form feed byte (e.g. {x0Conclck="alert(1)"} bypasses the AttributesHelper::filterAttributes() 'on*' event-handler filter because PHP's trim() does not strip U+000C, causing the attribute to be written verbatim into the...
CVE-2026-8794	6.9	MEDI		0.004		PaperCut NG/MF contains an observable timing discrepancy in its authentication component. An unauthenticated remote attacker can exploit this vulnerability to perform username enumeration by measuring response times during login attempts. The system executes a password hash comparison only when a valid account is supplied, creating a measurable timing oracle that reveals account existence.
CVE-2026-15927	6.8	MEDI		0.005		A flaw was found in Red Hat Quay's repository-level mirror configuration feature. The POST and PUT handlers in endpoints/api/mirror.py accept an external_reference parameter without SSRF validation, unlike the organization-level mirror handlers which apply validate_external_registry_url(). A repository administrator can supply a crafted hostname that causes the Quay mirror worker to make requests via Skopeo to int...
CVE-2026-18796	6.8	MEDI		0.001		Any application that uses external QSPI flash for encrypted XIP on nRF5340 and relies on that encryption for confidentiality and/or integrity of the externally stored code. No specific nRF Connect SDK version is the root cause; the weakness is in the on-the-fly decryption scheme.
CVE-2026-49349	6.8	MEDI		0.002		regclient is a Docker and OCI Registry Client in Go. Prior to version 0.11.5, credentials for a registry may be inadvertently leaked to external servers. A prerequisite for this attack is a malicious registry server, a malicious blob store, or a registry that does not restrict the external URLs for foreign blobs. Version 0.11.5 fixes the issue.
CVE-2026-71349	6.8	MEDI		0.004		Heap-based buffer overflow in Windows Spaceport.sys allows an unauthorized attacker to execute code with a physical attack.
CVE-2026-71350	6.8	MEDI		0.004		Heap-based buffer overflow in Windows Spaceport.sys allows an unauthorized attacker to execute code with a physical attack.
CVE-2026-48121	6.7	MEDI		0.002		@langchain/langgraph-checkpoint-mongodb provides a LangGraph.js CheckpointSaver implementation that uses MongoDB for storage. Versions 1.3.0 and below are vulnerable to NoSQL injection: checkpoint identifiers (thread_id, checkpoint_ns, checkpoint_id) from config.configurable are passed into MongoDB find() queries in MongoDBSaver.getTuple() without type enforcement. If an attacker supplies an object payload (such a...
CVE-2026-69350	6.7	MEDI		0.003		Heap-based buffer overflow in Windows Overlay Filter allows an authorized attacker to elevate privileges locally.
CVE-2026-69373	6.7	MEDI		0.003		Integer overflow or wraparound in Windows Overlay Filter allows an authorized attacker to elevate privileges locally.
CVE-2026-69449	6.7	MEDI		0.004		Heap-based buffer overflow in Windows BitLocker allows an authorized attacker to execute code locally.
CVE-2026-72935	6.7	MEDI		0.003		Out-of-bounds read in Windows NTFS allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-72948	6.7	MEDI		0.004		Relative path traversal in Windows DNS allows an authorized attacker to elevate privileges locally.
CVE-2026-19201	6.6	MEDI		0.003		An uncontrolled recursion vulnerability in the Windows SIPA event log parser of Google go-attestation versions up to and including 0.6.1 allows an attacker to cause a denial of service (DoS). The (*WinEvents).readELAMAggregation function recurses for every nested elamAggregation sub-event without enforcing a maximum recursion depth limit, while the size guard is bypassed on recursive execution paths. By submitting...
CVE-2024-9355	6.5	MEDI		0.003		A vulnerability was found in Golang FIPS OpenSSL. This flaw allows a malicious user to randomly cause an uninitialized buffer length variable with a zeroed buffer to be returned in FIPS mode. It may also be possible to force a false positive match between non-equal hashes when comparing a trusted computed hmac sum to an untrusted input sum if an attacker can send a zeroed buffer in place of a pre-computed sum. It...
CVE-2026-17443	6.5	MEDI		0.003	ibm:app_connect_enterprise, ibm:integration_bus_for_zVos	IBM App Connect Enterprise 13.0.1.0 through 13.0.8.1, and 12.0.1.0 through 12.0.12.28 and IBM Integration Bus for z/OS 10.1.0.0 through 10.1.0.7 could allow a remote authenticated attacker to obtain sensitive information due to an XML external entity (XXE) injection flaw.
CVE-2026-17622	6.5	MEDI		0.005	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.10.2 could allow a remote authenticated attacker to obtain sensitive information due to improper limitation of a pathname to a restricted directory.
CVE-2026-17631	6.5	MEDI		0.002	apple:macos, langflow:langflow, linux:linux_kernel, microsoft:windows	IBM Langflow OSS 1.0.0 through 1.10.2 could allow a remote authenticated attacker to obtain sensitive information due to a server-side request forgery (SSRF) vulnerability.
CVE-2026-41607	6.5	MEDI		0.009	apache:thrift	Out-of-bounds Read vulnerability in Apache Thrift. This issue affects Apache Thrift: before 0.23.0. Users are recommended to upgrade to version 0.23.0, which fixes the issue.
CVE-2026-46370	6.5	MEDI		0.003		Fleet is an open-source device management platform built on osquery. In versions up to and including 4.84.1, the labels host-listing endpoint (GET /api/v1/fleet/labels/{id}/hosts) allowed an authenticated user with the lowest-privilege Observer role to extract host enrollment secrets through a sort-order oracle. The endpoint accepted a user-supplied order_key parameter that was not validated against a column allow...
CVE-2026-46371	6.5	MEDI		0.002		Fleet is an open-source device management platform built on osquery. In versions up to and including 4.84.1, the Apple MDM commands listing endpoint (GET /api/v1/fleet/mdm/apple/commands) allowed an authenticated user with the lowest-privilege Observer role to extract sensitive values from joined database tables, including host enrollment secrets and Apple Push Notification Service tokens, through a sort-order ora...
CVE-2026-48093	6.5	MEDI		0.002		The Code Embed WordPress plugin prior to version 2.6.1 is vulnerable to stored Cross-Site Scripting (XSS) through the external URL embed feature in post content. The vulnerable code scans rendered content for URL embed tokens, fetches the remote URL, and inserts the remote response body into the page without output sanitization or an `unfiltered_html` capability check. This allows a Contributor attacker to submit ...
CVE-2026-48786	6.5	MEDI		0.003		Fleet is an open-source device management platform built on osquery. In versions prior to 4.87.0, the target search endpoint (POST /api/latest/fleet/targets) returned unmasked team enroll secrets and full team configuration, including credential-bearing agent options, to low-privilege observer-class users. Other team-facing endpoints mask these fields for observers, but the target search endpoint did not apply the...
CVE-2026-52733	6.5	MEDI		0.003		ZEBRA is a Zcash node written entirely in Rust. Prior to 4.5.0, a natural or attacker-influenced chain fork can leave stale Sapling and Orchard note-commitment subtree roots in Zebra state. In zebra-state/src/service/non_finalized_state/chain.rs, Chain::pop_tip removed a reverted tip block but did not remove subtree entries whose end_height belonged to that block, unlike the cleanup performed by pop_root. When the...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-53583	6.5	MEDI		0.002		libgit2 is a portable C implementation of the Git core methods provided as a linkable library with a solid API, allowing to build Git functionality into your application. Prior to 1.8.6 and 1.9.5, verify_server_cert in src/libgit2/streams/openssl.c uses an inverted !!memcmp result in the GEN_IPADD branch when comparing an IP-literal host with a certificate IP SubjectAltName. OpenSSL builds reject matching IP addre...
CVE-2026-54732	6.5	MEDI		0.003		libreoffice-convert is a Node.js module for converting office documents to different formats. Prior to 1.8.2, index.js uses the caller-controlled options.fileName value in path.join(tempDir.name, fileName) without reducing it to a base name. A filename containing ../ can escape the temporary directory because path.basename() normalization is missing and write the supplied document buffer to an arbitrary path writa...
CVE-2026-54738	6.5	MEDI		0.004		Lemmy is a link aggregator and forum for the fediverse. Prior to 0.19.19 and 1.0.0-beta.1, actix-web ConnectionInfo::realip_remote_addr reads the first value of X-Forwarded-For as the client address used by raw_ip_key in crates/utls/src/rate_limit/mod.rs. Lemmy's bundled docker/nginx.conf uses \$proxy_add_x_forwarded_for instead of \$remote_addr, which appends the real client address to an X-Forwarded-For value sup...
CVE-2026-55618	6.5	MEDI		0.003		eml_parser serves as a python module for parsing eml files and returning various information found in the e-mail as well as computed information. Prior to 3.0.2, the clean_found_uri function in eml_parser/parser.py validates potential URL strings before unescaping HTML entities used for colon, slash, or period characters. Valid encoded URLs and their host names are therefore rejected and omitted from the extracted...
CVE-2026-63667	6.5	MEDI		0.004		ApostropheCMS is an open-source Node.js content management system. Prior to 3.6.2, the import-export module in packages/import-export/lib/formats/gzip.js constructs an attachment source path from the attacker-controlled _id, name, and extension fields in aposAttachments.json without ensuring that the resolved path remains under the extracted attachments directory, allowing an authenticated contributor to import a ...
CVE-2026-63669	6.5	MEDI		0.002		ApostropheCMS is an open-source Node.js content management system. Prior to 4.32.0, the page module's move() operation fails to enforce the destination parent's _create permission because its oldParent archive condition disables the check for ordinary moves, allowing an authenticated editor or contributor to use _targetId and _position through the page REST update endpoint to move a controlled page into a restrict...
CVE-2026-64918	6.5	MEDI		0.005	microsoft:365_apps, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Insufficiently protected credentials in Microsoft Office allows an unauthorized attacker to perform spoofing over a network.
CVE-2026-69297	6.5	MEDI		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Storing passwords in a recoverable format in Windows DHCP Server allows an authorized attacker to disclose information over a network.
CVE-2026-69361	6.5	MEDI		0.008		Server-side request forgery (ssrf) in Microsoft Exchange Server allows an authorized attacker to perform spoofing over a network.
CVE-2026-69409	6.5	MEDI		0.01	microsoft:sharepoint_server	Execution with unnecessary privileges in Microsoft Office SharePoint allows an authorized attacker to disclose information over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69497	6.5	MEDI		0.011	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Missing release of memory after effective lifetime in Windows DHCP Server allows an authorized attacker to deny service over a network.
CVE-2026-69626	6.5	MEDI		0.009	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Buffer over-read in Microsoft Office allows an unauthorized attacker to disclose information over a network.
CVE-2026-69636	6.5	MEDI		0.01	microsoft:sharepoint_server	Improper neutralization of special elements used in an sql command ('sql injection') in Microsoft Office SharePoint allows an authorized attacker to disclose information over a network.
CVE-2026-72938	6.5	MEDI		0.009	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Access of resource using incompatible type ('type confusion') in Microsoft Office PowerPoint allows an unauthorized attacker to disclose information over a network.
CVE-2026-72974	6.5	MEDI		0.009	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Buffer over-read in Microsoft Office Excel allows an unauthorized attacker to disclose information over a network.
CVE-2026-72975	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Out-of-bounds read in Microsoft Office PowerPoint allows an unauthorized attacker to disclose information over a network.
CVE-2026-72977	6.5	MEDI		0.01	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Out-of-bounds read in Microsoft Office PowerPoint allows an unauthorized attacker to disclose information over a network.
CVE-2026-75509	6.5	MEDI		0.001		joserfc is a Python library that provides an implementation of several JSON Object Signing and Encryption (JOSE) standards. Prior to version 1.7.3, JWTClaimsRegistry applies membership matching to list-valued iss and sub claims, allowing an array-valued iss that contains the expected issuer to pass an intended equality check and enabling issuer-validation bypass. This issue is fixed in version 1.7.3.
CVE-2026-78515	6.5	MEDI		0.009	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:office_2021, micros	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to disclose information over a network.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-78520	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Out-of-bounds read in Microsoft Office Outlook allows an unauthorized attacker to execute code over a network.
CVE-2026-78838	6.5	MEDI		0.004		A reflected cross-site scripting (XSS) vulnerability in the grid_datasource.php component of AppNitro MachForm v30 allows attackers to execute arbitrary Javascript in the context of the victim's browser via injecting a crafted payload into the filter[filters][0][field] parameter.
CVE-2026-80073	6.5	MEDI		0.009	microsoft:365_apps, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, microsoft:outlook	Out-of-bounds read in Microsoft Office Outlook allows an unauthorized attacker to disclose information over a network.
CVE-2026-80076	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Out-of-bounds read in Microsoft Office allows an unauthorized attacker to disclose information over a network.
CVE-2026-80078	6.5	MEDI		0.007	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024	Out-of-bounds read in Microsoft Office allows an unauthorized attacker to disclose information over a network.
CVE-2026-84365	6.5	MEDI		0.003		Hono is a Web application framework that provides support for any JavaScript runtime. From 4.12.12 until 4.13.5, the fix released for CVE-2026-39408 does not cover every traversal sequence, and toSSG() can still write files outside the configured output directory when a route parameter contains consecutive parent-directory segments. Static site generation builds each output path from the route path and values supp...
CVE-2026-86550	6.5	MEDI		0.003		NuBrowser lacks protocol whitelist validation for the S.browser_fallback_url field of intent://, allowing attackers to inject javascript: URLs via 302 redirects. This results in a universal cross-site scripting (UXSS) vulnerability that enables script execution within the origin of arbitrary websites.
CVE-2026-87454	6.5	MEDI		0.002	google:chrome, microsoft:windows	Information leak in Enterprise in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker to obtain sensitive information via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-19634	6.4	MEDI		0.002		PostgreSQL Anonymizer contains a SQL injection vulnerability in two import functions. A user can create a malicious JSON document containing specially crafted object names. If a superuser subsequently calls anon.import_database_rules() or anon.import_roles_rules(), the malicious code is executed with superuser privileges. The issue is fixed in PostgreSQL Anonymizer 3.1.4 and later
CVE-2026-54743	6.4	MEDI		0.005		Lemmy is a link aggregator and forum for the fediverse. Prior to lemmy-ui 0.19.19-beta.1, LemmyNet/lemmy-ui renders Markdown in src/shared/markdown.ts for post bodies, comment bodies, private messages, and community and site sidebars through mdToHtml, which returns a raw __html object that Inferno injects without a sanitizer pass. setupMarkdown configures html as false but registers markdown-it-html5-embed@1.0.0 w...
CVE-2026-70582	6.4	MEDI		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Management Instrumentation allows an authorized attacker to elevate privileges locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-83534	6.4	MEDI		0.002		PostgreSQL Anonymizer contains a vulnerability in the anon.anonymize_database_parallel() function that allows the owner of a table to run arbitrary code with superuser privilege. The issue is fixed in PostgreSQL Anonymizer 3.2.0 and later versions
CVE-2026-25552	6.3	MEDI		0.002		Ghost CLI before 1.30.1 contains an IP spoofing vulnerability that allows unauthenticated remote attackers to bypass rate-limiting controls by manipulating the X-Forwarded-For header through a misconfigured Nginx configuration. Attackers can append attacker-controlled values to the header chain using the \$proxy_add_x_forwarded_for directive to present an arbitrary IP address, circumventing Ghost's rate-limiting me...
CVE-2026-43980	6.3	MEDI		0.002		Malla is a web analyzer for Meshtastic networks based on MQTT data. Prior to commit 4086e2b5f61615a813b70b25bc76095083552135, code names (long_name, short_name) received via MQTT are stored in SQLite without sanitization and rendered into the DOM without escaping. Any participant on a public Meshtastic MQTT broker can set a malicious node name that executes JavaScript in the browser of every Malla dashboard visito...
CVE-2026-50544	6.3	MEDI		0.001		NortheBridge/luminalshine is a Sunshine-compatible game stream host for Moonlight. Prior to version 26.05.0-rc4, a latent gap exists on a default install, the file at `src/platform/windows/misc.cpp` lives at `C:\ProgramData\LuminalShine\config\apps.json` and is created by the `SYSTEM` service. Under Windows' default `C:\ProgramData` inheritance, that gives `BUILTIN\Users` only Read+Execute — not writable — so the ...
CVE-2026-61807	6.3	MEDI		0.003		Snipe-IT is an IT asset/license management system. Prior to 8.6.2, a stored manufacturer or supplier name passed as the table component \$name becomes data-selected-count-id in resources/views/partials/bootstrap-table.blade.php. Client-side code reads the browser-decoded countId, uses it as a selector, concatenates countId.substring(1) into an HTML string, and passes the string to jQuery .after(). A crafted name ca...
CVE-2026-73411	6.3	MEDI		0.003		Shescape is a simple shell escape library for JavaScript. Prior to 2.1.14 and 3.0.1, getEscapeFunction in src/internal/unix/dash.js fails to escape ~ after : or = when applications use the escape or escapeAll APIs on Unix with shell set to dash, or with shell set to true when Dash is the default, and interpolate the result into an assignment prefixed to a command. An attacker who controls the input can supply a va...
CVE-2026-73412	6.3	MEDI		0.003		Shescape is a simple shell escape library for JavaScript. Prior to 2.1.14 and 3.0.1, this impacts users of Shescape on Unix systems that explicitly configure shell to Zsh, or true when the default shell is Zsh, using the escape and escapeAll. The Zsh options EXTENDED_GLOB and MAGIC_EQUAL_SUBST exacerbate the problem. In certain case, an attacker can leverage home directory expansion and extended glob syntax to obt...
CVE-2026-84942	6.3	MEDI		0.003		Improper input validation in the Vega expression function implementation in OpenSearch Dashboards allows a remote authenticated actor with dashboard write permissions to execute arbitrary JavaScript in the context of other users' browser sessions by saving a crafted Vega visualization. The checkForFunctionProperty validation routine failed to recurse into arrays of objects, allowing a function property nested insi...
CVE-2026-71429	6.2	MEDI		0.001		stream-json is a micro-library of stream components for processing JSON and JSONC with a minimal memory footprint. Prior to 3.5.0, the path filters pick, ignore, filter, and replace in src/core/filters/filter-base.js recompute the full path string from the nesting stack for every checkable token. Because the stack length equals the current nesting depth and a checkable token is emitted at every level, a depth D do...
CVE-2025-51684	6.1	MEDI		0.003		CleverTap Web SDK v1.15.1 is vulnerable to Cross Site Scripting (XSS). The application does not sanitize untrusted data received via window.postMessage before injecting it into the page DOM. An attacker can craft a malicious message that, when processed by renderCustomHtml, results in execution of arbitrary JavaScript in the context of the hosting site.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-50980	6.1	MEDI		0.004		Cross-Site Scripting (XSS) vulnerability in the DNS lookup/management component of oPanel before v1.20.25 allows remote attackers to execute arbitrary JavaScript and perform session hijacking via a crafted DNS TXT record
CVE-2026-52232	6.1	MEDI		0.002		A reflected cross-site scripting (XSS) vulnerability in the /logo.asp component of FS Inc S3150-8T2F Switch 2.2.0D Build 118101 allows attackers to execute arbitrary Javascript in the context of the victim's browser via a crafted URL.
CVE-2026-52370	6.1	MEDI		0.002		A reflected cross-site scripting (XSS) vulnerability in the Forum posting function of O2OA v10 allows attackers to execute arbitrary Javascript in the context of the victim's browser via a crafted URL.
CVE-2026-55087	6.1	MEDI		0.005		Etherpad is a real-time collaborative editor. From 2.1.0 until 3.1.0, Etherpad uses the attacker-controlled x-proxy-path request header in src/node/hooks/express/admin.ts when substituting paths into HTML, JavaScript, and CSS under /admin without sanitization, Vary: x-proxy-path, or Cache-Control: private, no-store. A shared proxy or CDN can cache the resulting response and serve attacker-injected script to an adm...
CVE-2026-63670	6.1	MEDI		0.003		ApostropheCMS is an open-source Node.js content management system. Prior to 2.17.6, sanitizeHtml() can pass disallowed executable markup through packages/sanitize-html/index.js when textarea or xmp is included in allowedTags because a literal solidus after the raw-text end-tag name is treated as text by htmlparser2 and the ontext handler emits that content without escaping, while a browser parses the following img...
CVE-2026-73084	6.1	MEDI		0.002		Activepieces is an open source AI workflow automation platform. Prior to 0.83.0, the /api/redirect OAuth callback endpoint embeds the user-supplied code query parameter directly into an inline script block without proper escaping. A crafted request to /api/redirect with a malicious code value can break out of the script context and execute arbitrary JavaScript in the Activepieces origin when a logged-in user opens...
CVE-2026-75170	6.1	MEDI		0.002		Cross-site scripting (XSS) vulnerability in the /loginController/doLogin endpoint of the HubCore platform (version 14.1.1) allows a remote unauthenticated attacker to inject arbitrary JavaScript into the application's response via the language POST parameter.
CVE-2026-76002	6.1	MEDI		0.007		ColdFusion is affected by a reflected Cross-Site Scripting (XSS) vulnerability. If an attacker is able to convince a victim to visit a URL referencing a vulnerable page, malicious JavaScript content may be executed within the context of the victim's browser. Scope is changed.
CVE-2026-79419	6.1	MEDI		0.002		A reflected cross-site scripting (XSS) vulnerability exists in EMX Tecnologia Gestao X Business Suite 8.4 and earlier. The vulnerability is caused by insufficient validation and sanitization of the mensagem parameter in the /Configuracao/Imagens.aspx endpoint, allowing an authenticated attacker to inject arbitrary JavaScript code that is reflected and executed in the context of a victim's browser.
CVE-2026-84369	6.1	MEDI		0.003		SVGO, short for SVG Optimizer, is a Node.js library and command-line application for optimizing SVG files. From version 1.0.0 until versions 2.8.4, 3.3.5, and 4.1.0, the opt-in removeScripts plugin, named removeScriptElement in versions 2 and 3 and implemented in plugins/removeScripts.js, removes SVG and XHTML script elements but does not inspect executable HTML content inside SVG foreignObject elements. Event-han...
CVE-2026-0294	6.0	MEDI		0.001	apple:macos, microsoft:windows, paloaltonetworks:prisma_access_agent	A privilege escalation (PE) vulnerability in the Palo Alto Networks Prisma® Access Agent app on Windows and macOS devices enables a local user to execute code with elevated privileges. The Prisma Access Agent on Linux, iOS, Android, and ChromeOS is not affected.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-58139	6.0	MEDI		0.003		The DuckDB AWS extension for DuckDB contains a security policy bypass vulnerability that allows any database user with SQL execution permissions to extract plaintext AWS credentials by calling the <code>load_aws_credentials</code> function with the <code>redact_secret</code> parameter set to false, circumventing the database-wide <code>allow_unredacted_secrets=false</code> policy. Attackers can invoke this single function to retrieve the underlying AWS...
CVE-2026-65985	6.0	MEDI		0.003		FUXA is a web-based Process Visualization (SCADA/HMI/Dashboard) software. In 1.3.2 and earlier, the <code>device-webapi-request</code> <code>Socket.IO</code> handler in <code>server/runtime/index.js</code> permits an authenticated non-admin runtime user to control <code>property.address</code> , causing the FUXA server to issue an outbound HTTP or HTTPS request and return the response body to the requesting socket. The attacker can use the server as a read SSRF orac...
CVE-2026-32637	5.9	MEDI		0.005		Velero is an open source tool for backing up, restoring, and migrating Kubernetes cluster resources and persistent volumes. Prior to 1.18.1, an attacker who compromises the backup object-storage backend can upload a malicious backup tarball containing parent-directory paths that escape the extraction directory during restore and overwrite sensitive files in the Velero pod filesystem. This issue is fixed in version...
CVE-2026-52739	5.9	MEDI		0.004		ZEBRA is a Zcash node written entirely in Rust. Prior to 4.5.0, a malicious block producer can terminate zebrad by placing the same shielded transaction in a non-finalized parent block and its child. In <code>zebra-state/src/service/non_finalized_state/chain.rs</code> , <code>Chain::push</code> originally inserted the transaction hash into <code>tx_loc_by_hash</code> and asserted uniqueness before updating shielded data and running the duplicate Sprout,...
CVE-2026-84363	5.9	MEDI		0.003		Hono is a Web application framework that provides support for any JavaScript runtime. Prior to 4.13.5, Hono's query helpers treat a question mark after a literal hash fragment as the start of a query string, so the application can read request parameters that browsers, <code>new URL()</code> , reverse proxies, filtering rules, parameter allow and deny lists, access logging, request validation, and other middleware do not observ...
CVE-2026-84378	5.9	MEDI		0.003		HTTPX2 is a next generation HTTP client for Python. From 2.5.0 until 2.10.0, the HTTPX2 Server-Sent Events parser in <code>src/httpx2/httpx2/_sse.py</code> repeatedly copies and rescans buffered text in <code>_SSELineDecoder.decode()</code> when an attacker-controlled or compromised SSE endpoint splits one unterminated line across many response chunks. The behavior affects <code>httpx2.Client.sse()</code> and <code>httpx2.AsyncClient.sse()</code> , and the total pro...
CVE-2026-69129	5.8	MEDI		0.002		KubePi is a Kubernetes multi-cluster management panel. In versions up to and including 2.0.0, cluster-scoped APIs do not consistently validate per-cluster access, allowing an authenticated user with cluster management permissions to operate on clusters outside the scope they were granted. Because the affected endpoints act on cluster-specific data without confirming that the requesting user is authorized for that ...
CVE-2026-72764	5.8	MEDI		0.004		n8n's JavaScript task runner shared a single module cache across all users' Code-node executions. In affected versions (before 1.123.67, 2.31.5, and 2.32.1), a user able to run a Code node could poison a cached module and thereby alter other users' Code-node executions on the same runner, affecting their confidentiality, integrity, or availability. This is a cross-user isolation break within a single n8n instance ...
CVE-2026-73243	5.8	MEDI		0.004		kkFileView is a universal file online preview project based on Spring Boot. Prior to 5.0.1, the unauthenticated GET <code>/addTask</code> endpoint in kkFileView is omitted from <code>TrustHostFilter</code> and <code>TrustDirFilter</code> in <code>server/src/main/java/cn/keking/config/WebConfig.java</code> , allowing <code>FileConvertQueueTask</code> to fetch an attacker-selected URL after <code>FileHandlerService#getFileAttribute</code> uses the <code>filename</code> parameter to force an OFFICE, COM...
CVE-2026-16180	5.7	MEDI		0.002	ibm:app_connect_enterprise, ibm:integration_bus_for_zVos	IBM App Connect Enterprise 13.0.1.0 through 13.0.8.1, and 12.0.1.0 through 12.0.12.28 and IBM Integration Bus for z/OS 10.1.0.0 through 10.1.0.7 Toolkit could allow an authenticated user to cause a denial-of-service condition due to improper validation of XML entities.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-69405	5.7	MEDI		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Missing release of memory after effective lifetime in Windows DHCP Server allows an authorized attacker to deny service over an adjacent network.
CVE-2026-69637	5.7	MEDI		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an authorized attacker to deny service over an adjacent network.
CVE-2026-69679	5.7	MEDI		0.006	microsoft:windows_10_1607, microsoft:windows_10_1809, microsoft:windows_server_2012, microsoft:windows_server_2016, micr	Out-of-bounds read in Windows DHCP Server allows an authorized attacker to deny service over an adjacent network.
CVE-2026-85788	5.7	MEDI		0.001		Incomplete list of disallowed inputs in the mutable SQL detector component in Amazon awslabs mysql-mcp-server might allow context-dependent actors to bypass the read-only enforcement gate and reach file-read and file-write SQL sinks via SQL inline comments that the regex engine does not treat as whitespace. To remediate this issue, users should upgrade to version 1.0.23.
CVE-2026-0293	5.6	MEDI		0.001	microsoft:windows, paloaltonetworks:prisma_access_agent	A vulnerability in Palo Alto Networks Prisma® Access Agent on Windows enables a local attacker with administrator privileges to bypass the anti-tamper protection, enabling unauthorized access to protected processes and files. The Prisma Access Agent on Linux, macOS, iOS, Android, and Chrome OS is not affected.
CVE-2026-73647	5.6	MEDI		0.004		Quasar Framework is a framework for building high-performance Vue.js user interfaces. Prior to 2.22.0, the public extend() utility in ui/src/utills/extend/extend.js recursively copied attacker-controlled object keys during extend(true, target, source) deep merges without rejecting an own __proto__ property. The merge could descend into the prototype object and write attacker-controlled properties to Object.prototype...
CVE-2026-84380	5.6	MEDI		0.002		HTTPX2 is a next generation HTTP client for Python. Prior to 2.11.0, Request._prepare() in src/httpx2/httpx2/_models.py can add a body-derived Content-Length header to a request that already contains a caller-supplied Transfer-Encoding header because its setdefault() processing checks each default header independently rather than treating the two framing headers as mutually exclusive. Fixed-size byte, JSON, form, ...
CVE-2025-51619	5.5	MEDI		0.001		A vulnerability in the Thesycon DPC Latency Checker driver (dpc.sys) thru 1.4.0 allows local unprivileged users to cause a denial-of-service (BSOD) condition on Windows systems. The driver exposes an IOCTL interface (0x81772008) that accepts user-controlled input without validating pointers before passing them to kernel APIs. Specifically, it dereferences a user-supplied pointer and uses the resulting value in a c...
CVE-2026-17440	5.5	MEDI		0.001	ibm:app_connect_enterprise, ibm:integration_bus_for_zVos	IBM App Connect Enterprise 13.0.1.0 through 13.0.8.1, and 12.0.1.0 through 12.0.12.28 and IBM Integration Bus for z/OS 10.1.0.0 through 10.1.0.7 could allow a local attacker to cause a denial of service due to uncontrolled recursion.
CVE-2026-17469	5.5	MEDI		0.002	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a local authenticated attacker to cause a denial of service due to an off-by-one write in the LPD queue name parser.
CVE-2026-19649	5.5	MEDI		0.001	ibm:app_connect_enterprise, ibm:integration_bus_for_zVos	IBM App Connect Enterprise 13.0.1.0 through 13.0.8.1, and 12.0.1.0 through 12.0.12.28 and IBM Integration Bus for z/OS 10.1.0.0 through 10.1.0.7 could allow a local attacker to obtain sensitive information due to improper logging of database credentials.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-49831	5.5	MEDI		0.003		DSpace open source software is a repository application which provides durable access to digital resources. Prior to versions 7.6.7, 8.4, 9.3, and 10.0, the Curation Task feature allows an output path to be used by the reporter (-r parameter), typically used to stream results and status of curation task operations. It is not restricted to any particular base path, meaning that any path writable by the DSpace (ofte...
CVE-2026-49833	5.5	MEDI		0.003		DSpace open source software is a repository application which provides durable access to digital resources. From versions 8.0-rc1 to before 8.4, 9.0-rc1 to before 9.3, and 10-rc1 to before 10.0, a path traversal vulnerability is possible via the COAR Notify / LDN service in DSpace. The attacker MUST already have DSpace administrator credentials in order to perform the attack. When reading a file input stream of an...
CVE-2026-54422	5.5	MEDI		0.001		In OpenStack Ironic Python Agent through 11.5.0, a malicious bootc container, when deployed using ironic-python-agent, may be able to extract the credentials used to download it.
CVE-2026-63004	5.5	MEDI		0.003		Unleash is an open-source feature management platform. Prior to 7.5.2, 7.6.5, and 8.0.2, the addon and integration subsystem passes the operator-controlled parameters.url value from src/lib/addons/webhook.ts and the Slack, Microsoft Teams, Datadog, and New Relic integrations to Addon.fetchRetry in src/lib/addons/addon.ts without restricting loopback, link-local, private, or cloud metadata addresses. An authenticat...
CVE-2026-68514	5.5	MEDI		0.002		OpenEXR is the reference implementation and specification for the EXR image file format, widely used in the motion picture industry. In versions 3.3.0 through 3.3.12 and 3.4.0 through 3.4.13, the PyOpenEXR Python bindings contain a heap out-of-bounds write triggered when reading a crafted deep scanline EXR file. When a deep file declares a literal channel named left alongside layer-prefixed RGB channels left.R, le...
CVE-2026-69321	5.5	MEDI		0.003		Missing authentication for critical function in Windows Power Dependency Coordinator allows an authorized attacker to perform tampering locally.
CVE-2026-69453	5.5	MEDI		0.003		Missing authorization in Microsoft Windows Search Component allows an authorized attacker to perform tampering locally.
CVE-2026-69531	5.5	MEDI		0.003		Unintended proxy or intermediary ('confused deputy') in Microsoft Windows Speech allows an authorized attacker to perform tampering locally.
CVE-2026-72964	5.5	MEDI		0.003		Missing authentication for critical function in Windows Internet Connection Sharing (ICS) allows an authorized attacker to perform tampering locally.
CVE-2026-73973	5.5	MEDI		0.003		Linuxfabrik Monitoring Plugins provides monitoring plugins for Icinga, Nagios, and related systems. Prior to version 7.0.0, check-plugins/logfile/logfile accepted a free-form --filename path and opened it as root when invoked through the shipped nagios or icinga sudoers allowlist, without confining the resolved path to /var/log. An attacker who controls the monitoring account can select a root-readable file such a...
CVE-2026-73974	5.5	MEDI		0.002		linuxfabrik-lib provides Python modules for database access, caching, shell execution, and API integrations, and Linuxfabrik Monitoring Plugins uses its shared testing helper across check plugins. Prior to linuxfabrik-lib 6.1.0 and Linuxfabrik Monitoring Plugins 7.0.0, lib.lfctest.test() treated the first or second element of a --test CSV argument as a filesystem path and returned the file contents as simulated sta...
CVE-2026-78513	5.5	MEDI		0.005	microsoft:365_apps, microsoft:microsoft_365, microsoft:office_2019, microsoft:office_2021, microsoft:office_2024, micros	Out-of-bounds read in Microsoft Office PowerPoint allows an unauthorized attacker to disclose information locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-81387	5.5	MEDI		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Exposure of sensitive system information to an unauthorized control sphere in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81390	5.5	MEDI		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81391	5.5	MEDI		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Use of uninitialized resource in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81392	5.5	MEDI		0.005	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81393	5.5	MEDI		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81394	5.5	MEDI		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Exposure of sensitive system information to an unauthorized control sphere in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81395	5.5	MEDI		0.005	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81399	5.5	MEDI		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Buffer over-read in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81400	5.5	MEDI		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-81401	5.5	MEDI		0.005	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Access of resource using incompatible type ('type confusion') in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-81958	5.5	MEDI		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Use of uninitialized resource in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-83991	5.5	MEDI		0.003	microsoft:windows_10_1809, microsoft:windows_10_21h2, microsoft:windows_10_22h2, microsoft:windows_11_23h2, microsoft:wi	Missing authentication for critical function in Windows Cloud Files Mini Filter Driver allows an authorized attacker to perform tampering locally.
CVE-2026-85875	5.5	MEDI		0.004	microsoft:365_apps, microsoft:excel, microsoft:microsoft_365, microsoft:office_2016, microsoft:office_2019, microsoft:of	Out-of-bounds read in Microsoft Office Excel allows an unauthorized attacker to disclose information locally.
CVE-2026-86222	5.5	MEDI		0.003		A vulnerability has been found in SourceCodester Class and Exam Timetabling System 1.0. This affects the function mysqli_query of the file /admin/modal_add_course2.php. Such manipulation of the argument course leads to sql injection. The attack may be launched remotely. The exploit has been disclosed to the public and may be used.
CVE-2026-86260	5.5	MEDI		0.004		A security flaw has been discovered in sfturing hosp_order up to 627f426331da8086ce8fff2017d65b1ddef384f8. The affected element is the function modifyPassWord of the file ssm_pro/src/main/java/cn/sfturing/web/CommonUserController.java of the component Password Recovery. Performing a manipulation results in unverified password change. Remote exploitation of the attack is possible. The exploit has been released to t...
CVE-2026-86319	5.5	MEDI		0.004		A vulnerability has been found in java-json-tools json-patch up to 1.13. Affected by this vulnerability is the function JsonPatch.apply of the file src/main/java/com/github/fge/jsonpatch/JsonPatch.java of the component Patch Operation Handler. The manipulation leads to resource consumption. It is possible to initiate the attack remotely. The exploit has been disclosed to the public and may be used. The project was...
CVE-2022-26961	5.4	MEDI		0.001		Italtel NetMatch-S 5.0.0-20200703 allows Multiple Stored XSS under NP_IBCF-NATUP-01/NMSCI-WebGui/backup_restore.jsp and NP_IBCF-MIBER-03/NMSCI-WebGui/storage.jsp via the name parameter. A malicious user leveraging this vulnerability could inject arbitrary JavaScript. The malicious payload will then be triggered every time an authenticated user browses the page containing it.
CVE-2026-17274	5.4	MEDI		0.002	ibm:i	IBM i 7.6, 7.5, 7.4, and 7.3 could allow a remote authenticated attacker to bypass security restrictions due to predictable server seeds.
CVE-2026-38725	5.4	MEDI		0.002		xipblog module v2.0.1 and before for PrestaShop allows unauthenticated remote attackers to inject arbitrary JavaScript via the name and content parameters in ajax.php. The input is stored in the database without HTML sanitization and rendered in Smarty templates without output escaping, resulting in Stored Cross-Site Scripting (XSS). When an administrator reviews comments in the back office, the payload executes w...
CVE-2026-38961	5.4	MEDI		0.002		Cross-Site Scripting (XSS) vulnerability in the RSS Widget of Netgate pfSense Plus (versions 26.03, 25.11.1) and pfSense CE (version 2.8.1) allows remote authenticated attackers to inject arbitrary JavaScript via malicious content in an RSS feed title. The injected script executes in the browser of any authenticated user who views the dashboard, due to insufficient sanitization of feed title data before rendering ...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-45694	5.4	MEDI		0.001		LibreNMS is a network monitoring system. In versions up to and including 26.4.0, the Proxmox application view is vulnerable to reflected cross-site scripting through the user-supplied instance and vmid GET parameters, which are reflected into the page title without adequate encoding. The parameters are placed into the page title with only strip_tags applied, and the title is then written into an inline document.ti...
CVE-2026-48483	5.4	MEDI		0.004		TypeBot is a chatbot builder tool. Prior to version 3.17.0, Typebot's WhatsApp status forwarding feature stores a workspace-configured webhook forwarding URL and later POSTs WhatsApp marketing/error status events to it from the server. The stored URL is only validated as a generic URL in settings, but the forwarding code uses the raw `ky` instance instead of the repository's SSRF-protected `safeKy` client. A works...
CVE-2026-54553	5.4	MEDI		0.003		Starlette-Admin is a fast, beautiful and extensible administrative interface framework for FastAPI and Starlette applications. Prior to 0.16.1, the list API does not validate user-supplied order_by and structured where field names against the configured sortable_fields and searchable_fields allowlists. An authenticated user with access to an affected list endpoint can submit arbitrary field names to starlette_admi...
CVE-2026-55779	5.4	MEDI		0.002		Silverstripe Versioned provides versioning for Silverstripe models. Prior to 3.2.1, RestoreAction::getRestoreMessage() in src/RestoreAction.php builds ArchiveAdmin restore notifications rendered as CAST_HTML and inserts \$restoredItem->Title, \$restoredItem->URLSegment, \$restoredItem->CMSEditLink(), and \$changedProperty['value'] without applying Convert::raw2xml(). When an administrator restores an archived page con...
CVE-2026-62324	5.4	MEDI		0.002		Jodit Editor is a WYSIWYG editor with a built-in file browser & image editor. Prior to 4.12.31, Jodit's sanitizeHTMLElement method fails to use isDangerousUrl to normalize javascript: href values before checking the scheme, allowing case variants, control-byte prefixes, and embedded tabs or newlines to bypass filtering and execute attacker-controlled script when a victim clicks a stored link rendered by an applica...
CVE-2026-69417	5.4	MEDI		0.004	microsoft:sharepoint_server	Improper neutralization of input during web page generation ('cross-site scripting') in Microsoft Office SharePoint allows an authorized attacker to perform spoofing over a network.
CVE-2026-69690	5.4	MEDI		0.004	microsoft:sharepoint_server	Improper neutralization of input during web page generation ('cross-site scripting') in Microsoft Office SharePoint allows an authorized attacker to perform spoofing over a network.
CVE-2026-71802	5.4	MEDI		0.002		A stored Cross-Site Scripting (XSS) vulnerability exists in the announcement preview component of REBUILD 4.4.3. Although the announcement content undergoes HTML escaping on the server side, the client-side preview code reverses the escaped entities using jQuery's `html().text()` method and subsequently injects the result into the DOM. An administrator or attacker capable of controlling the announcement content ca...
CVE-2026-71803	5.4	MEDI		0.002		money-pos 1.0 contains a stored Cross-Site Scripting (XSS) vulnerability. When processing returns, the backend fails to filter or escape the goodsName parameter, directly concatenating it into the order log description; the frontend subsequently renders this content using v-html. An attacker with product creation privileges can inject a malicious JavaScript payload, causing unauthorized code execution when an admi...
CVE-2026-73250	5.4	MEDI		0.001		Notepad++ is a free and open-source source code editor. Prior to 8.9.7, the Notepad++ Windows 11 x64 and ARM64 installer passes the attacker-influenced installation directory `\$INSTDIR` from PowerEditor/installer/nppSetup.nsi into a PowerShell `-Command` string used by RegisterMSIX to invoke Add-AppxPackage, allowing PowerShell subexpression syntax such as `\$()` in the installation path to execute commands in the ...
CVE-2026-73262	5.4	MEDI		0.002		Prowler is a cloud security platform. Prior to 5.37.0, Prowler's HTML output formatter in prowler/lib/outputs/html/html.py inserted finding.resource_tags, assembled by unroll_dict and parse_html_string, into generated reports without HTML escaping, allowing a cloud principal who can modify a scanned resource tag to store HTML or JavaScript that executes when another user opens the report. This issue is fixed in ve...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-73295	5.4	MEDI		0.002		Material for MkDocs is a powerful documentation framework built on top of MkDocs. From 7.2.0 until 9.7.7, the mountSearchSuggest function in src/templates/assets/javascripts/components/search/suggest/index.ts contains a DOM-based cross-site scripting vulnerability in the optional search.suggest feature that allows a crafted q URL parameter to execute JavaScript in a documentation site's origin after user interacti...
CVE-2026-81890	5.4	MEDI		0.002		elFinder is an open-source file manager for web, written in JavaScript using jQuery UI. Prior to 2.1.70, the netmount command is omitted from elFinderConnector::\$csrfProtectedCmds in php/elFinderConnector.class.php, so validateCsrfToken() is not called for this state-changing operation. In the shipped php/connector.minimal.php-dist configuration, FTP network mounts are enabled by default, and attacker-controlled p...
CVE-2026-84371	5.4	MEDI		0.002		ApostropheCMS is an open-source Node.js content management system, and sanitize-html provides a simple HTML sanitizer with a clear API. From version 1.9.0 until version 2.17.7, packages/sanitize-html/index.js validates an animation value attribute as one flat URL and does not recognize that attributeName selecting href or xlink:href gives the sibling values, from, to, or by attribute SVG SMIL URL semantics. In con...
CVE-2026-87653	5.4	MEDI		0.002	google:chrome, microsoft:windows	UI misrepresentation in FullScreen in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker to spoof UI elements via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-41606	5.3	MEDI		0.011	apache:thrift	Uncontrolled Recursion vulnerability in Apache Thrift. This issue affects Apache Thrift: before 0.23.0. Users are recommended to upgrade to version 0.23.0, which fixes the issue.
CVE-2026-47680	5.3	MEDI		0.003		The source-controller is a Kubernetes operator, specialised in artifacts acquisition from external sources such as Git, OCI, Helm repositories and S3-compatible buckets. In versions 0.0.17 through 1.8.4, an actor with the ability to influence the contents of a bucket referenced by a `Bucket` resource can cause source-controller to write fetched object data to paths outside the per-reconciliation working directory....
CVE-2026-48796	5.3	MEDI		0.003		CefSharp provides .NET bindings for the Chromium Embedded Framework for Windows Forms and Windows Presentation Foundation applications. Prior to version 148.0.90, CefSharp/SchemeHandler/FolderSchemeHandlerFactory.cs used filePath.StartsWith(rootFolder, StringComparison.OrdinalIgnoreCase) to decide whether a decoded and canonicalized request path remained inside rootFolder. That raw prefix test did not enforce a di...
CVE-2026-54048	5.3	MEDI		0.006	apache:impala	Specifying tblproperties('avro.schema.url'=' http://...') or with a 'file:/// ' URI on a table in Impala 2.0.0 to 4.5.1 on all platforms allows an attacker to trigger a GET request to internal endpoints they may not have access to but that Impala does and the response may be exposed via parsing error messages. Users are recommended to upgrade to version 4.5.2, which fixes this issue.
CVE-2026-55619	5.3	MEDI		0.003		eml_parser serves as a python module for parsing eml files and returning various information found in the e-mail as well as computed information. Prior to 3.0.2, eml_parser.parser.HeaderParser.header_fetch_parse in eml_parser/parser.py uses email.utils.getaddresses() to parse address-bearing e-mail headers. A deeply nested CFWS comment construct exhausts the standard-library recursive descent parser's call stack a...
CVE-2026-55867	5.3	MEDI		0.003		Graylog is a free and open log management platform. From 6.2.0 until 6.3.12, 7.0.7, and 7.1.2, the DELETE /users/{userId}/tokens/{idOrToken} endpoint implemented by UsersResource.revokeToken() in graylog2-server/src/main/java/org/graylog2/rest/resources/users/UsersResource.java checks USERS_TOKENREMOVE permission against the attacker-controlled userId path parameter before resolving the token selected by idOrToken...
CVE-2026-69207	5.3	MEDI		0.005		Hono is a Web application framework that provides support for any JavaScript runtime. Prior to 4.12.34, the built-in CORS middleware, hono/cors, is vulnerable to a regular expression denial of service (ReDoS). During a preflight OPTIONS request, the middleware parses the attacker-controlled Access-Control-Request-Headers header using a whitespace-tolerant regular expression whose backtracking makes its running tim...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-71848	5.3	MEDI		0.003		Hono is a Web application framework that provides support for any JavaScript runtime. From 4.12.0 to 4.12.33, the languageDetector middleware is vulnerable to algorithmic complexity denial of service when processing a crafted language tag containing a large number of hyphen separated subtags. To implement progressive language tag truncation, normalizeLanguage() repeatedly calls parts.slice(0, i).join('-') for ever...
CVE-2026-73244	5.3	MEDI		0.004		kkFileView is a universal file online preview project based on Spring Boot. Prior to 5.0.1, the unauthenticated POST /listFiles endpoint in server/src/main/java/cn/keking/web/controller/FileController.java passes the user-controlled path parameter from FileController#getFiles to Files.newDirectoryStream without confinement to the demo directory, allowing directory enumeration outside the intended root. This issue ...
CVE-2026-73422	5.3	MEDI		0.004		Astro is a web framework for content-driven websites. From 2.9.0 until 7.1.0, Astro's server-side View Transition CSS generator interpolates animation properties into an inline style element without escaping them for CSS and HTML contexts. An attacker-controlled View Transition animation value such as duration can terminate the generated style element and inject arbitrary HTML or JavaScript. The affected code is p...
CVE-2026-73508	5.3	MEDI		0.003		Netty is an asynchronous, event-driven network application framework. Prior to 4.1.136.Final and 4.2.16.Final, io.netty.handler.codec.dns.AbstractDnsRecord, io.netty.handler.codec.dns.DefaultDnsRecordDecoder.decodeRecord(), and io.netty.handler.codec.dns.DnsCodecUtil.decompressDomainName() failed to release retained or newly allocated ByteBuf objects when IDN.toASCII() or encodeDomainName() rejected a malformed do...
CVE-2026-73531	5.3	MEDI		0.002		django-helpdesk before 2.3.3 contains a stored cross-site scripting vulnerability that allows unauthenticated attackers to inject arbitrary JavaScript by submitting HTML-formatted email messages or uploading .html/.htm file attachments through public ticket submission channels. Attackers can exploit the lack of sanitization and Content-Disposition headers at the attachment-serving layer to execute malicious script...
CVE-2026-73555	5.3	MEDI		0.003		vLLM is an inference and serving engine for large language models. Prior to 0.26.0, the validation_exception_handler in vllm/entrypoints/openai/server_utils.py converts FastAPI RequestValidationError objects with str(exc), and sanitize_message in vllm/entrypoints/utils.py does not remove traceback-style file paths, allowing unauthenticated malformed JSON requests to /v1/chat/completions, /v1/completions, /tokenize...
CVE-2026-73628	5.3	MEDI		0.002		Serendipity versions >= 2.3.5 and <= 2.6.0 contain a reflected cross-site scripting vulnerability in the search clean-URL route (/search/<term>). In include/functions_routing.inc.php serveSearch(), the sanitisation pipeline runs urldecode() after HTML-encoding, so a single URL-encoded HTML payload survives strip_tags() and htmlspecialchars() and is then decoded back into live HTML in the page. A crafted search lin...
CVE-2026-77310	5.3	MEDI		0.002		jackson-databind contains the general-purpose data-binding functionality and tree-model for Jackson Data Processor. Prior to versions 2.18.9, 2.21.5, 2.22.1, 3.1.5, and 3.2.1 on their respective release lines, the java.net.InetAddress branch of FromStringDeserializer.Std._deserialize() calls InetAddress.getByName() on attacker-controlled input, causing eager DNS resolution during deserialization and enabling DNS-b...
CVE-2026-80339	5.3	MEDI		0.002		The Payment Plugins for Stripe WooCommerce WordPress plugin before 4.0.12 does not validate the order key before adding order data to the JavaScript configuration it outputs on the front end, allowing unauthenticated users to obtain the billing details of any order, together with the secret that gates access to it, by iterating sequential order identifiers.
CVE-2026-80340	5.3	MEDI		0.002		The Payment Plugins for PayPal WooCommerce WordPress plugin before 2.0.26 does not validate the order key before adding order data to the JavaScript configuration it outputs on the front end, allowing unauthenticated users to obtain the secret that gates access to any order and, through it, that customer's billing and shipping details, by iterating sequential order identifiers.

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-84364	5.3	MEDI		0.004		Hono is a Web application framework that provides support for any JavaScript runtime. Prior to 4.13.5, when <code>parseBody()</code> expands dot-separated form field names into nested objects with dot-notation parsing enabled, it does not limit the nesting depth or the total number of intermediate objects created. Empty segments are preserved, so one deeply dotted field name can encode one nesting level per byte, while a large...
CVE-2026-84379	5.3	MEDI		0.003		HTTPX2 is a next generation HTTP client for Python. Prior to 2.11.0, <code>FileField.render_headers()</code> in <code>src/httpx2/httpx2/_multipart.py</code> directly interpolates attacker-controlled <code>content_type</code> values and custom headers from the <code>files=</code> three-element (filename, content, <code>content_type</code>) tuple and the <code>files=</code> four-element (filename, content, <code>content_type</code> , headers) tuple into multipart/form-data part headers without validating h...
CVE-2025-7062	5.2	MEDI		0.003		A stored cross-site scripting (XSS) vulnerability has been identified in the H5P module <code>`h5p-nodejs-library`</code> by Lumi Education UG in versions up to and including 10.0.4. The library allows users to upload H5P content that contains malicious JavaScript. This code is then executed in the browsers of other users who view the affected H5P content.
CVE-2026-40507	5.1	MEDI		0.003		OpenEMR before 8.3.0 contains a reflected cross-site scripting vulnerability in the patient portal template import handler. The <code>templateHtml</code> GET parameter is reflected into the page response without sanitization. An attacker can craft a URL that executes arbitrary JavaScript in the browser of any authenticated user with Forms Administration permissions who visits the link, enabling session hijacking.
CVE-2026-40508	5.1	MEDI		0.002		OpenEMR before 8.3.0 contains a stored cross-site scripting vulnerability in the patient portal template import handler that allows authenticated attackers with Forms Administration permissions to upload template files containing arbitrary HTML or JavaScript. Attackers can inject malicious scripts through the template upload functionality, which are stored without sanitization and execute in the browser of any oth...
CVE-2026-56126	5.1	MEDI		0.004		pfSense Plus before 26.07 and CE before 2.9.0 allow authenticated users with the Status: Monitoring privilege to inject arbitrary JavaScript via graph configuration parameters in <code>/status_monitoring.php</code> . Multiple POST parameters including <code>graph-left</code> , <code>graph-right</code> , <code>time-period</code> , <code>resolution</code> , <code>start-date</code> , <code>end-date</code> , <code>start-time</code> , <code>end-time</code> , <code>graph-type</code> , <code>invert</code> , and <code>refresh-interval</code> are concatenated and written to the global p...
CVE-2026-56127	5.1	MEDI		0.004		pfSense Plus before 26.07 and CE before 2.9.0 allow authenticated users with the Firewall: Rules: Edit privilege to inject arbitrary JavaScript via the <code>descr</code> parameter in <code>/firewall_rules_edit.php</code> . The firewall rule description is stored in the pfSense XML configuration with only backslash-escaping applied and no HTML sanitization, then rendered without encoding in the firewall log table in <code>/status_logs_filter.php</code>
CVE-2026-56128	5.1	MEDI		0.004		pfSense Plus before 26.07 and CE before 2.9.0 allow authenticated users with the Firewall: Schedules: Edit privilege to inject arbitrary JavaScript via the <code>descr</code> parameter in <code>/firewall_schedule_edit.php</code> . The schedule description is stored without HTML sanitization and subsequently inserted into an HTML attribute value in <code>/firewall_rules.php</code> with only single-quote escaping applied, permitting double-quote breakout....
CVE-2026-63105	5.1	MEDI		0.001		ReadyEcommerce before 4.5.2 contains a stored cross-site scripting (XSS) vulnerability that allows authenticated customers to inject malicious HTML payloads through the chat and support ticket messaging systems by exploiting unsanitized rendering via the <code>v-html</code> directive in <code>Messages.vue</code> , <code>RightChatSidebar.vue</code> , <code>SupportTicketMessages.vue</code> , and <code>SupportTicketDetails.vue</code> . Attackers can submit crafted message content that...
CVE-2026-67196	5.1	MEDI		0.002		Perspective 5.0.0 contains a cross-site scripting vulnerability in the built-in Debug plugin that allows attackers to inject arbitrary HTML and JavaScript by writing table cell values containing unescaped HTML markup, which are interpolated directly into <code>innerHTML</code> during CSV serialization rendering. Attackers can craft table rows with payloads such as unquoted attribute injections containing event handler attribut...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-67338	5.1	MEDI		0.002		JupyterLab before 4.5.9 contains a stored cross-site scripting vulnerability in the Extension Manager that fails to validate URI protocols in package metadata URLs. Attackers can publish malicious PyPI packages with javascript: URLs in project metadata that execute arbitrary JavaScript in the JupyterLab origin when users click the extension name.
CVE-2026-73037	5.1	MEDI		0.002		Next AI Draw.io 0.2.1 through 0.4.16 contains a reflected cross-site scripting vulnerability in the mcp query parameter that is interpolated without escaping into HTML and JavaScript. Attackers can craft malicious URLs to execute arbitrary JavaScript in the localhost origin, enabling exfiltration of diagram sessions and API data.
CVE-2026-81887	5.1	MEDI		0.005		Livewire is a full-stack framework for Laravel. From 3.0.0-beta.1 until 3.8.3 and 4.3.4, the dot-notated query-string parser in js/plugins/history/index.js, including fromQueryString() and insertDotNotatedValueIntoData(), accepts the __proto__, constructor, and prototype path segments and creates inherited objects. Client-side state handlers then access effects.html, effects.js, effects.xjs, and effects.scripts wi...
CVE-2026-84305	5.1	MEDI		0.001		sqlparse is a non-validating SQL parser module for Python. Prior to 0.6.0, sqlparse.format(sql, reindent=True) and sqlformat --reindent route attacker-controlled parenthesized tuple lists through ReindentFilter._get_offset() in sqlparse/filters/reindent.py, where _flatten_up_to_token() repeatedly rebuilds and joins the statement prefix. Thousands of offset calculations walk an expanding token tree, producing quadr...
CVE-2026-84967	5.1	MEDI		0.002	mongodb:mongodb	A component of the MongoDB extension for Visual Studio Code does not neutralize special characters in a connection string before that value is placed into a command line the extension composes for an integrated terminal. An unauthenticated remote unauthorized-user who persuades a developer to accept a user-supplied connection target, and then to open the extension's shell feature, can place characters of the unaut...
CVE-2026-86440	5.1	MEDI		0.001	misp-project:misp	Affected versions of MISP insufficiently validate URLs used by dashboard widgets, particularly the Button widget. The widget's URL is stored configuration controlled by a user. The previous renderer considered a URL safe if it appeared relative or if its parsed hostname matched the configured MISP hostname. That logic failed to reject dangerous schemes and URL forms that browsers normalize differently from PHP's...
CVE-2026-86742	5.1	MEDI		0.003	snipeitapp:snipe-it	Snipe-IT through 8.6.3 does not neutralize formula elements in the "unaccepted assets" acceptance report CSV export. ReportsController::postAssetAcceptanceReport builds the CSV by hand (stripping commas and joining rows manually) and, unlike the six sibling exports in the same controller, never applies League\Csv\EscapeFormula or honors the config('app.escape_formulas') setting. An authenticated low-privilege user...
CVE-2026-86745	5.1	MEDI		0.004	snipeitapp:snipe-it	Snipe-IT is an IT asset management application. In Snipe-IT master-branch builds after 8.6.3 (the code was never included in a tagged release), SettingsController::downloadLocationScopingReport streams the FMCS location-scoping mismatch report (GET /admin/settings/location-scoping-report.csv) through a bare fputcsv() call without applying League\Csv\EscapeFormula, unlike the other CSV exports which honor config('a...
CVE-2026-55425	5.0	MEDI		0.003		Graylog is a free and open log management platform. From 7.1.0 until 7.1.4 and 7.2.0-alpha.2, the System Catalog entity titles endpoint in graylog2-server/src/main/java/org/graylog2/rest/resources/system/contentpacks/titles/EntityTitleServiceImpl.java allows an authenticated user to request composite display fields without verifying that every selected field is readable. A user can retrieve protected values, inclu...
CVE-2026-62293	5.0	MEDI		0.002		HAPI FHIR is a complete implementation of the HL7 FHIR standard for healthcare interoperability in Java. Prior to 6.9.11, the hidden scan command concatenates attacker-controlled Implementation Guide titles, profile titles, and source references into scan.html without escaping in Scanner.java. As a result, a user who scans an attacker-supplied IG/profile and then opens or publishes the generated local/CI HTML repo...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-19729	4.9	MEDI		0.005		A flaw was found in the key provider component of the keycloak-services library, which is the core engine for the Red Hat Build of Keycloak. The issue occurs because a previous fix for path probing was incomplete, allowing a realm administrator to still submit arbitrary filesystem paths as keystore parameters. This can be used to determine the existence and readability of files on the server, potentially exposing ...
CVE-2026-40175	4.8	MEDI		0.019	axios:axios	Axios is a promise based HTTP client for the browser and Node.js. Versions prior to 1.15.0 and 0.3.1 are vulnerable to a specific gadget-style attack chain in which prototype pollution in a third-party dependency may be leveraged to inject unsanitized header values into outbound requests. This vulnerability is fixed in 1.15.0 and 0.3.1.
CVE-2026-53529	4.8	MEDI		0.002		LeafWiki is a self-hosted wiki. Prior to version 0.10.2, page titles returned by the search API could be rendered as raw HTML in the frontend. A user with editor or administrator permissions could create or modify a page title containing an HTML/JavaScript payload. When another user searched for a matching term, the payload could execute in the victim's browser. The impact depends on deployment configuration. With...
CVE-2026-67612	4.8	MEDI		0.001		OpenEMR through 8.2.0 contains a stored cross-site scripting vulnerability in the patient portal template system that allows authenticated administrators to inject arbitrary HTML and JavaScript by storing malicious payloads through the template save mode, which only filters literal PHP open tags. Attackers can exploit the lack of output encoding at the template retrieval endpoint combined with missing HttpOnly coo...
CVE-2026-71850	4.8	MEDI		0.002		Hono is a Web application framework that provides support for any JavaScript runtime. From 3.8.0 to 4.12.33, memo() from hono/jsx retains the result of a server side render and reuses it for later renders with comparator equal props, and request scoped values read inside the component take no part in that comparison, so a response can contain HTML rendered for another user's request. Components wrapped with memo()...
CVE-2026-71870	4.8	MEDI		0.001		pypdf is a free and open-source pure-python PDF library. Prior to 6.15.0, a crafted PDF can cause large memory consumption when pypdf/_cmap.py function parse_bfrange parses unusually large source-code or destination-string tokens in a font /ToUnicode CMap during text extraction. This issue is fixed in 6.15.0.
CVE-2026-84310	4.8	MEDI		0.001		pypdf is a free and open-source pure-python PDF library. Prior to 6.16.1, an attacker can craft a PDF that causes pypdf/_doc_common.py _get_outline to consume long runtimes and large amounts of memory when retrieving document outlines with large numbers of entries or deeply nested reused paths because the traversal lacked global entry-count and nesting-depth limits. This issue is fixed in version 6.16.1.
CVE-2026-84311	4.8	MEDI		0.001		pypdf is a free and open-source pure-python PDF library. Prior to 6.16.1, an attacker can craft a PDF that causes pypdf/_page.py PageObject._extract_text and PageObject.extract_xform_text to traverse a directed acyclic graph of reused form XObjects in which each form invokes a child multiple times, creating exponentially many traversal paths and causing long runtimes and large memory consumption. This issue is fix...
CVE-2026-69792	4.7	MEDI		0.002		Concurrent execution using shared resource with improper synchronization ('race condition') in Windows Win32K allows an authorized attacker to bypass a security feature locally.
CVE-2026-87602	4.7	MEDI		0.002	google:chrome, microsoft:windows	Out of bounds read in ANGLE in Google Chrome on on Windows prior to 153.0.8010.36 allowed a remote attacker to potentially read memory outside the sandbox via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-18741	4.6	MEDI		0.001		Worksuite SaaS versions prior to 6.0.14 contains a stored cross-site scripting vulnerability in the Asset Management module that allows authenticated administrators to inject arbitrary JavaScript by entering malicious payloads into the Location and Description fields when creating a new asset. Attackers can store crafted HTML script tags in the application database that execute automatically in the browsers of any...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-61607	4.6	MEDI		0.003		Grav API Plugin is a RESTful API for Grav CMS that provides full headless access to your site's content. Prior to 1.0.2, the Grav API plugin POST /api/v1/media pipeline in HandlesMediaUploads::processUploadedFile() validates an SVG filename extension but does not invoke Security::sanitizeSVG(). An attacker with api.media.write permission can store an SVG containing JavaScript, and the server returns the file as Co...
CVE-2026-9852	4.6	MEDI		0.002	hitachienergy:microscada_x_sys600	A CSV injection vulnerability exists in SYS600. Injected malicious formulas can add or modify data to the spreadsheet, insert links, exfiltrate data, and in some cases, depending on how the user has their environment configured, execute malicious code on the user's machine. To exploit this issue attackers would need a way to create arbitrary log messages. This could be achieved through normal functionality via SCI...
CVE-2026-69713	4.4	MEDI		0.003		Dependency on vulnerable third-party component in Windows Secure Boot allows an authorized attacker to bypass a security feature locally.
CVE-2026-52730	4.3	MEDI		0.002		Xibo is an open source digital signage platform with a web content management system and Windows display player software. Prior to 4.4.3, missing Authorization in Module::settingsForm allows to view (not change) super admin-restricted module settings and leak the full module entity. Exploitation of the vulnerability is possible on behalf of an authorized user who has access to the Module View feature, which are no...
CVE-2026-53487	4.3	MEDI		0.002		Kite is a Kubernetes dashboard. Prior to version 0.12.3, authenticated Kite users with any role can request `/api/v1/overview` for a cluster that their roles do not permit by selecting that cluster with `x-cluster-name`. The overview route is registered before `middleware.RBACMiddleware()` and `GetOverview` only checks `len(user.Roles) > 0`, so it returns aggregate Kubernetes inventory and capacity data from unaut...
CVE-2026-53541	4.3	MEDI		0.003		OliveTin gives access to predefined shell commands from a web interface. The `filterToDefinedArgumentsOnly` function in the executor is intended to discard any arguments not explicitly defined in the action's configuration. However, prior to commit ebffd9f040f791208aee1db2e5a8aecd1e3e603d, a special case allows any argument whose name starts with `ot_` to bypass this filter. While two system arguments (`ot_executi...
CVE-2026-54492	4.3	MEDI		0.003		Koel is a free, open-source music streaming solution. Prior to 9.7.0, the Subsonic-compatible createPodcastChannel.view route accepts an authenticated user's private URL because app/Http/Requests/Subsonic/CreatePodcastChannelRequest.php does not apply the SafeUrl validation used by the regular podcast API. app/Http/Controllers/Subsonic/CreatePodcastChannelController.php passes the URL to app/Services/Podcast/Podca...
CVE-2026-55696	4.3	MEDI		0.002		PrivateBin is an online pastebin where the server has zero knowledge of pasted data. Prior to 2.0.5, AttachmentViewer.setAttachment in js/privatebin.js uses getAttachmentMimeType to accept attacker-controlled MIME types and uses getBlobUrl to create a same-origin blob before setting attachmentLink's href for the Download attachment link. The SVG-only sanitization branch updates only the preview blob, so text/html,...
CVE-2026-55834	4.3	MEDI		0.003		Pocket ID is an OIDC provider that allows users to authenticate with their passkeys to services. From 2.6.0 until 2.9.0, frontend/src/routes/authorize/+page.ts reads the redirect_uri query parameter and frontend/src/routes/authorize/+page.svelte uses the raw callbackURL in redirectWithError when prompt=none cannot complete silent authorization. The client-side path only blocks javascript and data schemes and does ...
CVE-2026-61911	4.3	MEDI		0.002	cyrus:imap	An issue was discovered in Cyrus IMAP before 3.12.4. There is a Sieve mailbox existence oracle. An authenticated user could install a Sieve script that probed whether another user's private mailbox existed, or read the value of shared mailbox annotations, by observing which fileinto branch fired during LMTP delivery.
CVE-2026-62986	4.3	MEDI		0.002		OpenEXR is the reference implementation and specification for the EXR image file format, widely used in the motion picture industry. In versions 3.3.0 through 3.3.12 and 3.4.0 through 3.4.13, the PyOpenEXR Python bindings return stale heap data when reading a crafted deep scanline EXR that uses layer-prefixed RGB channels. With the default channel coalescing (separate_channels=False), the wrapper groups channels s...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-63466	4.1	MEDI		0.002		Unleash is an open-source feature management platform. Prior to 8.0.3, FeatureEventFormatterMd.format in src/lib/addons/feature-event-formatter-md.ts assigns Mustache.escape to an identity function before rendering action and path templates. Because Mustache.escape is process-wide, the assignment disables escaping for subsequent Mustache.render calls in email-service.ts, webhook.ts, datadog.ts, and new-relic.ts. A...
CVE-2026-71849	3.7	LOW		0.002		Hono is a Web application framework that provides support for any JavaScript runtime. From 4.7.0 to 4.12.33, the Proxy Helper proxy() function in hono/proxy does not remove response headers named by the origin's Connection header. Per RFC 9110 Section 7.6.1, an intermediary must remove the header fields listed in a message's Connection header field before forwarding the message, in addition to the well known hop b...
CVE-2026-73425	3.7	LOW		0.002		Astro is a web framework for content-driven websites. Prior to 8.1.2, the Astro Netlify adapter converts each image.remotePatterns entry into a regular expression written to .netlify/v1/config.json under images.remote_images for Netlify's Image CDN allowlist. In packages/integrations/netlify/src/index.ts, remotePatternToRegex() escapes dots in hostname values but interpolates literal pathname values without escapi...
CVE-2026-84367	3.7	LOW		0.003		joi is a schema description language and data validator for JavaScript. From 16.0.0 until 17.13.5 and 18.2.4, joi's lib/types/keys.js internals.rename() implementation used by object().rename() permits a schema that renames keys with a regular-expression source and a Joi.expression() or Joi.x() target that interpolates the pattern's own match data, combined with { multiple: true }, to derive a target from an attac...
CVE-2026-84368	3.7	LOW		0.003		joi is a schema description language and data validator for JavaScript. From 16.0.0 until 17.13.6 and 18.2.5, the @hapi/joi package through 17.1.1 and the successor joi package contain prototype pollution in lib/messages.js, where exports.compile() and exports.merge() reuse inherited objects for attacker-controlled language keys supplied through messages(), message(), prefs({ messages }), Joi.extend({ messages }),...
CVE-2026-69904	3.5	LOW		0.006	microsoft:sharepoint_server	Server-side request forgery (ssrf) in Microsoft Office SharePoint allows an authorized attacker to disclose information over a network.
CVE-2026-76961	3.5	LOW		0.001		SAP S/4HANA Finance (Advanced Payment Management) does not perform sufficient Cross-Site Request Forgery protection on certain requests, due to this an attacker with low privileges could craft a malicious link or page. If an authenticated victim interacts with it, unintended actions could be triggered on the web server on their behalf. This results in a low impact on confidentiality and integrity. There is no impa...
CVE-2026-87525	2.7	LOW		0.001	google:chrome, microsoft:windows	Out of bounds read in Chromoting in Google Chrome on on Windows prior to 153.0.8010.36 allowed a local attacker to read memory outside the sandbox via a local program. (Chromium security severity: High)
CVE-2026-73087	2.3	LOW		0.003		Dozzle is a realtime log viewer for docker containers. From 10.5.2 until 10.6.15, the isBlockedIP SSRF guard in internal/notification/dispatcher/webhook.go, used by safeDialContext for webhook notification URLs, does not inspect IPv4 addresses embedded in 6to4, NAT64, Teredo, or IPv4-compatible IPv6 addresses, allowing an authenticated user to reach loopback or link-local targets that the guard intends to block. T...
CVE-2026-73491	2.3	LOW		0.002		Loofah is a general library for manipulating and transforming HTML/XML documents and fragments, built on top of Nokogiri. From 2.25.0 until 2.25.2, Loofah::HTML5::Scrub.allowed_uri? does not reject javascript: URIs whose scheme is split or prefixed with the HTML5 named whitespace character references 	 or
. CGI.unescapeHTML leaves those references intact, so allowed_uri? reports the URL safe even thou...
CVE-2026-73492	2.3	LOW		0.002		Loofah is a general library for manipulating and transforming HTML/XML documents and fragments, built on top of Nokogiri. From 2.25.0 until 2.25.2, Loofah::HTML5::Scrub.allowed_uri? does not reject javascript: or vbscript: URIs whose scheme is split by semicolon-less numeric character references such as :, 	,
, or . CGI.unescapeHTML leaves these references encoded, so allowed_uri? reports the URL safe...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-86441	2.3	LOW		0.002	misp-project:misp	Affected versions of MISP contain inconsistent authorization checks across dashboard widgets that display organisation information. Several organisation-related widgets did not honor Security.hide_organisation_index_from_users. As a result, authenticated users without the perm_sharing_group permission could enumerate organisations even though the normal organisation index was intentionally hidden from them. Th...
CVE-2026-0292	2.1	LOW		0.001	microsoft:windows, paloaltonetworks:prisma_access_agent	An authentication bypass vulnerability in the network driver of Palo Alto Networks Prisma® Access Agent on Windows enables a local administrator to bypass security inspection, subsequently allowing them to inject and intercept arbitrary network traffic. The Prisma Access Agent on Linux, macOS, iOS, Android, and Chrome OS is not affected.
CVE-2026-73427	2.1	LOW		0.003		Trix is a what-you-see-is-what-you-get rich text editor for everyday writing. Prior to 2.1.18, Trix is vulnerable to cross-site scripting when a crafted application/x-trix-document JSON payload is dropped into an editor using the fallback Level0InputController, such as an embedded WebView without Input Events Level 2 support. The StringPiece.fromJSON method trusts href attributes from the JSON payload without sani...
CVE-2026-86512	2.1	LOW		0.002		A vulnerability was identified in java-json-tools json-patch up to 1.13. This affects the function CopyOperation.apply/MoveOperation.apply of the file src/main/java/com/github/fge/jsonpatch/CopyOperation.java of the component Copy Move Operations. The manipulation leads to improper access controls. Remote exploitation of the attack is possible. The exploit is publicly available and might be used. The project was i...
CVE-2026-86517	2.1	LOW		0.002		A flaw has been found in itsourcecode Sales and Inventory System 1.0. The impacted element is the function mysqli_query of the file /pages/us_searchfrm.php. Executing a manipulation of the argument ID can lead to sql injection. It is possible to launch the attack remotely. The exploit has been published and may be used.
CVE-2026-48791	2.0	LOW		0.001		sigstore-java is a sigstore java client for interacting with sigstore infrastructure. Version 2.0.0 erroneously removed verification of the integrated (Rekor entry) time) against the Fulcio certificate. Version 2.1.0 re-added this verification with enhancements that adhere to the Sigstore verification spec. The old sigstore-conformance test for this check was built incorrectly. This vulnerability impacts only user...
CVE-2026-53759	2.0	LOW		0.003		linuxfabrik-lib provides Python modules for database access, caching, shell execution, and API integrations. Prior to version 4.2.0, db_sqlite.py created SQLite databases at predictable paths in the shared /tmp directory and followed attacker-created symbolic links at those paths. An attacker who controls a local monitoring account can create a symlink such as /tmp/linuxfabrik-monitoring-plugins-docker-stats.db an...
CVE-2026-0291	1.1	LOW		0.001	linux:linux_kernel, paloaltonetworks:prisma_access_agent	An improper link resolution before file access vulnerability exists in the Palo Alto Networks Prisma® Access Agent on Linux platforms that enables a local low privileged user to delete system files in a limited scope and disable Prisma Access Agent. The Prisma Access Agent on macOS, Windows, iOS, Android, and Chrome OS is not affected.
CVE-2026-0289	0.5	LOW		0.002	paloaltonetworks:prisma_browser	A security bypass vulnerability in the Account Protection feature of Palo Alto Networks Prisma® Browser enables a user to bypass intended security controls.
CVE-2026-0290	0.5	LOW		0.001	paloaltonetworks:prisma_browser	An information disclosure vulnerability in the Account Protection feature of Palo Alto Networks Prisma® Browser enables a local attacker to view sensitive data.
CVE-2026-4765	0.0	NONE		0.004		Self Cross-Site Scripting (Self-XSS) vulnerability in the RD Station Conversas chat feature. The vulnerability lies in the 'name' parameter of the initialisation process due to incorrect sanitisation of user-supplied input. Exploitation allows specially crafted JavaScript code to be injected, which is executed within the context of the user's own session who provides the payload. The demonstrated impact is limited...

CVE	CVSS	Sev	KEV	EPSS	Vendor / Product	Description
CVE-2026-80915				0.002		In the Linux kernel, the following vulnerability has been resolved: drm/xe: Fix DPT allocation paths. Remove the fallback for VRAM to system memory, I tested it and that doesn't work at all, only a black screen with pipe fault errors were observed. On systems with media GT, extra latency is added when accessing stolen memory when the GT is in MC6. Since we additionally aren't counting how much memory is used fo...
CVE-2026-80916				0.002		In the Linux kernel, the following vulnerability has been resolved: kcov: fix data corruption and race conditions on PREEMPT_RT syzbot is reporting KCOV state corruption on PREEMPT_RT kernels, for the temporary storage used for saving/restoring remote KCOV state is currently allocated as the per-CPU area. On PREEMPT_RT kernels, softirq handlers run as preemptible task threads (e.g., ksoftirqd). If a softirq con...
CVE-2026-80917				0.002		In the Linux kernel, the following vulnerability has been resolved: PCI: host-generic: Fix NULL pointer dereference on 32-bit CAM systems On 32-bit systems the config space is too large to ioremap in one go, so pci_ecam_create() maps each bus segment separately and relies on the ->add_bus callback (pci_ecam_add_bus) to populate the per-bus mapping in cfg->winp[]. pci_ecam_map_bus() then uses that mapping as the ...
CVE-2026-80918				0.002		In the Linux kernel, the following vulnerability has been resolved: HID: core: fix number/pointer type confusion on long items When fetch_item() is called by hid_scan_report() on an item with HID_ITEM_TAG_LONG, it stores a pointer to the item data in item->data.longdata instead of storing a value directly in item->data.{u8/u16/u32}. When item_udata() or item_sdata() encounters such an item, it incorrectly assum...
CVE-2026-80919				0.001		In the Linux kernel, the following vulnerability has been resolved: drm/amdgpu: fix recursive ww_mutex acquire in amdgpu_devcoredump_format When dumping IB contents from a hung job, amdgpu_devcoredump_format() acquired the VM root PD's reservation via amdgpu_vm_lock_by_pasid() and then, for each IB, called amdgpu_bo_reserve() on the BO backing the IB. Both reservations are reservation_ww_class_mutex objects and ...
CVE-2026-80920				0.002		In the Linux kernel, the following vulnerability has been resolved: io_uring: defer eventfd signaling when queued from a wakeup handler io_req_local_work_add() signals the CQ ring eventfd inline when it is the one to push the first entry onto ->work_list. For DEFER_TASKRUN rings that add is frequently done from a waitqueue wakeup handler, where an arbitrary waitqueue lock is held. eventfd_signal_mask() only ref...
CVE-2026-80922				0.002		In the Linux kernel, the following vulnerability has been resolved: crypto: qcom-rng - Allow zero as a random number Zero is a valid random number and needs to be allowed. Otherwise the output is distinguishable from random.
CVE-2026-80923				0.002		In the Linux kernel, the following vulnerability has been resolved: xhci: dbgtty: Fix unregister on tty_register_driver() failure If tty_register_driver() fails, it drops the reference, but fails to set the global dbc_tty_driver to NULL, causing the unregister to be called again when module exits. On module unload dbc_tty_exit() only gates its cleanup on the driver pointer being non-NULL, so it operates on the ...
CVE-2026-80925				0.002		In the Linux kernel, the following vulnerability has been resolved: vlan: fix skb_under_panic and races when toggling HW VLAN offload Toggling hardware VLAN TX offload (NETIF_F_HW_VLAN_CTAg_TX or NETIF_F_HW_VLAN_STAg_TX) on a lower device invokes vlan_transfer_features(), which dynamically changed vlandev->hard_header_len. This causes two issues: 1. Lockless TX paths (e.g. packet_snd in af_packet.c, ip6_finish_...